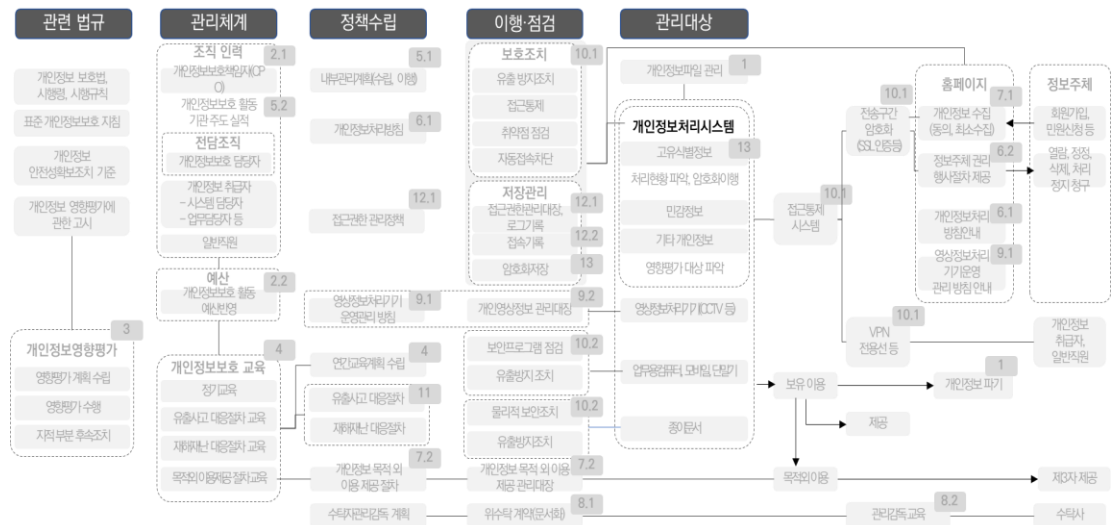


개인정보보호법 주요내용

믿을 수 있는 개인정보 활용, 신뢰사회의 기본입니다
Privacy by Trust, Trust by Privacy



개인정보, 이해관계자, 개인정보보호법



개인정보 보호법 주요내용

0. 교육 전 참고사항

개인정보보호 관련 가이드라인(KISA 지식플랫폼, 가이드라인)

고객서비스 지식플랫폼 사업소개 주요성과 알림마당 ESG 열린경영 KISA 소개



○ 가이드라인

인터넷 진흥 및 이용 활성화	개인정보보호	기업정보보호
보안취약점 및 침해사고 대응	융합보안	암호 기술

총 8건 | 페이지 1 / 1

제목 검색어 입력 검색

번호	제목	등록일	조회수	첨부파일
8	자동처리되는 개인정보 보호 가이드라인	2021-02-24	3710	
7	인터넷 자기계사물 접근배제요청권 가이드라인	2021-02-24	2906	
6	온라인 개인정보 처리 가이드라인	2021-02-24	5424	
5	자율규제단체 참여사를 위한 개인정보 처리 가이드	2016-02-25	2084	
4	개인정보 유출 대응 매뉴얼	2016-02-24	6547	
3	개인정보 수집 최소화 가이드라인	2016-02-24	6213	

지식플랫폼

연구보고서

동향분석

정기간행물

실태조사 및 통계

역대발간물

법령-가이드라인

- 법령 고시
- 가이드라인
- 안내서
- 사례집, 편람 등

자료 : KISA 지식플랫폼(<https://www.kisa.or.kr/20601>)

개인정보 보호법 주요내용



0. 교육 전 참고사항

🔒 개인정보보호 포털

 개인정보 포털

QUICK | 개인 QUICK | 사업자 이용자가이드

🏠 ☰

개인정보보호란? 개인서비스 기업·공공 서비스 교육 자료 알림/소통

🔍

오늘 하루도
안전하고 즐겁게
Lock and Roll!



계정정보 유출 2차 피해를 방지하기 위한
털린 내 정보 찾기 서비스
를 시작합니다.

Korean ID Checker
털린 내 정보 찾기 서비스 kidc.eprivacy.go.kr

개인정보보호위원회 KISA 한국인터넷진흥원

 개인정보침해 신고센터

 개인정보배움터

 털린 내 정보 찾기

 웹사이트 회원탈퇴

 지우개서비스

개인정보보호 자율규제에 대해 알아볼까요? 개인정보보호 침해유출 현황을 확인해보세요! 개인정보와 관련된 다툼이 있나요?

* <https://www.privacy.go.kr/front/main/main.do>

4

Contents

- 1 개인정보 보호법 개요
- 2 개인정보 보호법 개정내용
- 3 개인정보의 처리 주요 내용
- 4 개인정보의 안전한 관리
- 5 정보주체의 권리보장 및 피해구제



1

개인보호 보호법 개요

(개인정보 보호법 제1장)



개인정보 보호법 주요내용



1. 개인정보 보호법 개요

🔒 개인정보란? (제2조)

<그 자체의 식별 가능성>

- 가명처리를 하여 원래의 상태로 복원하기 위한 추가 정보의 사용·결합 없이는 특정 개인을 알아 볼 수 없는 정보

<타 정보의 결합을 통한 식별 가능성>

- 다른 정보의 입수 가능성 등 개인을 알아보는 데 소요되는 시간, 비용, 기술 등을 합리적으로 고려

<정보를 통한 식별 가능성>

- 해당정보를 처리하는 자의 입장에서 합리적으로 활용 될 가능성이 있는 수단을 고려
(cf. 고유식별정보, 주민등록번호)



<정보가 지칭하는 대상>

- 자연인에 관한 정보만 해당
- 국적이나 신분에 관계없이 법 적용대상
(Ex. 외국인, 피의자 정보)

<정보가 지칭하는 대상>

- 법인 또는 단체의 정보는 해당 없음
- 단, 연관성에 따라 개인정보가 될 수 있음
(Ex. 대표자 성명, 담당자 전화번호)

<정보의 형태>

- 전자, 수기 등 형태와 처리방식은 무관
- 주관적 평가, 허위정보라도 해당될 수 있음
(Ex. 평가표, 예명)

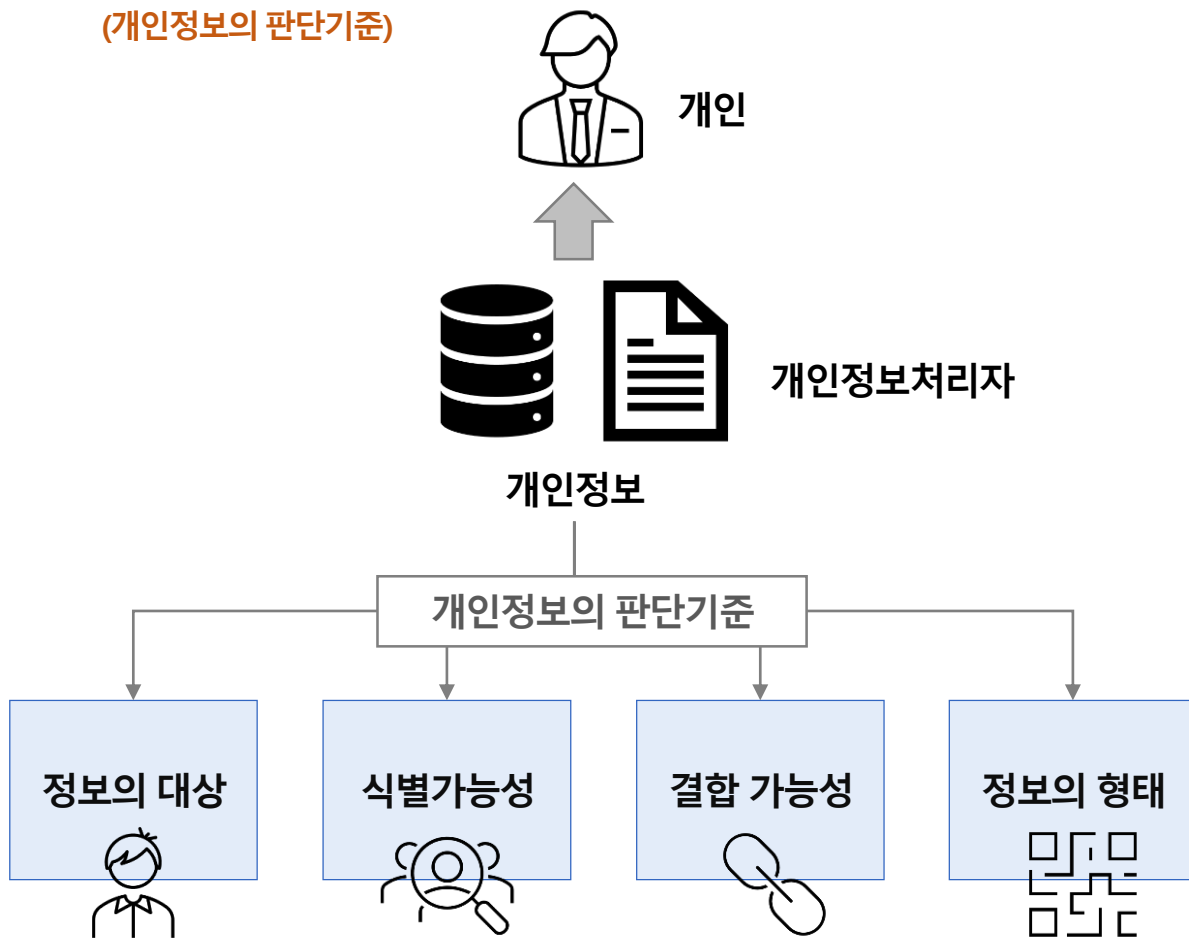
개인정보 보호법 주요내용



1. 개인정보 보호법 개요

🔒 개인정보에 관한 잘못된 판단기준 예

(개인정보의 판단기준)



(개인정보에 대한 잘못된 판단기준)



개인정보 보호법 주요내용



1. 개인정보 보호법 개요

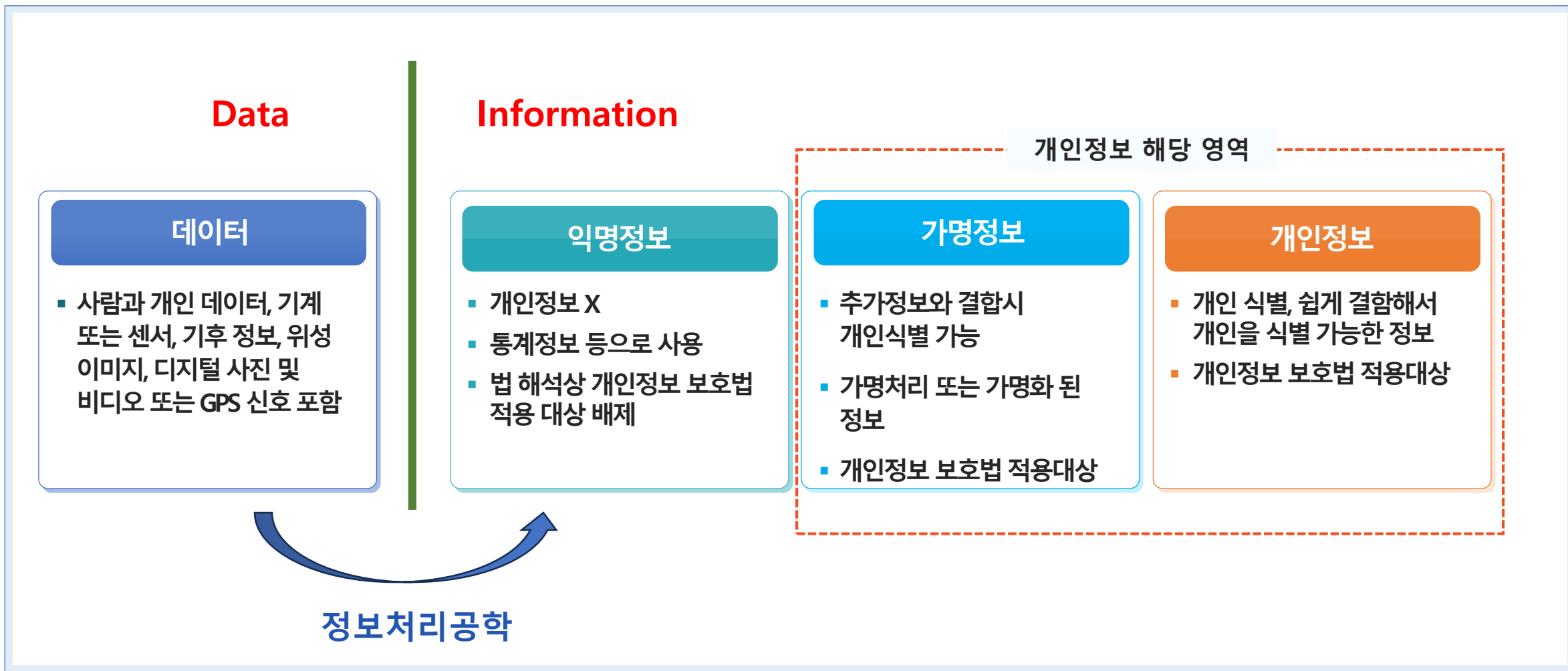
개인정보의 예시

구분		내용
인적사항	일반정보	성명, 주민등록번호, 주소, 연락처, 생년월일, 출생지, 성별 등
	가족정보	가족관계 및 가족구성원 정보 등
신체적 정보	신체정보	얼굴, 홍채, 음성, 유전자 정보, 지문, 키, 몸무게 등
	의료·건강 정보	건강상태, 진료기록, 신체장애, 장애등급, 병력, 혈액형, IQ, 약물테스트 등의 신체검사 정보 등
정신적 정보	기호·성향 정보	도서·비디오 등 대여기록, 잡지구독정보, 물품구매내역, 웹사이트 검색내역 등
	내면의 비밀 정보	사상, 신조, 종교, 가치관, 정당·노조 가입여부 및 활동내역 등
사회적 정보	교육정보	학력, 성적, 출석상황, 기술 자격증 및 전문 면허증 보유내역, 상벌기록, 생활기록부, 건강기록부 등
	병역정보	병역여부, 군번 및 계급, 제대유형, 근무부대, 주특기 등
	근로정보	직장, 고용주, 근무처, 근로경력, 상벌기록, 직무평가기록 등
	법정정보	전과·범죄 기록, 재판 기록, 과태료 납부내역 등
재산적 정보	소득정보	봉급액, 보너스 및 수수료, 이자소득, 사업소득 등
	신용정보	대출 및 담보설정 내역, 신용카드번호, 통장계좌번호, 신용평가 정보 등
	부동산정보	소유주택, 토지, 자동차, 기타소유차량, 상점 및 건물 등



1. 개인정보 보호법 개요

데이터 VS 정보



개인정보 보호법 주요내용



1. 개인정보 보호법 개요

개인정보 보호법 주요 구성

목차	주요 내용
제1장 총칙	목적, 정의, 보호 원칙, 정보주체의 권리
제2장 개인정보 보호정책의 수립 등	개인정보보호위원회의 구성, 업무 등
제3장 개인정보의 처리	
제1절 개인정보의 수집, 이용, 제공 등	개인정보의 수집·이용, 제공, 수집 출처 통지, 이용·제공 내역 통지, 파기, 아동의 개인정보보호
제2절 개인정보의 처리 제한	민감정보, 고유식별정보, 주민등록번호, [고정형, 이동형] 영상처리기기, 개인정보 처리위탁
제3절 가명정보의 처리에 관한 특례	가명정보 처리, 결합, 안전조치, 적용 제외
제4절 개인정보의 국외 이전	개인정보 국외 이전 요건, 국외 이전 중지
제4장 개인정보의 안전한 관리	안전조치, 개인정보 처리방침, CPO/국내대리인, ISMS-P, 영향평가, 유출통지·신고, 노출 삭제
제5장 정보주체의 권리 보장	열람권, 정정·삭제권, 처리정지권, 동의철회권, 전송요구권, AI결정 대응권, 손해배상
제7장 개인정보 분쟁조정위원회	개인정보 분쟁조정위원회 구성, 업무, 조정 신청, 사실 조사, 분쟁 조정
제8장 개인정보 단체소송	단체소송의 대상, 요건, 진행
제9장 보칙	적용 제외, 금지행위, 사전 실태점검, 과징금, 고발 및 징계권고, 개선권고
제10장 벌칙	형사처벌, 과태료



1. 개인정보 보호법 개요

개인정보 보호 원칙(제3조)

- 1 처리 목적의 명확화, 목적 내에서 적법하고 정당하게 최소 수집
- 2 처리 목적 내에서 처리, 목적 외 활용 금지
- 3 처리 목적 내에서 정확성·완전성·최신성 보장
- 4 정보주체의 권리침해 위험성 등을 고려하여 안전하게 관리
- 5 개인정보 처리사항 공개, 정보주체의 권리보장
- 6 사생활 침해 최소화 방법으로 처리
- 7 가명/익명처리가 가능한 경우 가명/익명으로 처리
- 8 개인정보처리자의 책임 준수, 정보주체의 신뢰성 확보



1. 개인정보 보호법 개요

정보주체의 권리(제4조)

- 1 개인정보의 처리에 관한 정보를 **제공받을 권리**
- 2 개인정보의 처리에 관한 동의 여부, 동의 범위 등을 **선택, 결정할 권리**
- 3 개인정보의 처리 여부 확인, 개인정보 **열람을 요구할 권리**(사본 발급 포함)
- 4 개인정보의 **처리 정지, 정정·삭제 및 파기를 요구할 권리**
- 5 개인정보의 처리로 인한 **피해를 신속, 공정하게 구제받을 권리**
- 6 **완전히 자동화된** 개인정보 처리에 따른 **결정을 거부하거나 그에 대한 설명 등을 요구할 권리**

개인정보 자기결정권 >

자신에 관한 정보가 언제, 어떻게, 어느 범위까지 수집, 이용, 공개될 수 있는지를 정보주체가 스스로 통제, 결정할 수 있는 권리



1. 개인정보 보호법 개요

타 법률과의 관계(제6조)

▶ 개인정보 보호법은 개인정보 보호 분야의 일반법

- ✓ 사회 전반의 개인정보 보호를 규율
- ✓ 모든 공공기관, 사업자, 법인, 단체, 개인 등

▶ 다른 법률에 특별한 규정이 있는 경우

- ✓ 해당 법률의 규정을 우선 적용
※ 위치정보법, 신용정보법, 전자금융거래법, 의료법 등



2

개인정보 보호법 개정내용

(2023. 9. 15. 시행)



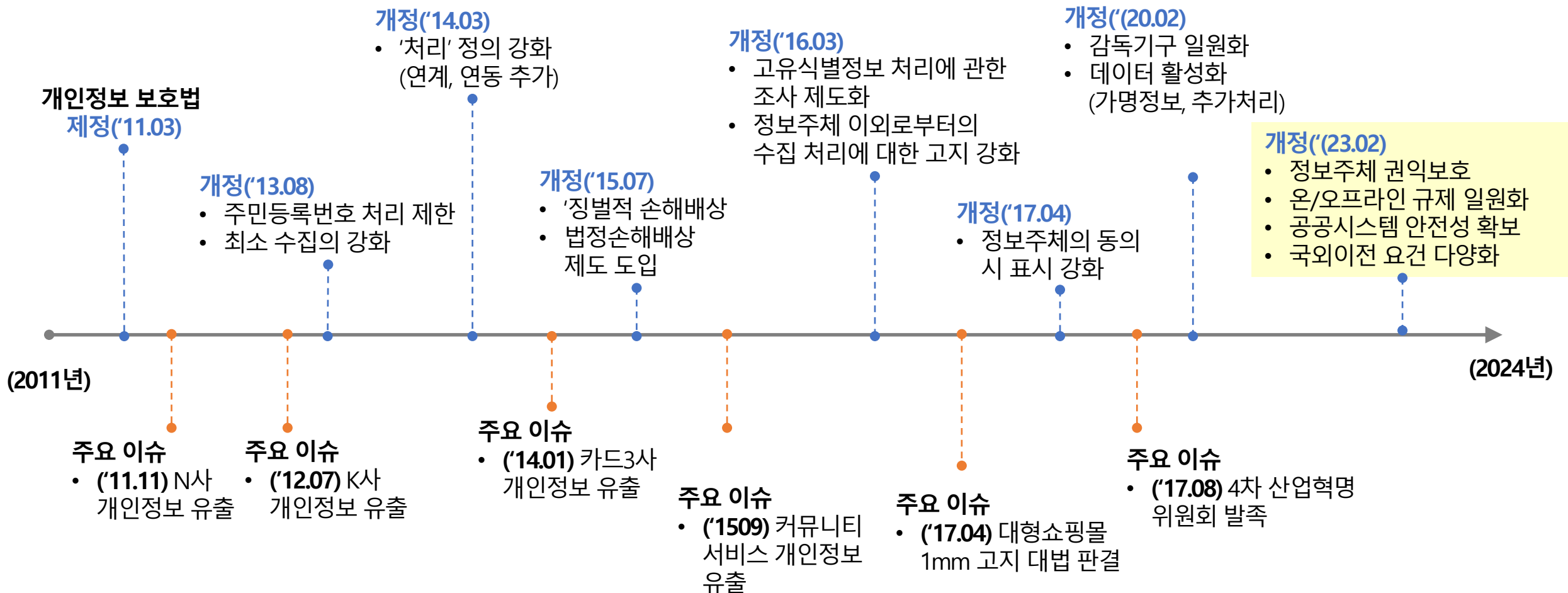
개인정보 보호법 주요내용



2. 개인정보 보호법 개정내용

🔒 개인정보 보호법 제·개정 연혁

▶ 개인정보 관련 사건사고와 개인정보 보호법 개정 현황





2. 개인정보 보호법 개정내용

개인정보 보호법 개정 주요 사항(1/2)

정보주체의 권익 보호

1

국민의 생명·신체 등
보호를 위한 법 체계 정비

2

개인정보 처리 요건 개선
및 처리방침 평가 도입

3

개인정보
분쟁조정 강화

4

손해배상청구소송 시
국민의 정보 접근권 강화

온·오프라인 이중 규제 등 개선

1

영상정보처리기기
운영기준 개선

2

수집 출처 통지 및 이용·
제공 내역 통지 제도 합리화

3

14세 미만 아동의
개인정보 보호 확대

4

개인정보 유출 등의
신고·통지 일원화

5

안전조치 기준
일원화

6

개인정보 파기
특례 정비

7

벌칙 규정
개선





2. 개인정보 보호법 개정내용

🔒 개인정보 보호법 개정 주요 사항(2/2)

공공기관 안전성 강화 등

1

주요 공공시스템
안전조치 강화

2

공공기관 개인정보파일
등록 확대

3

공공기관 개인정보
영향평가 개선

4

통계법 적용 제외
규정개선

5

처리위탁·재위탁 시
개인정보 보호 개선

글로벌 스탠다드

1

국외 이전 다양화 및 이전 중지명령 도입

2

과징금 제도 개선

* <https://www.pipc.go.kr/np/cop/bbs/selectBoardArticle.do?bbsId=BS213&mCode=C040050000&nttId=9149>

3

개인정보의 처리 주요내용

(개인정보 보호법 제3장)





3. 개인정보의 처리

🔒 개인정보 처리단계와 법령



수집·이용(15조)

최소 수집(16조)

아동의 개인정보 처리(22조의2)

제3자 제공(17조)

목적 외 이용·제공 제한(18조)

처리위탁(26조)

안전조치 의무(29조)

처리방침(30조)
처리방침평가(30조의2)
보호책임자(31조)

파기(21조)

- 처리제한 -
민감정보(23조)
고유식별정보(24조)
주민등록번호(24조의 2)

국외이전(28조의8)

영업양도·양수(27조)
(민간)

개인정보 유출 통지·신고
(34조)

개인정보파일 등록
(32조)(공공기관)

이용/제공 내역통지
(20조의2조의8)

손해배상보장
(39조)

노출정보 차단, 삭제
(34조의2)

국내대리인 지정
(제31조의2)



3. 개인정보의 처리

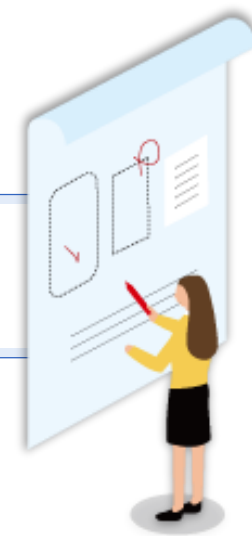
개인정보 수집·이용(제15조)

※ 민감정보, 고유식별정보, 주민등록번호는 제15조, 제17조, 제18조 해당 없음!

1 정보주체의 동의를 받은 경우

※ 동의 받을 때 고지 의무 사항 (위반 시 3천만원 이하의 과태료)

① 수집·이용 목적 ② 수집 항목 ③ 보유·이용 기간 ④ 동의 거부 권리 및 동의거부 시 불이익 내용



2 법률의 특별한 규정, 법령상 의무 준수를 위해 불가피한 경우

3 공공기관이 법령 등에서 정한 소관업무를 위해 불가피한 경우

4 정보주체와 체결한 계약을 이행하거나 계약을 체결하는 과정에서 정보주체의 요청에 따른 조치를 이행하기 위하여 필요한 경우

5 명백히 정보주체 등의 급박한 생명, 신체, 재산의 이익을 위해 필요한 경우

6 개인정보처리자의 정당한 이익 달성을 위해 필요한 경우로서, 명백하게 정보주체의 권리보다 우선하는 경우

7 공중위생 등 공공의 안전과 안녕을 위하여 긴급히 필요한 경우



3. 개인정보의 처리

🔒 개인정보 수집·이용(제15조)

▶ 정보주체와 체결한 계약을 이행하기 위해 필요한 경우(사례)

- 인터넷 쇼핑몰이 고객으로부터 구매상품 주문을 받아 결제-배송-AS 등 계약 이행을 위해 주소, 연락처, 결제 정보 등을 수집하여 이용하는 경우
- 판매한 상품에 대한 AS 상담을 위해 전화한 고객의 성명, 연락처, 상품정보 등을 수집하여 이용하는 경우
- 회의 참석자 등에게 참석수당을 지급하기 위해 이름, 계좌정보, 연락처 등을 수집하여 수당지급에 이용하는 경우
- 백화점에서 상품구매 및 배송서비스를 위해 결제정보(카드정보 등)와 배송정보(주소, 연락처) 등 계약 이행을 위해 '불가피하게' 필요한 개인정보 외에 오배송 등 방지를 위해 이름, 이메일, 집전화번호, 배송희망시간 등의 개인정보를 수집하여 배송목적으로 이용하는 경우
- 아파트 관리사무소가 아파트 입주자와 아파트 관리서비스 계약 체결 및 이행을 위해 세대주 이름, 연락처, 차량번호 등 불가피하게 필요한 개인정보 외에 아파트 관리서비스 제공을 위해 필요한 범위 안에서 거주자수, 반려견 정보 등의 개인정보를 수집하여 이용하는 경우
- 맞춤형 추천이 계약의 본질적인 내용인 경우로서 서비스 이용계약에 따라 맞춤형 추천을 제공하기 위해 이용자의 검색기록 등을 수집하여 이용하는 경우
- 디지털 서비스 이용자 보호를 목적으로 보안위험, 악용사례(스팸, 멀웨어, 불법 콘텐츠 등) 등 감지 및 예방을 위해 서비스 이용계약에 따라 이용자의 개인정보를 수집하여 이용하는 경우



3. 개인정보의 처리

개인정보 수집·이용(제15조)

▶ 정보주체와 체결한 계약을 이행하기 위해 필요한 경우(사례)

- 인터넷서비스 이용을 위해 회원가입을 요청한 정보주체와의 이용계약 체결을 위해 이름, 연락처, 생성 아이디 등의 개인정보를 수집하는 경우
- 공인중개사가 부동산거래 중개 계약 체결을 위해 부동산 소유자, 권리관계 등을 미리 조사·확인하기 위해 개인정보를 수집하는 경우
- 회사가 취업지원자와 근로계약 체결 전에 지원자의 이력서, 졸업증명서, 성적증명서 등 정보를 수집·이용하는 경우

* 개인정보 보호법 및 시행령 개정사항 안내(2023.12.29, 개보위)



3. 개인정보의 처리

🔒 개인정보의 수집 제한(제16조)

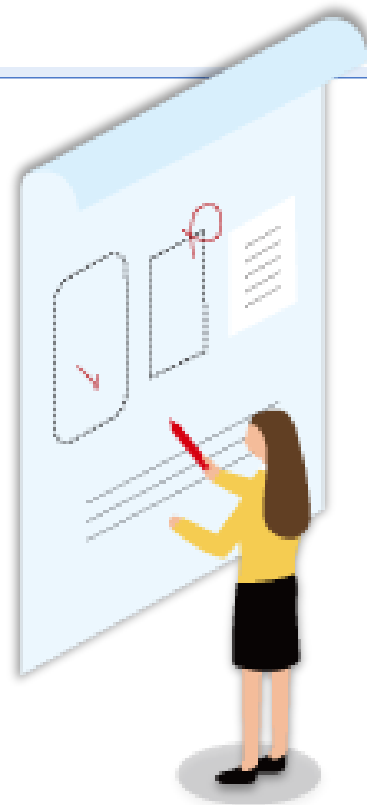
➤ 필요 최소한의 개인정보 수집

※ 정보주체의 동의를 받거나 법령의 처리 근거 또는 계약의 체결·이행 등을 위해 불가피하게 개인정보 수집하는 경우에도 처리 목적 달성에 필요한 최소한의 개인정보만을 수집

➤ 최소한의 개인정보 수집이라는 입증책임은 개인정보처리자가 부담

➤ 필요 최소한의 정보 외의 개인정보 수집에는 동의 거부 가능

➤ 최소한의 개인정보 이외의 개인정보 수집에 동의하지 않는다는 이유로 재화 등 제공 거부 금지 (위반시 3천만원 이하의 과태료)





3. 개인정보의 처리

🔒 동의 받는 방법(제22조)

- ▶ 정보주체(법정대리인 포함)의 동의를 받을 때에는 각각의 동의사항을 구분하여 정보주체가 이를 명확하게 인지할 수 있도록 알리고 동의를 받아야 함
- ▶ 정보주체의 동의 없이 처리할 수 있는 개인정보와 정보주체의 동의가 필요한 개인정보를 구분

- ✓ 개인정보의 수집·이용, 개인정보의 제3자 제공, 민감정보의 처리, 고유식별정보의 경우
- ✓ 동의 없이 처리 가능한 개인정보라는 입증책임은 개인정보처리자에게 있음

- ▶ 홍보나 마케팅 등의 이유로 개인정보 처리 동의를 받으려 할 때는 정보주체가 이를 명확하게 인지할 수 있도록 알리고 동의를 받아야 함
- ▶ 선택적으로 동의할 수 있는 사항을 동의하지 않는다는 이유로 재화 또는 서비스의 제공 거부 금지 (위반 시 3천만원 이하의 과태료)
- ▶ 만 14세 미만 아동의 개인정보를 처리하려면 법정대리인의 동의를 받아야 함 (위반 시 5천만원 이하의 과태료)

- ✓ 법정대리인의 동의를 받기 위해 필요한 최소한의 정보(성명, 연락처)는 해당 아동으로부터 직접 수집할 수 있음





3. 개인정보의 처리

🔒 동의 받는 방법(제22조)

▶ 동의서에 명확히 표시하여야 하는 사항

- ✓ 재화나 서비스의 **홍보 및 판매 권유** 등을 위해서 개인정보를 이용하여 정보주체에게 연락할 수 있다는 사실
- ✓ 개인정보 중 다음의 사항
 - **민감정보, 여권번호, 운전면허번호, 외국인등록번호**
- ✓ 개인정보의 **보유 및 이용 기간**(제공 시에는 제공받는 자의 보유 및 이용기간)
- ✓ 개인정보를 제공받는 자 및 개인정보를 제공받는 자의 **개인정보 이용 목적**



▶ 표시방법(전자문서와 서면동의 시)

- ✓ 글씨는 9포인트 이상(온라인 화면에서는 3mm이상)의 크기로 하되 다른 내용보다 20% 이상 크게 할 것
- ✓ 다른 색의 글씨, 굵은 글씨 또는 밑줄 등을 사용하여 명확히 드러나게 할 것
- ✓ 중요한 내용이 많은 경우에는 별도로 요약하여 제시할 것





3. 개인정보의 처리

🔒 개인정보 처리 동의서 작성 시 점검사항

▶ 작성 전 확인사항

No.	확인사항	고려사항
1	업무처리에 필요한 개인정보 확인	최소한의 개인정보, 민감정보, 고유식별정보의 처리 여부
2	동의가 필요한지 여부 확인	동의 필요 여부의 확인
3	개인정보의 보유기간 확인	개인정보의 보유기간 확인
4	개인정보의 제3자 제공 여부 확인	제3자 제공 여부, 동의 필요 여부 확인 필요
5	개인정보 처리업무 위탁 여부 확인	위탁사실, 위탁내용, 수탁자 등의 처리방침 게시 연계
6	개인정보 목적 외 이용·제공 여부 확인	동의받은 사항의 변경, 별도 동의 필요 여부 확인
7	동의 거부 시 불이익 확인	불이익 범위 여부의 확인

▶ 동의 후 조치사항

No.	확인사항	고려사항
1	동의 의사 확인	동의받은 사실의 입증
2	동의 입증	
3	필수 선택항목의 구분	특례조항

▶ 자동 수집되는 개인정보의 동의 필요 예

- ✓ 자동수집장치에 의해 수집하는 경우라도 서비스 제공계약 이행과는 무관한 목적으로 이용 하기 위해 개인정보를 수집하는 경우 선택동의 항목으로 분류하여 별도의 동의 필요
- ✓ 쿠키를 통해 수집하는 행태정보를 개인별 맞춤형 광고에 활용하고자 하는 경우 등



3. 개인정보의 처리

🔒 개인정보 처리 동의 시 잘못된 사례

▶ 동의 거부 시 불이익 고지가 미흡한 잘못된 사례

▶ 개인정보 수집·이용 동의

○○○○○는 다음과 같은 목적을 위하여 개인정보를 수집하고 있습니다.

1. 개인정보 수집 목적 및 수집 항목

① 회원가입

- 회원제 서비스 이용에 따른 본인 식별 : 성별, 아이디, 중복확인정보, 생년월일, 비밀번호, 이메일, 주소, 전화번호
- 맞춤형 서비스 제공을 위한 자료 : 생년월일, 이메일, 휴대전화번호

② 서비스 이용정보

- 사용자 이용 편의서비스 제공, 이용정보 분석, 사이버 공격을 대비한 자료 취득 : 접속 IP, 이용한 콘텐츠 로그, 쿠키

2. 보유 및 이용기간: 회원 탈퇴 시

※ 고객님의께서는 상기 동의를 거부할 수 있습니다.

다만, 이에 동의하지 않을 경우에는 관련 서비스에 제한이 있을 수 있습니다.

동의서에 동의 거부 시 제한되는 서비스를 구체적으로 안내하고 있지 않음

위 개인정보의 수집·이용에 동의합니다.(선택) 동의함 ☐ 동의하지 않음 ☐

※ 불이익의 사항이 맞춤형인지 회원제 서비스의 이용제한인지 여부가 불분명함

▶ 향후 이용 가능성을 고려해 민감정보를 수집한 잘못된 사례

▶ 개인정보 수집·이용 동의

1. 개인정보 수집 목적 : 회사의 상품/서비스에 대한 이용실적 정보와 분석 및 고객의 관심에 부합하는 서비스와 이벤트 기획 및 개인별 최적화된 서비스 제공

2. 개인정보 수집 항목 : 설치한 어플리케이션 관련 정보(APP패키지명, 버전, 설치경로, 이용횟수, 이용시간), 이용환경(단말기 모델명, OS, 통신사) 정보, 기기관리 번호

*위 정보 중에서, 이용자가 이용한 어플리케이션에 따라 (1) 사상, 신념 (2) 노동조합, 정당의 가입 및 탈퇴 (3) 정치적 견해 (4) 건강, 성생활 등에 관한 정보 (5) 유전정보, 형의 실효에 관한 법률상 범죄 경력에 해당하는 정보가 포함될 수 있음

3. 보유 및 이용기간 : 회원 탈퇴 시

민감정보 수집 시에는 다른 정보와 별도로 동의 필요

* 귀하는 개인정보 수집에 동의를 거부할 권리가 있으며, 거부 시 상품 홍보 및 이벤트 참여에 제한될 수 있습니다.

위 개인정보를 수집·이용하는 것에 동의합니다.(선택) 동의함 ☐ 동의하지 않음 ☐

민감정보의 수집 필요성이 불분명하면서 수집 가능성에 대하여 동의를 요구해서는 안 됨

※ 수집목적의 명확화



3. 개인정보의 처리

🔒 개인정보 처리 동의 시 잘못된 사례

▶ 마케팅 목적의 불분명한 안내

1. 개인정보 수집 목적 : 고객편의 향상을 위한 안내 메일 발송, 회원에게 제공하는 뉴스 전달
2. 개인정보 수집 항목 : 이름, 휴대전화번호, 이메일 주소
3. 보유 및 이용기간 : 회원 탈퇴 시

* 귀하는 개인정보 수집에 동의를 거부할 권리가 있으며, 동의를 거부할 경우 안내 메일 및 뉴스를 받으실 수 없습니다.

위와 같은 개인정보의 수집·이용에 동의합니다.(선택) 동의함 ☐ 동의하지 않음 ☐

※ (수집 목적 불분명) 고객편의 향상을 위한 안내 메일 발송

→ (수정 예시) 구매물품 관련 신상품 개발 홍보

※ 불이익의 사항이 맞춤형인지 회원제 서비스의 이용제한인지 여부가 불분명함

▶ 동의없는 홍보 및 마케팅 목적의 사용

✓ 개인정보처리방침 내용

(쿠키 사용목적)

- 개인의 관심분야에 따라 차별화된 정보제공
- 접속빈도 또는 방문시간을 분석하고 이용자의 취향과 관심분야를 파악하여 타겟 마케팅 및 서비스 개선의 척도로 활용

✓ 개인정보 수집·이용 동의서

(누락)

1. 수집목적 : 신규서비스 /상품 안내 → **개인맞춤형 광고 및 마케팅**
2. 수집항목 : 휴대폰번호 /이메일 → **쿠키에 의한 자동수집 정보**

**처리방침 상 쿠키 사용을 안내하고 있지만,
정보주체 동의 없이 홍보 및 마케팅 목적으로 사용하고 있음**

※ 자동수집되는 개인정보도 계약이행과 무관할 경우, 선택정보로 동의 필요



3. 개인정보의 처리

개인정보 수집 목적 범위내 제3자 제공(제17조)

※ 민감정보, 고유식별정보, 주민등록번호는 제15조, 제17조, 제18조 해당 없음!

1 정보주체의 동의를 받은 경우

※ 동의 받을 때 고지 의무 사항 (위반 시 3천만원 이하의 과태료)

- ① 개인정보를 **제공받는 자** ② 제공받는 자의 개인정보 **이용 목적**
- ③ 제공하는 개인정보의 **항목** ④ 제공받는 자의 개인정보 **보유·이용기간** ⑤ **동의거부 권리** 및 동의거부 시 **불이익 내용**

2 다음의 경우에 따라 수집한 목적 범위 내에서 제공하는 경우

- ✓ **법률의 특별한 규정, 법령상 의무 준수**를 위해 불가피한 경우
- ✓ **공공기관이 법령 등에서 정한 소관업무**를 위해 불가피한 경우
- ✓ **명백히 정보주체 등의 급박한 생명, 신체, 재산의 이익**을 위해 필요한 경우
- ✓ **공중위생 등 공공의 안전과 안녕**을 위하여 긴급히 필요한 경우



위반 시 5년 이하의 징역 또는 5천만원 이하의 벌금



3. 개인정보의 처리

🔒 개인정보 제3자 제공 방법 예시

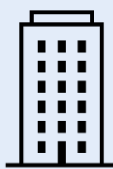
▶ 제3자 제공의 정의와 예시



✓ 개인정보 제공의 정의

"제공"이란 개인정보의 저장 매체나 개인정보가 담긴 출력물·책자 등을 **물리적으로 이전**하거나 네트워크를 통한 개인정보의 **전송**, 개인정보에 대한 제3자의 **접근권한 부여**, 개인정보처리자와 제3자의 **개인정보 공유** 등 개인정보의 이전 또는 **공동 이용 상태를 초래**하는 모든 행위를 말함 (표준지침 제7조 제1항)

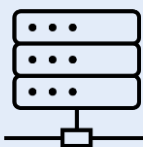
제공하는 개인정보처리자



개인정보처리자
(민간·공공)



개인정보 취급자



개인정보처리시스템
(문서 포함)

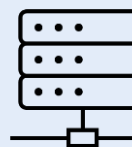
제공받는 개인정보처리자



개인정보처리자
(민간·공공)



개인정보 취급자



개인정보처리시스템
(문서 포함)

1. 저장매체(USB), 출력물 등의 제공

2. 접근권한(조회, 다운로드 등) 부여

3. 시스템 연계(공유)



3. 개인정보의 처리

🔒 개인정보 수집 목적 범위 내 제3자 제공

▶ 사례

✓ 법률의 특별한 규정

- 「보험업법」 제176조에 따라 보험요율산출기관은 보험계약자의 교통법규 위반 정보를 제공받아 보험회사가 보험료 산출에 이용하도록 제공

✓ 법령상 의무 준수

- 「학원의 설립·운영 및 과외교습에 관한 법률」 제6조에 따른 학원의 설립·운영하려는 자의 강사명단 등을 교육감에게 등록 의무
- 「소득세법」 제127조 및 제128조에 따른 소득지급자의 소득 귀속자의 대한 원천징수의무 및 원천징수 이행상황신고 등 이행

✓ 공공기관이 법령 등에서 정한 소관업무를 위해 불가피한 경우

- 「정부조직법」 및 각 기관별 직제령·직제규칙, 개별 조직법 등에서 정하고 있는 소관사무 「주민등록법」, 「의료법」, 「국민건강보험법」 등 개별 법에서 정하고 있는 소관사무



3. 개인정보의 처리

🔒 개인정보 수집 목적 범위 내 제3자 제공

▶ 수집이용 기준과 제공기준의 비교(제15조, 제17조)

기준	수집이용(제15조)	(목적 내) 제3자 제공(17조)
정보주체의 동의를 받은 경우	가능	제공가능
법률에 특별한 규정이 있거나 법령상 의무를 준수하기 위하여 불가피한 경우	가능	수집 목적 범위 안에서 제공 가능
공공기관이 법령 등에서 정하는 소관업무의 수행을 위하여 불가피한 경우	가능	수집목적 범위 안에서 제공 가능
정보주체와의 계약의 체결 및 이행을 위하여 불가피하게 수반되는 경우	가능	제공 불가(정보주체의 동의 필요)
정보주체 또는 그 법정대리인이 의사표시를 할 수 없는 상태에 있거나 주소불명 등으로 사전 동의를 받을 수 없는 경우로 명백히 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 필요하다고 인정되는 경우	가능	수집목적 범위 내에서 제공 가능
개인정보처리자의 정당한 이익을 달성하기 위하여 필요한 경우로서 명백히 정보주체의 권리보다 우선하는 경우	가능	제공 불가(정보주체의 동의 필요)



3. 개인정보의 처리

개인정보 수집 목적 외 이용·제3자 제공(제18조)

※ 민감정보, 고유식별정보, 주민등록번호는 제15조, 제17조, 제18조 해당 없음!

목적 외 이용·제공은 원칙적으로 금지,
다만 아래 사항 중 정보주체 또는 제3자의 이익을 부당하게 침해할 우려가 없는 경우 예외적 허용

- 1 정보주체의 별도 동의를 받은 경우
- 2 다른 법률의 특별한 규정이 있는 경우
- 3 명백히 정보주체 또는 제3자의 생명, 신체, 재산의 이익에 필요한 경우
- 9 공중위생 등 공공의 안전과 안녕을 위하여 긴급히 필요한 경우

[공공기관만 해당]

- 4 개인정보를 목적 외로 이용하거나 제3자에게 제공하지 않으면 다른 법률에서 정하는 소관업무 수행 불가능한 경우로 개인정보보호위원회의 심의·의결을 거친 경우
- 5 조약, 국제협정 이행을 위해 외국정부 등 제공에 필요한 경우
- 6 범죄수사 및 공소제기·유지
- 7 법원의 재판업무 수행
- 8 형 및 감호, 보호처분 집행

위반 시 5년 이하의 징역 또는 5천만원 이하의 벌금



3. 개인정보의 처리

🔒 개인정보 수집 목적 외 이용·제3자 제공

▶ 사례

✓ 다른 법률의 특별한 규정 사례

- 『소득세법』 제170조에 따른 세무공무원의 납세의무자 등에 대한 조사, 질문
- 『감사원법』 제27조에 따른 감사원의 감사 관계자 등 자료 요구
- 『국가유공자 등 예우 및 지원에 관한 법률』 제77조에 따른 국가 유공자 등록 등을 위하여 국가보훈처장이 관계기관의 장에게 가족관계 등록사항 등에 자료제공 요구
- 『병역법』 제81조제2항에 따른 병무청장이 병역 이행 사항 확인·점검을 위하여 지방자치단체 등의 자료제공 요구
- 『부패방지 및 국민권익위원회 설치와 운영에 관한 법률』 제42조제1항 및 제3항에 따른
- 국민권익위원회가 민원사항에 대한 조사를 위해 관계기관에 자료제출 요구 등



3. 개인정보의 처리

🔒 개인정보 수집 목적 외 이용·제3자 제공

▶ 목적외 이용의 잘못된 예

- ✓ 공무원들에게 업무용으로 발급한 이메일 계정으로 사전 동의절차 없이 교육 등 마케팅 홍보 자료를 발송한 경우
- ✓ 조세 담당 공무원이 자신과 채권·채무 관계로 소송 중인 사람에 관한 납세정보를 조회하여 소송에 이용한 경우
- ✓ 상품배송을 목적으로 수집한 개인정보를 사전에 동의 받지 않은 자사의 별도 상품·서비스 홍보에 이용
- ✓ 고객 만족도 조사, 판촉행사, 경품행사에 응모하기 위하여 입력한 개인정보를 사전에 동의받지 않고 자사의 할인판매행사 안내용 광고물 발송에 이용
- ✓ A/S센터에서 고객 불만 및 불편 사항을 처리하기 위해 수집한 개인정보를 자사의 신상품광고에 이용

▶ 목적외 제3자 제공의 잘못된 예

- ✓ 주민센터 복지카드 담당 공무원이 복지카드 신청자의 개인정보(홍보 마케팅 등으로 개인정보 제공을 동의하지 않은 경우)를 정보주체의 동의 없이 사설학습지 회사에 제공
- ✓ 홈쇼핑 회사가 주문 상품을 배달하기 위해 수집한 고객정보를 정보주체의 동의 없이 계열 콘도미니엄사에 제공하여 콘도미니엄 판매용 홍보자료 발송에 활용



3. 개인정보의 처리

🔒 개인정보 수집 목적 외 이용·제3자 제공

▶ 심의·의결 사례

✓ 개인정보 보호위원회의 심의·의결을 거친 사례(공공기관만 해당)

- 경기도 구리시는 구리농수산물도매시장에 출입하는 노후경유자동차의 소유주에게 『수도권 대기환경개선에 관한 특별법』 제28조의2에 따른 노후경유자동차 운행제한제도의 시행을 사전에 안내하기 위하여 구리농수산물공사로부터 주차시스템에 등록된 차량정보를 제공받을 수 있음
- 인천광역시 옹진군은 『서해 5도 지원 특별법』 제12조에 따른 서해 5도 주민의 정주생활지원금의 부정수급 방지를 위하여 인천항만공사로부터 서해 5도 주민의 화물선 이용정보(성명, 생년월일, 선명, 출입도지, 승선일) 제공받을 수 있음
- 강원도 삼척시는 『발전소주변지역 지원에 관한 법률』 제11조 및 같은 법 시행령 제19조 제4항에 따른 발전소 주변 주민건강검진 지원사업 안내를 위하여 『주민등록법』에 따라 수집한 삼척화력발전소 주변지역 만65세 이상 주민의 성명과 주소 이용 가능

(출처: 개인정보보호위원회 홈페이지(pipc.go.kr))



3. 개인정보의 처리

🔒 목적 외 이용·제공(제18조)에 따른 이행사항

제공하는 자

개인정보를 제공받는 자에게
이용목적, 이용방법 그 외 필요사항에 대한
제한 및 개인정보 안전성 확보 조치 마련 요청



요청

제공받는 자

개인정보 안전성 확보 조치 이행

공공기관 이행사항

- ✓ 개인정보 이용 및 제공 관련 법적 근거, 목적 및 범위 관련 사항을 관보 또는 인터넷 홈페이지 게재
- ✓ 개인정보 목적 외 이용 및 제3자 제공 대장 기록 관리



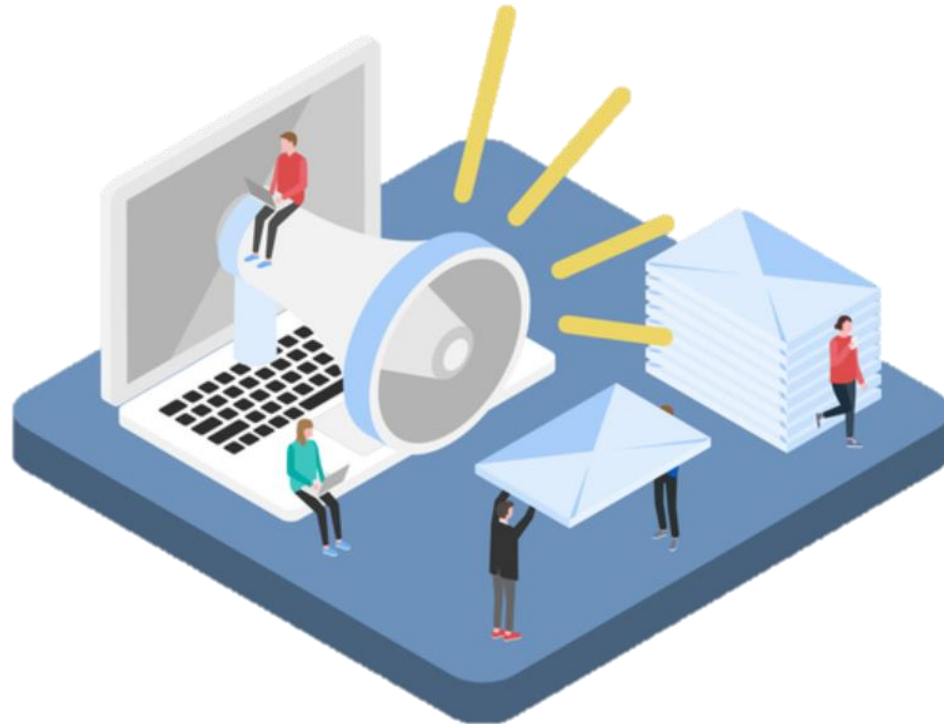


3. 개인정보의 처리

개인정보의 수집 출처 등 고지(제20조)

- ▶ 정보주체 이외로부터 수집한 개인정보를 처리할 때, 정보주체의 요구가 있으면 즉시(3일 이내) 다음의 사항을 알려야 함
(위반 시 3천만원 이하의 과태료)

✓ 개인정보 수집 출처, 개인정보 처리 목적, 개인정보 처리 정지하거나 동의 철회를 요구할 권리가 있다는 사실





3. 개인정보의 처리

🔒 개인정보의 수집 출처 등 고지(제20조)

- ▶ 일정 기준 이상의 개인정보처리자는 제3자로부터 개인정보를 제공받은 경우 정보주체에게 수집 출처, 처리목적, 처리정지 또는 동의철회 요구가 가능함을 고지하여야 함(위반 시 3천만원 이하의 과태료)

※ 단, 정보주체에게 알릴 수 있는 개인정보(연락처 등)가 없다면 적용 제외 가능

✓ 고지의무 대상 개인정보처리자

- 5만명 이상의 민감정보 또는 고유식별정보를 처리하는 자
 - 100만명 이상의 정보주체에 대한 개인정보를 처리하는 자
- 제17조제1항 제1호에 따라 제3자 제공 동의를 받은 자로부터 수집한 경우에 한정

✓ 고지 방법 및 시기

- 서면, 전화, 문자전송, 전자우편 등 방법으로 개인정보를 제공받은 날로부터 3개월 이내
- 정보주체의 동의를 받은 범위에서 연 2회 이상 주기적으로 제공받는 경우 제공 받은 날로부터 3개월 이내 또는 동의를 받은 날로부터 기산하여 연 1회 이상

✓ 고지하였다는 사실, 알린 시기, 알린 방법을 개인정보 파기할 때까지 보관 관리

- ▶ 단, 범죄수사, 공소 제기·유지, 형·감호 집행, 교정·보호·보안관찰 처분, 출입국 관리사항 등의 개인정보, 다른 사람의 생명·신체를 해할 우려 또는 재산·이익의 부당한 침해 우려 시에는 적용 예외



3. 개인정보의 처리

🔒 개인정보의 파기(제21조)

- ▶ **보유기간의 경과, 처리목적 달성 등 개인정보가 불필요하게 되었을 때 지체 없이(5일 이내) 파기 (위반 시 3천만원 이하의 과태료)**
※ 다른 법령에 따라 보존하여야 하는 경우 보존 가능
- ▶ **개인정보 파기할 때에는 복구·재생되지 않도록 조치**
- ▶ **다른 법령에 따라 보존하여야 하는 경우 다른 개인정보와 분리하여 저장·관리 (위반 시 1천만원 이하의 과태료)**



파기방법

- 기록물, 인쇄물, 서면, 기록매체
: 파쇄 또는 소각
- 전자적 파일 형태
: 복원이 불가능한 방법으로 영구 삭제
: 기술적으로 영구삭제 불가능할 경우
→ 복원 불가능하도록 조치

파기절차

- 개인정보처리자
: 개인정보의 파기에 관한 사항을 기록 및 관리
- 개인정보 보호책임자
: 개인정보 파기 시행 후 파기 결과를 확인



3. 개인정보의 처리

🔒 개인정보 파기 시 고려사항

▶ 보존의무를 규정하고 있는 입법례

법령	보존의무 사항
전자상거래 등에서의 소비자 보호에 관한 법률 제6조 및 동법 시행령 제6조	- 표시·광고에 관한 기록 : 6개월 - 계약 또는 청약철회 등에 관한 기록 : 5년 - 대금결제 및 재화 등의 공급에 관한 기록 : 5년 - 소비자의 불만 또는 분쟁처리에 관한 기록 : 3년
통신비밀보호법 제15조의2 및 동법 시행령 제41조	- 법 제2조11호가목부터 라목까지 및 바목에 따른 통신사실 확인자료 : 12개월 - 위 자료 중 시외·시내전화역무와 관련된 자료인 통신사실확인자료 : 6개월 - 법 제2조제11호 마목 및 사목에 따른 통신사실확인자료(컴퓨터 통신 또는 인터넷의 로그기록 자료, 정보통신기기와 위치를 확인할 수 있는 접속지 추적자료) : 3개월
의료법 시행규칙 제15조	- 환자명부 : 5년 - 진료기록부 : 10년 - 처방전 : 2년 - 수술기록 : 10년 - 검사소견기록 : 5년 - 방사선사진 및 그 소견서 : 5년 - 간호기록부 : 5년 - 조산기록부 : 5년 - 진단서 등의 부분(진단서, 사망진단서 및 시체검안서 등을 따로 구분하여 보존할 것) : 3년



3. 개인정보의 처리

🔒 민감정보, 고유식별정보 처리제한(제23조, 제24조)

“민감정보 및 고유식별정보는 원칙적으로 처리 금지”

▶ 정보주체에게 **별도 동의를** 얻거나, 법령에서 구체적으로 처리를 요구하거나 허용하는 경우에 한하여 처리

민감정보

- 사상, 신념, 노동조합·정당가입, 건강정보, 유전정보, 범죄경력 정보, 생체정보, 인종 및 민족 정보

고유식별정보

- 주민등록번호, 여권번호, 운전면허번호, 외국인등록번호

위반 시 5년 이하의 징역 또는 5천만원 이하의 벌금

▶ 분실·도난·유출·위조·변조·훼손되지 않도록 안전성 확보조치 의무(위반 시 3천만원 이하의 과태료)

위 규정에도 불구하고 주민등록번호는 법률 또는 대통령령 등에
구체적으로 처리근거가 있어야 처리가 가능함(제24조2)





3. 개인정보의 처리

🔒 생체정보의 처리

▶ 개인정보, 생체정보, 생체인식정보

- ✓ 생체정보란 지문, 얼굴, 홍채, 정맥, 음성, 필적 등 ①**개인의 신체적, 생리적, 행동적 특징**에 관한 정보로서 ②**특정 개인을 인증·식별하거나** ③**개인에 관한 특징**(연령·성별·감정 등)을 알아보기 위해 ④**일정한 기술적 수단**을 통해 처리되는 정보를 말함
- ✓ 생체인식정보란 생체정보 중 특정 개인을 인증·식별할 목적으로 처리되는 정보를 의미함
 - 생체정보는 특정 개인을 인증·식별하기 위한 목적으로 처리되는 '**생체인식정보**'와 인증·식별 목적이 아닌, 개인에 관한 특징(연령·성별·감정 등)을 알아보기 위해 처리되는 **일반적인 생체정보**로 구성
- ✓ 생체인식정보와 일반적인 생체정보의 구분 예시

구분	얼굴 사진(영상)의 경우	음성의 경우	민간정보 여부
생체인식정보	얼굴 사진(영상)에서 특징점 등을 기술적으로 추출 목적으로 출입통제 시스템 등에 사용하는 경우	시스피커에서 입력된 사람의 음성을 통해 특징점 등을 기술적으로 추출하여 말하는 사람이 누구인지 확인해 응답하는 경우	O
일반적인 생체정보	얼굴 사진(영상)에서 특징점 등을 기술적으로 추출하지만 성별, 감정상태 등을 알아보기 위해 사용되는 경우	시스피커에서 입력된 사람의 음성을 통해 특징점을 기술적으로 추출하지만 단순히 화상의 감정상태를 알아보기 위해 사용하는 경우	X



3. 개인정보의 처리

🔒 생체정보의 처리

▶ 생체인식정보의 수집이용과 동의 예시

원본정보 수집·이용 동의			
항목	목적	보유·이용기간	동의여부
얼굴정보 (원본정보)	[필수*] 이용자 식별 및 본인 인증	• 특징정보 생성 시 까지	☐ 동의함 ☐ 동의안함
	[선택*] 얼굴 인식 알고리즘 연구	• 수집일로부터 1년	☐ 동의함 ☐ 동의안함
※ 위의 개인정보 처리에 대한 동의를 거부할 권리가 있습니다. 그러나 필수 항목의 동의를 거부할 경우 얼굴정보를 이용한 로그인 기능을 이용할 수 없습니다.			
민감정보(특징정보) 처리 동의			
항목	목적	보유·이용기간	동의여부
얼굴정보 (특징정보)	이용자 식별 및 본인 인증	• 회원탈퇴 시 까지	☐ 동의함 ☐ 동의안함
※ 위의 민감정보 처리에 대한 동의를 거부할 권리가 있습니다. 그러나 동의를 거부할 경우 얼굴정보를 이용한 로그인 기능을 이용할 수 없습니다.			

* 필수·선택 동의 여부는 해당 서비스의 특성에 따라 달리 정할 수 있음



3. 개인정보의 처리

주민등록번호의 처리제한(제24조의2)

주민등록번호는 정보주체의 동의를 받아도 처리 불가!

▶ 다음의 어느 하나에 해당하는 경우에만 주민등록번호 처리 가능

- ✓ 법률·대통령령·국회규칙·대법원규칙·헌법재판소규칙·중앙선거관리위원회규칙 및 감사원규칙에서 구체적으로 주민등록번호의 처리를 요구하거나 허용한 경우
- ✓ 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 명백히 필요하다고 인정되는 경우

▶ 인터넷으로 회원 가입 시 주민등록번호를 사용하지 않는 가입 방법을 제공하여야 함

- ✓ (예) I-PIN, 휴대폰, 공인인증서, 전자서명 등



위반 시 3천만원 이하의 과태료

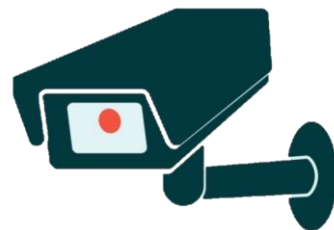


3. 개인정보의 처리

🔒 고정형 영상정보처리기기의 설치·운영 제한(제25조)

▶ 다음의 경우를 제외하고는 누구든지 공개된 장소에 영상정보처리기기 설치·운영 금지

- ✓ 법령에서 구체적으로 허용하고 있는 경우
- ✓ 범죄의 예방 및 수사를 위하여 필요한 경우
- ✓ 시설안전 및 화재 예방을 위하여 필요한 경우
- ✓ 교통단속, 교통정보의 수집·분석 및 제공을 위하여 필요한 경우



▶ 목욕실, 화장실, 발한실(發汗室), 탈의실 등의 내부를 볼 수 있도록 고정형 영상정보처리기기 설치·운영 금지 (위반 시 5천 만원 이하의 과태료)

※ 교도소, 정신보건 시설 등 법령에 근거하여 사람을 구금 또는 보호하는 시설에는 적용 제외

▶ 설치 목적과 다른 목적으로 고정형 영상정보처리기기 임의 조작, 다른 곳을 비추는 행위, 녹음기능 사용 금지 (위반 시 3년 이하의 징역 또는 3천 만원 이하의 벌금)

▶ 고정형 영상정보처리기기를 설치·운영하는 자는 정보주체가 쉽게 인식할 있도록 안내판 설치 및 개인정보가 분실·도난·유출·위조·변조·훼손되지 않도록 안전성 확보조치



3. 개인정보의 처리

🔒 고정형 영상정보처리기기의 설치·운영 제한(제25조)

▶ 고정형 영상정보 처리기기의 설치 운영에 관한 쟁점

<공개된 장소>

- ✓ 정보주체가 접근하거나 통행하는 데에 제한을 받지 않는 장소를 의미함 (법 제25조 적용)
- ✓ 특정인들 또는 특정한 용건이 있는 사람만 출입할 수 있거나, 출입이 엄격히 통제되는 장소는 해당하지 않음

(예시)

- 도로, 공원, 공항, 항만, 주차장, 놀이터, 지하철역 등의 공공장소
- 백화점, 대형마트, 상가, 놀이공원(테마파크) 등 시설
- 버스, 택시 등 누구나 탑승할 수 있는 대중교통

<비공개된 장소>

- ✓ 고정형 영상정보처리기기의 설치·운영이 개인정보처리자의 정당한 이익 달성을 위하여 필요하고 명백하게 정보주체 의 권리보다 우선하는 경우 (제15조제1항제6호 적용)

(추가 고려사항)

- 비공개 장소임에도 보호의 필요성이 큰 만큼 영상정보처리 기기 운영 현황을 알리는 차원에서 법에서 정한 안내판 등 설치의무 준수가 바람직함



3. 개인정보의 처리

🔒 고정형 영상정보처리기의 설치·운영 제한(제25조)

▶ 고정형 영상정보처리기의 설치 의무 법령 현황(예시)

관련 법령	내용
주차장법 시행규칙	주차대수 30대를 초과하는 규모의 자주식 주차장으로서
아동복지법	유치원, 초등학교, 특수학교, 보육시설, 도시공원 등 아동보호구역으로 지정된 시설
공중위생관리법	목욕장업자는 목욕실, 발한실, 탈의실 이외의 시설에 무인감시카메라 설치 가능
생명윤리 및 안전에 관한 법률 시행규칙	체세포 복제 배아 연구기관은 실험실 및 보관시설의 감시를 위하여 CCTV를 설치해야 함
지하공공보도시설의 결정·구조 및 설치기준에 관한 규칙	지하공공보도시설의 중앙방재실은 자체 감시카메라(CCTV) 설비를 갖추어야 함
여객자동차 운수사업법	운송사업자는 여객자동차운송사업에 사용되는 차량의 운행상황 기록, 교통사고 상황 파악, 차량 내 범죄예방을 위하여 대통령령으로 정하는 여객자동차운송사업의 사업용 자동차에 영상기록장치를 설치하여야 함



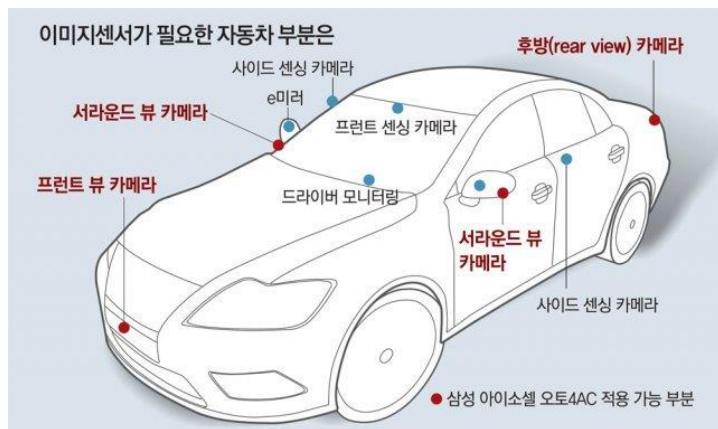
3. 개인정보의 처리

이동형 영상정보처리기기의 설치·운영 제한(제25조의 2)

이동형 영상정보처리기기



출처: 동아일보 2021.7.14



이동가능한 물체에 부착



신체에 착용



신체에 휴대



3. 개인정보의 처리

🔒 이동형 영상정보처리기기의 설치·운영 제한(제25조의 2)

➤ 업무를 목적으로 공개된 장소에서 이동형 영상정보처리기기로 촬영은 일반적으로 금지(제1항)

- 사람 또는 그 사람과 관련된 사물의 영상(개인영상정보)을 촬영 금지
- **업무 목적**: 개인정보처리자가 대상이 됨, 일반 개인의 사적인 촬영은 제외됨
- (참고) 고정형 영상정보처리기기는 **누구든지** 공개된 장소에서 원칙적으로 설치운영 금지(제25조 제1항)



➤ 촬영이 허용되는 경우(제1항 제1호~제3호)

- 제15조(개인정보의 수집·이용) 제1항 각 호(제1호~제7호)의 어느 하나에 해당하는 경우
- 촬영 사실을 명확히 표시하여 정보주체가 촬영 사실을 알 수 있도록 하였음에도 불구하고
- 촬영 거부 의사를 밝히지 아니한 경우.
- 이 경우 정보주체의 권리를 부당하게 침해할 우려가 없고 합리적인 범위를 초과하지 아니하는 경우로 한정

➤ 촬영 사실을 명확히 표시하는 방법

- 불빛, 소리, 안내판, 서면, 안내방송 또는 이에 준하는 수단, 드론에 의한 항공촬영 등 촬영 방법의 특성으로 인해
- 정보주체에게 촬영 사실을 쉽게 알 수 있도록 알리기 어려운 경우에는 홈페이지 공지 등 고시



3. 개인정보의 처리

🔒 업무위탁에 따른 개인정보 처리 제한(제26조)

➤ 개인정보 처리업무 위탁 문서화

✓ 문서에 포함될 내용

- | | |
|---------------------------|---|
| ① 위탁업무 수행목적 외 개인정보의 처리 금지 | ⑤ 개인정보에 대한 접근 제한 등 안전성 확보 조치 |
| ② 개인정보의 기술적·관리적 보호조치 | ⑥ 위탁업무와 관련하여 보유하고 있는 개인정보의 관리 현황 점검 등의 감독 |
| ③ 위탁업무의 목적 및 범위 | ⑦ 수탁자가 준수하여야 할 의무를 위반한 경우의 손해배상 등의 책임 |
| ④ 재위탁 제한 | |

➤ 위탁하는 업무 내용, 수탁자를 인터넷 홈페이지 등에 공개

➤ 홍보나 판매 권유 업무 위탁 시 업무 내용과 수탁자를 정보주체에게 통지

➤ 수탁자가 개인정보를 안전하게 관리할 수 있도록 수탁자 교육, 감독

➤ 수탁자는 위탁 받은 업무 범위를 초과한 개인정보 이용 및 제3자 제공 금지 (위반 시 5년 이하의 징역 또는 5천만원 이하의 벌금)





3. 개인정보의 처리

🔒 업무위탁에 따른 개인정보 처리 제한(제26조)

위탁자의 책임 확대: 수탁자 → 재수탁자

- 수탁자의 정의 확대(제2항)
 - ✓ **[개정 전]** 위탁하는 업무의 내용과 개인정보 처리 업무를 위탁받아 처리하는 자
 - ✓ **[개정 후]** 개인정보 처리 업무를 위탁받아 처리하는 자 (**수탁자**)로부터 위탁받은 업무를 다시 위탁받은 **제3자(재수탁자)**를 포함
- 다음 조항의 '수탁자'에 '재수탁자' 포함
 - ✓ 개인정보 처리방침에 **수탁자** 공개(제3항)
 - ✓ **수탁자**에 대한 관리·감독·교육(제4항)
 - ✓ **[신설]** 수탁자가 재위탁 시 위탁자의 동의 취득(제6항)
 - ✓ **수탁자**의 법 위반으로 발생한 손해배상에 관한 위탁자의 책임(제7항)

[개정] 수탁자의 책임 강화(제8항) → 적용 조항 추가

- 제63조(자료제출 요구 및 검사)
법 위반 사항이나 협의가 있는 등 일정 요건에 해당하는 개인정보처리자에게 관계 물품·서류 등 자료를 제출 요구
- 제63조의2(사전 실태점검)
개인정보 침해사고 발생의 위험성이 높고 개인정보 보호의 취약점을 사전에 점검할 필요성이 인정되는 개인정보처리자에 대하여 개인정보 보호실태를 점검
- 제64조의2(과징금의 부과)



3. 개인정보의 처리

업무위탁 사례

▶ 개인정보 처리에 따른 위탁사와 수탁사 관계 예시

No	위탁사	수탁사
1	고객대상 만족도 조사를 실시하는 (가)기업	(가) 기업과 계약을 맺고 고객 리스트를 제공받은 A컨설팅 회사
2	기업 공식 SNS의 활성화를 위해 D마케팅업체와 계약한 (나) 기업	(나)기업이 제공한 개인정보를 분석하여 고객의 성향을 고려한 친구 맺기 독려 캠페인을 진행하는 B 마케팅 업체
3	등록금을 은행을 통해 대리 수납하는 (다)대학	(다) 대학으로부터 재학생 정보를 받아 등록금 납무 서비스를 운영하는 C 은행
4	회사 내 직원 복지의 일환으로 리조트와 계약을 맺은 (라) 기업	(라)기업으로부터 직원의 성명, 전화번호 등을 받아 객실 예약을 하는 D 리조트
5	전국에 약 1,000여개의 가명점을 가지고 배달음식을 파는 (마)본사	(마)본사의 콜센터 홈페이지를 통해 접수된 배달주문을 처리하는 E가맹점
6	공공기관 간 협약을 통해 업무일부는 N 공공기관에 위탁하는 (바) 공공기관	협약에 따라 (바) 공공기관으로부터 개인정보를 전송받아 처리하는 F 공공기관



3. 개인정보의 처리

위·수탁사 개인정보보호 체크리스트

▶ 업무위탁 단계별 점검사항 예시(개인정보 처리위수탁 안내서 참조)

단계	점검사항	대상
계약 전	• 위탁자는 위탁할 업무의 개인정보 위험성을 확인하였는가?	• 위탁자
	• 위탁자는 수탁자의 개인정보 보호 역량을 확인하였는가?	• 위탁자
	• 위탁자는 위탁하여 처리할 개인정보의 범위를 명확히 하고 수탁자와 사전 협의 하였는가?	• 위탁자
	• 위·수탁자는 다음 6가지 내용이 포함된 위·수탁 문서를 작성하였는가?	• 위탁자 • 수탁자
	• 수탁자가 재수탁하는 업무가 있는가?	
	• 만약 위·수탁 업무 종료 후에도 수탁자가 개인정보를 보관하는 등 추가처리를 해야 하는 사유가 있다면 미리 위·수탁 문서에 이를 포함 하였는가?	
	• 만약 법령상 수탁자에게 개인정보를 보관해야 하는 의무가 발생하는 경우 위탁자에게 이를 미리 알리고 위·수탁 문서 내에 법률상 근거와 개인정보 보관 기간·목적 등을 명시하였는가?	

단계	점검사항	대상
수행 중	• 위탁자는 위탁 업무 내용과 수탁자(재수탁자)를 홈페이지 등에 공개하였는가?	• 위탁자
	• 위탁자는 수탁자의 개인정보 처리가 안전한지 여부를 감독하기 위한 계획을 수립하고 시행하였는가?	• 위탁자
	• 수탁자는 법 제29조의 안전조치 의무를 수행하고, 재수탁자를 관리감독 하고 있는가? (내부관리계획, 접근권한, 암호화, 접속기록, 백신 등)	• 수탁자
	• 위탁자는 수탁자 대상 개인정보보호 교육을 위한 계획을 세우고 시행하였는가?	• 위탁자
업무 종료 후	• 위탁자와 수탁자는 개인정보 열람·정정·파기 요청 등 정보주체의 권리 행사를 보장하기 위한 창구를 마련하였는가?	• 위탁자 • 수탁자
	• 수탁자는 개인정보 파기 사유가 발생한 경우 지체 없이 이를 파기하고, 재수탁자의 파기를 확인하였는가?	• 수탁자
	• 위탁자는 수탁자(재수탁자)의 개인정보 파기를 확인하였는가?	• 위탁자



3. 개인정보의 처리

가명정보의 처리특례(제28조의 2)



- ✓ 살아 있는 개인에 관한 정보로서 성명, 주민등록번호 및 영상 등을 통하여 **개인을 알아볼 수 있는 정보**

※ 해당 정보만으로는 특정 개인을 알아볼 수 없더라도 다른 정보와 쉽게 결합하여 알아볼 수 있는 것 포함



- ✓ 가명정보는 원상태로 복원하기 위한 **추가정보를 사용하지 아니하고는 특정 개인을 알아볼 수 없도록** 가명처리한 정보

※ 개인정보 보호법 제2조(정의)



- ✓ 시간·비용·기술 등 개인정보처리자가 활용할 수 있는 **모든 수단을 합리적으로 고려할 때** 다른 정보를 사용하여도 **더 이상 개인을 알아볼 수 없는 정보**

※ 개인정보 보호법 제58조의2(적용제외)



3. 개인정보의 처리

가명정보의 처리특례(제28조의 2)

1 정보주체의 동의 없이 가명정보의 처리

- ✓ 개인정보처리자는 **통계작성, 과학적 연구, 공익적 기록보존** 등을 위하여 정보주체의 동의 없이 가명정보를 처리할 수 있음
- ✓ “통계”란 특정 집단이나 대상 등에 관하여 작성하는 수량적인 정보를 통계작성의 목적은 시장조사와 같은 상업적 목적으로 가능함
- ✓ “과학적 연구”란 기술의 개발과 실증, 기초연구, 응용연구 및 민간 투자 연구 등 과학적 방법을 적용하는 연구
- ✓ “공익적 기록보존”이란, 공공의 이익을 위하여 지속적으로 열람할 가치가 있는 기록을 보존하는 것

2 가명정보의 제3자 제공 시 특정 개인을 알아볼 수 있는 정보의 미포함

- ✓ 통계작성, 과학적 연구, 공익적 기록보존 목적으로 가명정보를 제3자에게 제공하는 경우, 특정 개인을 알아보기 위하여 사용될 수 있는 정보를 포함하여서는 안 된다.
- ✓ 가명정보를 제3자에게 제공할 때, 제3자가 법에서 허용하는 목적으로 가명정보를 처리하는지에 대하여 추가 자료를 제출받아 결합 가능한 개인정보의 목록 확인
- ✓ 가명정보가 재식별 되지 않는지에 대한 책임은 기본적으로 가명정보를 제공받는 제3자에게 있음

위반 시 5년 이하의 징역 또는 5천만원 이하의 벌금



3. 개인정보의 처리

가명정보의 처리특례(제28조의 2)

1 통계작성을 위한 가명정보 처리 예시

- ✓ 인터넷으로 상품을 판매하는 쇼핑몰 등에서 주간, 월간 단위로 판매상품의 재고를 관리하기 위해 판매상품에 대한 지역별 통계(품번, 품명, 재고, 판매수량, 금액)를 작성하고자 하려는 경우
- ✓ 공공기관이 도로구조 개선 및 휴게공간 추가설치 등 고객서비스 개선을 위하여 월별 시간대별 차량 평균속도, 상습 정체구간, 사고구간 및 원인 등에 대한 통계를 작성하고자 하려는 경우

2 과학적 연구를 위한 가명정보 처리 예시

- ✓ A지자체에서 특정 관광지의 활성화를 위해 국내의 유사 관광지 주변의 상권과 유동인구 분석을 통한 관광지 주변 상권에 대한 지원 및 전환 대책 수립을 위한 연구를 수행하려는 경우
- ✓ 공공기관이 보유하고 스팸정보와 민간 통신사에서 자체적으로 보유하고 있는 스팸정보를 가명정보 결합하여 보다 더 많은 스팸정보를 차단할 수 있다는 가설을 세우고, 스팸정보에 해당하는 전화번호, 유형, 날짜, 내용, 신고건수 등의 정보를 가명처리 및 결합을 통해 가설을 검증하고 결합에 참여한 스팸방지 시스템을 고도화하려는 경우

3 공익적 기록보존을 위한 가명처리 예시

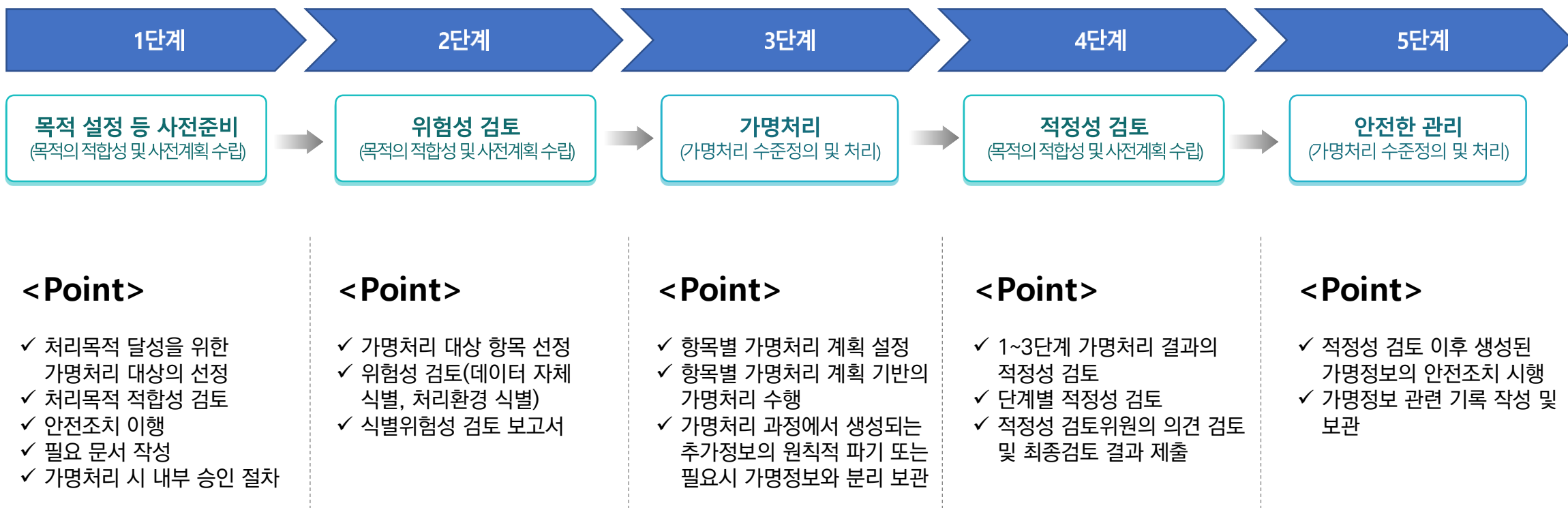
- ✓ 연구소가 코로나19 연구 과정에서 수집한 정보 중 공익적 연구가치가 있는 환자에 관한 정보를 가명처리하여 기록보존하고자 하려는 경우



3. 개인정보의 처리

가명정보의 처리특례(제28조의 2)

가명정보의 처리 단계



(자세한 사항은 가명정보 처리 가이드라인(22.04) 참조)

개인정보 보호법 주요내용



3. 개인정보의 처리

가명처리 예시

가명처리와 위험성 검토

선정			선정				선정						
소유자명	연락처	주택구분	법정동코드	시도	시군구	읍면동	지번	건물명	전세(천원)	보증금(천원)	월세(천원)	전용면적	공급면적
김철수	010-1234-5678	아파트	2647525	서울시	동작구	사당동	1388-4	대우마리나	-	25,000	750	104.00	84.00
이영희	010-1234-9876	오피스텔	578951	대전시	서구	둔산동	656	푸르지오시티	81,250	-	-	56.65	24.32

식별정보(식별자)

						식별가능정보(준식별자)					
소유자명	연락처	주택 구분	시도	시군구	읍면동	지번	전세 (천원)	보증금 (천원)	월세 (천원)	전용 면적	공급 면적
김철수	010-1234-5678	아파트	서울시	동작구	사당동	1388-4	-	25,000	750	104.00	84.00
이영희	010-1234-9876	오피스 텔	대전시	서구	둔산동	656	81,250	-	-	56.65	24.32

삭제

라운딩

위험성 검토사항

<데이터 자체 위험성 검토사항>

- ☑ 소유자명, 연락처: 개인정보로 간주해 암호화 조치
- ☑ 구체적인 지번은 분석목적과 무관해 삭제 조치
- ☑ 시세정보: 분석에 필요한 단위(만원)로 가명처리

<처리환경 위험성 검토사항>

- ☑ A사의 부동산 시세정보를 B기관에 제공(계약)
- ☑ 제공되는 항목의 지번의 경우 등기부열람을 통해 특정 개인 식별 가능성 존재

ID	연락처	주택구분	시도	시군구	읍면동	전세(천원)	보증금(천원)	월세(천원)	전용면적	공급면적
Skad2iswefjh	010-1234-5678	아파트	서울시	동작구	사당동	-	25,000	800	104.00	84.00
dsi545sdkfjd	010-1234-9876	오피스텔	대전시	서구	둔산동	81,300	-	-	56.65	24.32



3. 개인정보의 처리

가명정보의 처리특례(제28조의 2)

잘못된 가명정보의 이용

✓ 잘못된 가명정보의 내부 이용 사례(동일 부서)

- **(상황)** 동일 부서 내 이용으로 ○○화장품 회사의 A팀은 화장품 판매정보를 관리하는 팀으로서, 가명정보 또는 추가정보에 접근할 수 있는 권한을 분리하지 않고 해당 정보를 가명처리하여 신상품 수요조사 예측 모델 개발을 목적으로 활용
- **(처리현황)** A팀은 판매정보 내 개인식별 가능성이 있는 이름, 성별, 승인번호를 가명처리하고, 희귀 지역의 판매내역을 삭제하여 A팀 가명정보 분석담당자에게 제공
- **(문제점)** 가명정보 분석담당자는 가명정보 분석을 통해 최고가 화장품의 금액과 판매지역을 파악할 수 있으며, 판매정보가 관리되고 있는 개인정보처리시스템에 접근이 가능하여 금액과 지역을 통해 특정 개인을 식별할 가능성이 있음

✓ 잘못된 가명정보의 내부 이용 사례(타 부서 이용)

- **(상황)** 타 부서 이용으로 □□공사는 A부서의 고속도로 이용차량 빅데이터 분석 결과를 고속도로 통행요금을 관리하는 B부서에 교통서비스 개선을 위한 연구 목적으로 제공(이 때 B 부서에서 처리하는 개인정보를 고려하지 않음)
- **(처리현황)** A부서는 개인식별 가능성이 있는 차량번호, 차종 등을 가명처리하고, 톨게이트 입출시간, 이동량, 사고정보 등의 정보를 B부서에 제공
- **(문제점)** B부서는 A부서에서 제공받은 정보의 이동시간 정보와 B부서가 보유한 톨게이트 입출시간을 활용하여 특정시간에 통과한 차량의 번호를 알 수 있으며, 해당 차량번호를 통해 특정 개인을 식별할 가능성이 있음



3. 개인정보의 처리

가명정보의 적용범위(제28조의7)

▶ 가명정보의 적용 예외 조항

- ✓ 가명정보에는 적용하지 않는 개인정보 보호법 조항
 - 제20조(정보주체 이외로부터 수집한 개인정보의 수집 출처 등 고지)
 - 제20조의2 (개인정보 이용 · 제공 내역의 통지)
 - 제27조(영업양도 등에 따른 개인정보의 이전 제한)
 - 제34조(개인정보 유출 등의 통지 · 신고)
 - 제35조,(개인정보의 열람)
 - 제35조의2 (개인정보의 전송 요구)
 - 제36조(개인정보의 정정 · 삭제)
 - 제37조(개인정보의 처리정지 등)



3. 개인정보의 처리

개인정보의 국외 이전(제3장 제4절)

▶ 국외이전 요건 강화

1. 정보주체의 별도 동의 (제2호~제5호는 동의 없이 이전)
2. [개정] 처리위탁·보관
 - (1) **정보주체와의 계약의 체결 및 이행**을 위하여 필요한 경우로서
 - (2-1) 개인정보처리방침에 공개하거나
 - (2-2) 개별 통지한 경우
3. [신설] **법률, 조약, 국제협정**에 개인정보 이전에 관한 내용이 있는 경우
4. [신설] 개인정보를 **이전받는 자가 ISMS-P 인증**을 받고 (1)개인정보 안전조치 (2)정보주체 권리보장에 필요한 조치를 수행하는 경우
5. [신설] 개인정보가 이전되는 국가 또는 국제기구의 개인정보 보호 수준이 **우리나라와 동등 수준**을 갖췄다고 개인정보위가 인정하는 경우



3. 개인정보의 처리

🔒 개인정보의 국외 이전(제3장 제4절)

▶ 국외이전 중지

✓ 국외이전 중지 요건

1. 국외 이전 가능 요건 위반(제28조의8 제1항 위반)

- 국외이전 가능 5가지 가능 요건 중 하나 이상 위반한 경우

2. 국외 이전 시 준수사항 위반(제28조의8 제4항 위반)

- 제17조(개인정보의 제공)
- 제18조(개인정보의 목적 외 이용·제공 제한)
- 제19조(개인정보를 제공받은 자의 이용·제공 제한)
- 제5장 정보주체의 권리 보장

3. 개인정보보호법을 위반하는 개인정보 국외 이전 계약 체결 금지 위반(제28조의8 제5항 위반)

4. 이전받는 자(기업 등)나 국가, 국제기구가 개인정보보호 수준이 적정하지 않아 정보주체에 피해가 발생하거나 발생할 우려가 현저한 경우

4

개인정보의 안전한 관리

(개인정보 보호법 제5장)

2교시 상세 설명





4. 개인정보의 안전한 관리

🔒 개인정보 처리방침 수립 및 공개(제30조)

▶ 개인정보처리자는 다음 각 호의 사항이 포함된 개인정보의 처리방침을 수립해야 함.

1. 개인정보의 처리 목적
2. 개인정보의 처리 및 보유 기간
3. 개인정보의 제3자 제공에 관한 사항
- 3의2. 개인정보의 파기절차 및 파기방법
- 3의3. 제23조 제3항에 따른 민감정보의 공개 가능성 및 비공개를 선택하는 방법 (신설)
4. 개인정보처리의 위탁에 관한 사항
- 4의2. 제28조의2 및 제28조의3에 따른 가명정보의 처리 등에 관한 사항(신설)
5. 정보주체와 법정대리인의 권리·의무 및 그 행사방법에 관한 사항
6. 제31조에 따른 개인정보 보호책임자의 성명 또는 개인정보 보호업무 및 관련 고충사항을 처리하는 부서의 명칭과 전화번호 등 연락처 (반드시 CPO의 이름을 적을 필요는 없음)
7. 인터넷 접속정보파일 등 개인정보를 자동으로 수집하는 장치의 설치·운영 및 그 거부에 관한 사항(해당하는 경우에만 정한다)
 - ✓ 쿠키에 대한 설명
8. 그 밖에 개인정보의 처리에 관하여 대통령령으로 정한 사항
 - ✓ 영 제31조(개인정보 처리방침의 내용 및 공개방법 등)



4. 개인정보의 안전한 관리

🔒 개인정보 처리방침의 평가 및 개선권고(제30조의2)

▶ 평가 기준

1. 이 법에 따라 개인정보 처리방침에 포함하여야 할 사항을 적정하게 정하고 있는지 여부
2. 개인정보 처리방침을 알기 쉽게 작성하였는지 여부
3. 개인정보 처리방침을 정보주체가 쉽게 확인할 수 있는 방법으로 공개하고 있는지 여부
(홈페이지 메인화면 하단에 링크로 표시 - 굵은글씨, 색깔 등으로 알기 쉽게 표기 등)

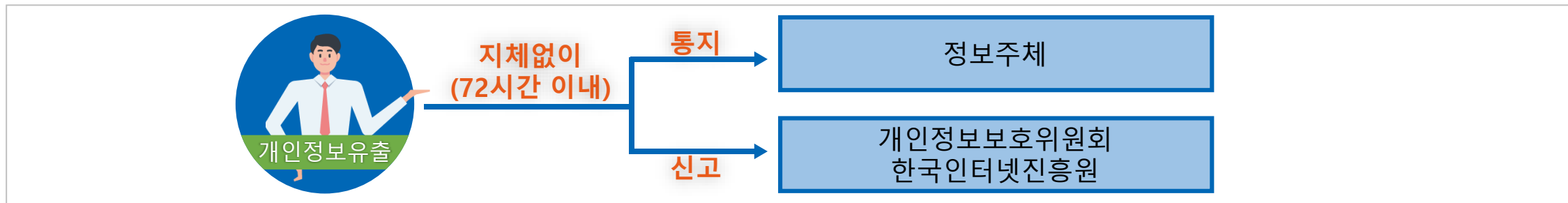
▶ 평가 대상(영 제31조의2)

1. 개인정보처리자의 유형 및 매출액 규모
2. 민감정보 및 고유식별정보 등 처리하는 개인정보의 유형
3. 개인정보 처리의 근거 및 형태·방식
4. 개인정보 보호 법령 위반행위 발생 여부
5. 아동·청소년 등 정보주체의 특성



4. 개인정보의 안전한 관리

🔒 개인정보 유출 통지 등(제34조)



▶ 통지 방법

구분	통지 세부 사항
통지대상	✓ 1건이라도 개인정보 유출되었음을 알게 되었을 때, 정보주체에게 관련 사실을 통지
통지시기	✓ 72시간 이내
통지방법	✓ 개별통지 – 서면, 전자우편, 전화, 팩스, 문자전송 등 ※ 1천명 이상의 개인정보가 유출된 경우, 서면 등의 방법과 함께 인터넷 홈페이지에 7일 이상 게재
통지내용	✓ 유출된 개인정보의 항목, 유출된 시점과 그 경위, 정보주체가 할 수 있는 피해 최소화 방법, 개인정보처리자(사업자 등)의 대응조치 및 피해구제 절차, 담당부서 및 연락처

▶ 신고 방법

구분	통지 세부 사항
신고대상	① 1천명 이상의 정보주체에 관한 개인정보가 유출이 된 경우 ② 민감정보 또는 고유식별정보가 유출이 된 경우 ③ 개인정보처리시스템 또는 개인정보취급자가 개인정보 처리에 이용하는 정보기기에 대한 외부로부터의 불법적인 접근에 의해 개인정보가 유출이 된 경우
신고시기	✓ 72시간 이내
신고기관	✓ 개인정보침해신고센터
신고방법	✓ 개인정보 포털(www.privacy.go.kr), 전화(118), 전자우편(privacyclean@kisa.or.kr) 등
신고 내용	✓ 정보주체에게 통지한 내용, 유출피해 최소화 대책 및 조치 결과 등

5

정보주체 권리 보장과 피해구제

(개인정보 보호법 제5장)





5. 정보주체 권리 보장과 피해구제

정보주체의 권리(제4조)

▶ 정보주체의 권리 보장을 강화

※ 시행일: 2024. 3. 15

1. 개인정보의 처리에 관한 정보를 제공받을 권리
2. 개인정보의 처리에 관한 동의 여부, 동의 범위 등을 선택하고 결정할 권리
3. 개인정보의 처리 여부를 확인하고 개인정보에 대한 열람(사본의 발급을 포함한다. 이하 같다) 및 **전송을 요구할 권리**
4. 개인정보의 처리 정지, 정정·삭제 및 파기를 요구할 권리
5. 개인정보의 처리로 인하여 발생한 피해를 신속하고 공정한 절차에 따라 구제받을 권리
6. **[신설] 완전히 자동화된 개인정보 처리에 따른 결정을 거부하거나 그에 대한 설명 등을 요구할 권리**



5. 정보주체 권리 보장과 피해구제

개인정보 전송요구권(제35조의2)

▶ 개인정보의 전송 요구권

- 정보주체가 개인정보처리자에게 자신의 개인정보를 본인 또는 개인정보관리 전문기관(또는 다른 개인정보처리자)에 전송해 달라고 요구하는 권리

▶ 전송 요구 대상 개인정보

- 정보주체의 동의를 얻어 수집한 개인정보(민감정보, 고유식별정보 포함)
- 필수 개인정보: 계약 체결 또는 계약의 이행을 위해 정보주체의 동의 없이 수집한 개인정보(제15조 제1항 제4호)
- 개인정보위가 전송 대상으로 의결한 개인정보

▶ 전송 요구권 종류

다운로드권

- 정보주체가 개인정보처리자에게 자신에 관한 개인정보를 정보주체 본인에게 전송해 달라고 요구

이동요구권

- 정보주체가 개인정보처리자에게 자신에 관한 개인정보를 개인정보관리 전문기관(마이데이터사업자) 또는 다른 개인정보처리자(일정한 요건을 충족한)에 전송해 달라고 요구



5. 정보주체 권리 보장과 피해구제

🔒 개인정보관리 전문기관(제35조의 3)

▶ 지정 : 개인정보위 또는 관계 중앙행정기관이 승인

- 정보주체가 개인정보처리자에게 자신의 개인정보를 본인 또는 개인정보관리 전문기관(또는 다른 개인정보처리자)에 전송해 달라고 요구하는 권리

▶ 주요업무

- 개인정보의 전송 요구권(제35조의2)행사 지원
- 정보주체의 권리행사를 지원하기 위한 개인정보 전송시스템의 구축 및 표준화
- 정보주체의 권리행사를 지원하기 위한 개인정보의 관리·분석
- 그 밖에 정보주체의 권리행사를 효과적으로 지원하기 위하여 대통령령으로 정하는 업무

▶ 전송 요구권 종류

- 개인정보를 전송·관리·분석할 수 있는 기술수준 및 전문성을 갖추었을 것
- 개인정보를 안전하게 관리할 수 있는 안전성 확보조치 수준을 갖추었을 것
- 개인정보관리 전문기관의 안정적인 운영에 필요한 재정능력을 갖추었을 것



5. 정보주체 권리 보장과 피해구제

🔒 정보주체의 권리 보장(제35조, 제36조, 제37조)

열람요구권(제35조)

정보주체(또는 14세 미만 아동의 법정대리인)가 자신의 개인정보에 대한 열람을 요구할 수 있는 권리

- 개인정보처리자는 10일 이내에 열람하도록 하거나, 정당한 거절 사유가 있으면, 그 사유를 알려야 함

열람 제한·거절 사유

- ✓ 법률에 따라 열람이 금지되거나 제한되는 경우
- ✓ 다른 사람의 생명·신체를 해할 우려가 있거나, 다른 사람의 재산과 그 밖의 이익을 부당하게 침해할 우려가 있는 경우
- ✓ 공공기관의 해당 업무를 수행에 중대한 지장을 초래하는 경우(조세, 성적 평가, 시험 및 자격 심사 등)

정정·삭제권(제36조)

정보주체(또는 14세 미만 아동의 법정대리인)가 자신의 개인정보에 대한 정정·삭제를 요구할 수 있는 권리

- 개인정보처리자는 10일 이내에 처리하고 결과를 알려야 함. 정당한 거절 사유가 있으면, 그 사유를 알려야 함

정정·삭제 거절 사유

- ✓ 다른 법령에서 그 개인정보가 수집 대상으로 명시되어 있는 경우





5. 정보주체 권리 보장과 피해구제

🔒 정보주체의 권리 보장(제35조, 제36조, 제37조)

처리정지권(제37조)

정보주체(또는 14세 미만 아동의 법정대리인)가 자신의 개인정보에 대한 처리 정지를 요구할 수 있는 권리

- 개인정보처리자는 10일 이내 처리 정지, 파기하여야 함. 정당한 거절 사유가 있으면, 그 사유를 알려야 함

처리정지 거절 사유

- ✓ 법률에 특별한 규정이 있거나, 법령상 의무를 준수하기 위하여 불가피한 경우
- ✓ 다른 사람의 생명·신체를 해할 우려가 있거나 다른 사람의 재산과 그 밖의 이익을 부당하게 침해할 우려가 있는 경우
- ✓ 공공기관이 해당 개인정보를 처리하지 아니하면 다른 법률에서 정하는 소관 업무를 수행할 수 없는 경우
- ✓ 정보주체와 약정한 계약 이행이 곤란한 경우로서 정보주체가 그 계약의 해지 의사를 명확하게 밝히지 아니한 경우

동의철회권(제37조)

이용자가(또는 14세 미만 아동의 법정대리인)가 자신의 개인정보에 대한 동의 철회를 요구할 수 있는 권리

- 개인정보처리자는 10일 이내 동의 철회하고, 파기해야 함. 정당한 파기 거절 사유가 있으면 그 사유를 알려야 함

동의 철회는 거절 불가,
파기 거절 사유 = 처리정지 거절 사유





5. 정보주체 권리 보장과 피해구제

자동화 결정에 대한 정보주체의 권리(제4조, 제37조의2)

자동화 결정에 대한 정보주체의 권리(제37조의2)

- 자동화된 결정: AI 등을 적용한 완전히 자동화된 시스템으로 개인정보를 처리하여 이뤄지는 결정
예) AI 기반 면접, 자기소개서 평가, 신용평가

결정 거부권 : 결정을 거부할 수 있는 권리

설명 요구권 : 결정에 대한 설명 요구

예외) 제15조 제1항 제1호 · 제2호 · 제4호에 따라 이루어지는 경우

(참고) 제15조(개인정보의 수집·이용) 제1항

1. 정보주체의 동의를 받은 경우
2. 법률에 특별한 규정이 있거나 법령상 의무를 준수하기 위하여 불가피한 경우
4. 정보주체와 체결한 계약을 이행하거나 계약을 체결하는 과정에서 정보주체의 요청에 따른 조치를 이행하기 위하여 필요한 경우



5. 정보주체 권리 보장과 피해구제

자동화 결정에 대한 정보주체의 권리(제4조, 제37조의2)

▶ 개인정보처리자 의무사항

1. 결정 거부, 설명 요구에 대한 개인정보처리자의 조치(제3항)

- 자동화된 결정을 적용 제외
- 사람(인적자원)에 의한 재처리
- 처리결과, 처리과정 등에 대한 설명

2. 자동화된 결정의 기준과 절차, 개인정보가 처리되는 방식 등을 정보주체가 쉽게 확인할 수 있도록 공개(제4항)

- 개인정보 처리방침에 공개



5. 정보주체 권리 보장과 피해구제

🔒 개인정보 피해구제 제도 현황

개인정보침해 신고상담



PRIVACY

개인정보침해 신고센터

행정안전부, 방송통신위원회, 한국인터넷진흥원이 국민의 개인정보보호를 위해 함께합니다. 정보통신강국의 미래를 개척하는 선봉이 되고자 다양한 업무를 수행하고 있습니다.

- 제도개선권고
- 행정처분 의뢰
- 수사 의뢰

관련근거
(개인정보 보호법 제62조)

개인정보분쟁조정



개인정보분쟁조정위원회

- 제도개선권고
- 손해배상 권고

관련근거
(개인정보 보호법 제43조)

민사소송



- 손해배상 청구

관련근거
(개인정보 보호법 제39조)



5. 정보주체 권리 보장과 피해구제

손해배상제도

▶ 징벌적 손해배상제도(제39조)와 법정 손해배상제도(제39조의2)

구분	징벌적 손해배상제도	법적 손해배상제도
적용 요건	✓ 처리자의 고의·중과실로 개인정보 유출 또는 동의 없이 활용하여 피해 발생	✓ 처리자의 고의·중과실로 개인정보 유출
입증 책임	✓ 처리자가 고의·중과실 없음을 입증 ✓ 피해액은 피해자가 입증	✓ 처리자가 고의·과실 없음을 입증 ✓ 피해자에 대한 피해액 입증책임 면제
구제 범위	✓ 재산 및 정신적 피해 모두 포함	✓ 사실상 피해 입증이 어려운 정신적 피해
배상 규모	✓ 실제 피해액의 5배 이내 배상	✓ 300만원 이하의 범위에서 상당한 금액
적용 시기	2016년 7월 25일 이후 유출사고	

감사합니다



개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례

믿을 수 있는 개인정보 활용, 신뢰사회의 기본입니다
Privacy by Trust, Trust by Privacy



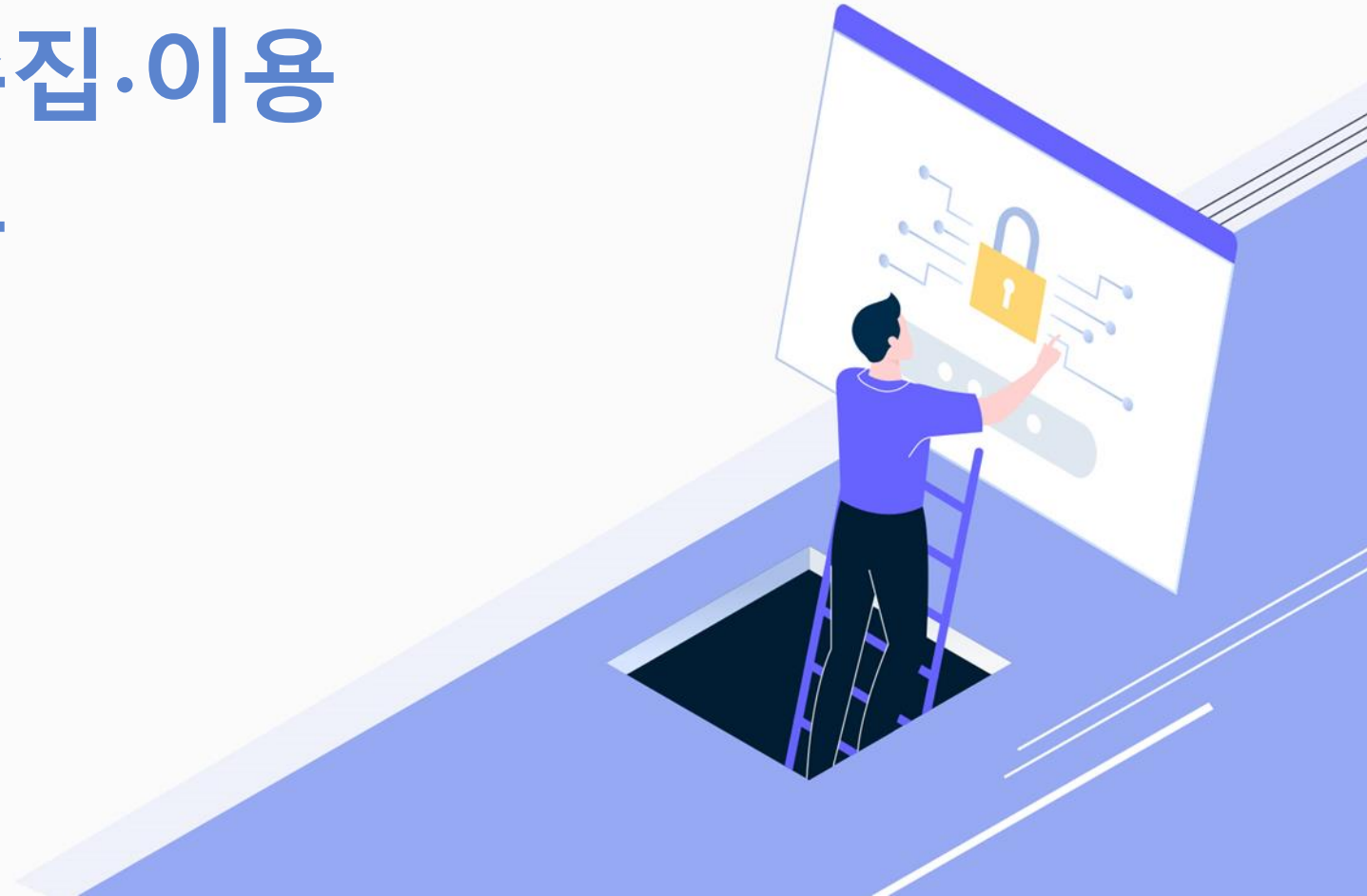
Contents

- 1 개인정보 수집이용 동의서 검토
- 2 개인정보의 안전한 관리와 주요 조치사항
- 3 개인정보 보호법 법령 해석 사례
- 4 개인정보 관련 법령, 고시, 가이드라인 현황



1

개인정보 수집·이용 동의서 검토



개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



1. 개인정보 수집이용 동의서 검토

PIP교육진흥원 현황 주요 내용

▶ PIP 교육진흥원 주요 업무

기관 설립 목적

- 정보주체 및 개인정보처리자에게 개인정보의 중요성과 인식제고를 위한 전문 교육 서비스 제공
- 개인정보처리자를 위한 효과적인 보호 방안과 효율적인 개인정보 활용 방안 마련을 위한 전문화된 교육과정 제공
- 개인정보보호 전문 자격제도 운영을 통한 전문가 양성

▶ PIP 교육진흥원 주요 업무

주요 업무 현황

- PIP교육센터 운영(회원제)
- 개인정보보호 관련 온라인 교육과정 운영(일반과정, 전문가 과정)
- 개인정보보호 전문가 자격시험(국가공인) 제도 운영
- 4개의 개인정보파일을 운영하고 있음

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



1. 개인정보 수집이용 동의서 검토

PIP교육진흥원 현황 주요 내용

▶ PIP 교육진흥원 개인정보파일 현황

No	개인정보 파일명	운영목적
1	PIP교육센터 회원정보	PIP교육센터 홈페이지 회원관리
2	PIP교육센터 일반교육 및 전문교육 과정 수강생 정보	PIP교육센터 일반교육 수료증 발급 및 수강생 관리
3	개인정보보호 전문가 자격 시험 응시자 및 자격증 보유자 정보	PIP교육센터 전문교육 수료증 발급 및 수강생 관리
4	PIP교육수강생 및 응시자민원대응	자격시험 응시자 및 자격증 보유자 관리

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



1. 개인정보 수집이용 동의서 검토

🔒 개인정보 수집이용 동의서 현황

▶ (실습내용) 다음은 정보주체가 PIP 교육진흥원 회원가입 웹 페이지 상 보여지는 개인정보 수집·이용 동의서의 전체 내용입니다. 배포된 PIP교육진흥원의 현황과 아래 동의서를 참고하여 잘못된 부분을 찾으시오.

✓ PIP교육진흥원은 회원관리와 개인정보보호 전문가 자격시험 합격자 관리를 위하여 다음과 같이 개인정보를 수집·이용하고자 합니다.

- 개인정보의 수집이용 목적: **회원가입 및 관리, 전문가 자격시험 합격자 관리**
- 개인정보 수집 항목: **회원ID, 패스워드, 이름, 주민등록번호, 휴대전화번호, 거주지 주소, 소속기관, 응시번호, 자격증 번호,**
- 개인정보의 보유기간: **회원탈퇴 후 즉시 파기**

※ 정보주체는 위의 개인정보 수집·이용에 대한 동의를 거부할 권리가 있습니다. 그러나 동의를 거부할 경우 회원가입 및 개인정보보호 전문가 자격시험에 응시할 수 없습니다.

개인정보 수집·이용에 동의하십니까?

☐ 동의 | ☐ 미동의

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



1. 개인정보 수집이용 동의서 검토

🔒 개인정보 수집이용 동의서 현황

▶ (실습내용) 다음은 정보주체가 PIP 교육진흥원 회원가입 웹 페이지 상 보여지는 개인정보 수집·이용 동의서의 전체 내용입니다. 배포된 PIP교육진흥원의 현황과 아래 동의서를 참고하여 잘못된 부분을 찾으시오

✓ PIP교육진흥원은 회원관리와 개인정보보호 전문가 자격시험 합격자 관리를 위하여 다음과 같이 개인정보를 수집·이용하고자 합니다.

▪ 개인정보의 수집이용 목적: 회원가입 및 관리, 전문가 자격시험 합격자 관리

▪ 개인정보 수집 항목: 회원ID, 패스워드, 이름, 주민등록번호, 휴대전화번호, 거주지 주소, 소속기관, 응시번호, 자격증 번호

▪ 개인정보의 보유기간: 회원탈퇴 후 즉시 파기

※ 정보주체는 위의 개인정보 수집·이용에 대한 동의를 거부할 권리가 있습니다. 그러나 동의를 거부할 경우 회원가입 및 개인정보보호 전문가 자격시험에 응시할 수 없습니다.

개인정보 수집·이용에 동의하십니까?



동의



미동의

- 회원가입 시에는 회원가입과 관련된 최소한의 사항만을 작성하여야 함
- 필요 최소한의 개인정보만 수집, 과도한 정보를 수집하고 있음
- 주민등록번호 수집 이용 근거가 고지되어 있지 않음
- 자격증 보유자에 대한 정보는 법령 상 준영구로 규정되어 있으나 기관 임의대로 파기하고 있음
- 주요정보 알기쉽게 표기(굵은 글씨, 색깔 등)
- 자격시험 합격자에 대한 개인정보 제3자 제공에 대한 고지와 동의가 이뤄지지 않음
- 개인정보 보호법 제15조제1항 제4호에 근거하여 정보주체와 체결한 계약을 이행하거나 계약을 체결하는 과정에서 정보주체의 요청에 따른 조치를 이행하기 위한 경우 동의 없이 수집 가능
- 단, 입증책임은 개인정보처리자에게 있음

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



1. 개인정보 수집이용 동의서 검토

개인정보 수집이용 동의서 현황

- ▶ (실습내용) PIP 교육진흥원 회원가입 시 개인정보 수집·이용 동의서와 국가기술자격 시험 합격자에 대한 개인정보 수집·이용 동의서를 각각 올바르게 작성하시오.

앞에서 찾은 문제점을 개선하도록 동의서를 수정해 보세요

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



1. 개인정보 수집이용 동의서 검토

🔒 올바른 개인정보 수집이용 동의서 예시

▶ 회원가입 및 관리에 따른 개인정보 수집이용 동의서 예시

✓ (필수 수집) PIP교육진흥원은 회원가입과 회원관리를 위하여 다음과 같이 개인정보를 수집·이용하고자 합니다

- 개인정보의 수집이용 목적: **회원가입 처리 및 회원관리 업무, 민원응대**
- 개인정보 수집 항목: **회원ID, 비밀번호, 이름, 생년월일, 휴대전화번호, 이메일 주소**
- 개인정보의 보유기간: **회원탈퇴 시 파기**

※ 개인정보 수집·이용 근거법령 : 개인정보 보호법 제15조제1항제4호에 근거하여 정보주체와 체결한 계약의 이행을 위해 필요한 경우

✓ (선택 동의) PIP교육진흥원은 회원의 개인정보를 아래와 같이 수집 및 이용하고자 합니다.

- 개인정보의 수집이용 목적: **신청자에 한해 교육과정, 자격시험 일정 등 PIP교육진흥원 서비스에 대한 정보를 이메일로 제공**
- 개인정보 수집 항목: **이메일 주소**
- 개인정보의 보유기간: **회원탈퇴 시 파기**

※ 이용자는 위의 개인정보 수집·이용에 대한 동의를 거부할 권리가 있습니다. 그러나 동의를 거부할 경우 이메일 수신에 불가능합니다.

개인정보 수집·이용에 동의하십니까?

☐ 동의 | ☐ 미동의

✓ PIP교육진흥원은 신청자에 한 해 교육과정, 자격시험 일정 등 PIP교육진흥원 서비스에 대한 정보를 이메일로 제공하고 있습니다. 해당 안내메일 수신에 동의하십니까?

정보수신에 동의하십니까?

☐ 동의 | ☐ 미동의

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



1. 개인정보 수집이용 동의서 검토

올바른 개인정보 수집이용 동의서 예시

▶ 국가기술자격증 보유자에 대한 개인정보 수집이용 동의서 예시

✓ PIP교육진흥원은 개인정보보호 전문가 자격시험 합격자 관리를 위하여 다음과 같이 개인정보를 수집·이용하고자 합니다.

- 개인정보의 수집이용 목적: 국가기술자격시험 합격자 관리
- 개인정보 수집 항목: 이름, 주민등록번호, 휴대전화번호, 이메일주소, 거주지 주소, 소속기관, 자격취득현황, 최종학력, 응시번호, 자격시험 평가점수, 사진
- 개인정보의 보유기간: 응시시험 경과 후 5년 후 파기

※ PIP교육진흥원 국가기술자격법 시행령 제26조(국가기술자격증의 관리 등) 4항 1호와 제33조의2(고유식별정보의 처리)에 따라 응시자의 응시자격여부를 확인하기 위하여 주민등록번호를 수집 및 이용합니다.

※ 개인정보 수집·이용 근거법령: 개인정보 보호법 제15조제1항제4호에 근거하여 정보주체와 체결한 계약의 이행하거나 계약을 체결하는 과정에서 정보주체의 요청에 따른 조치를 이행하기 위해 필요한 경우

✓ PIP교육진흥원은 국가기술자격자 관리를 위하여 다음과 같이 개인정보를 제3자 제공하고자 합니다.

- 개인정보의 제공 목적: 국가기술자격자관리
- 개인정보 제공 항목: 이름, 주민등록번호, 시험 응시 상태, 합격여부, 전화번호, 이메일, 최종학력, 자격취득상태
- 제공받는 기관: 행정안전부, 한국고용정보원, 산업인력관리공단
- 보유기간: 준영구

※ 개인정보 제3자 제공은 법령에 근거한 사항으로 제3자 제공 미동의 시에는 국가기술자격자로 관리되지 않습니다.

※ 제3자 제공 근거법령: 자격기본법 제10조(자격정보시스템의 구축 등), 국가기술자격법 제7조(국가기술자격 정보체계의 구축), 국가기술자격법 시행령 제8조(국가기술자격 정보체계의 구축 및 운영)

개인정보 제3자 제공에 동의하십니까?

☐ 동의 | ☐ 미동의

2

개인정보의 안전한 관리 주요 조치사항



개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 개인정보처리시스템의 범위(용어정의)

▶ 개인정보처리자

- "개인정보처리자"란 업무를 목적으로 개인정보파일을 운영하기 위하여 스스로 또는 다른 사람을 통하여 개인정보를 처리하는 공공기관, 법인, 단체 및 개인 등을 말함

▶ 개인정보책임자

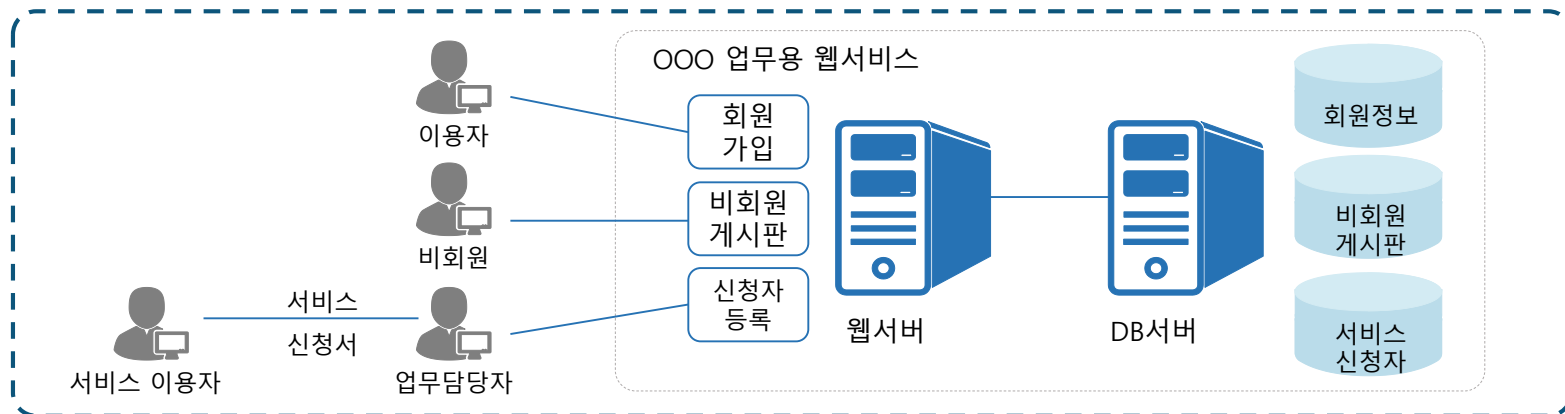
- 개인정보처리에 관한 업무를 총괄해서 책임지거나 업무처리를 최종적으로 결정하는 자

▶ 개인정보취급자

- 개인정보처리자의 지휘감독을 받아 개인정보를 처리하는 임직원, 파견근로자, 시간제근로자 등

▶ 개인정보처리시스템

- 데이터베이스시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성한 시스템



개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 안전조치의무(제29조) / 시행령제30조(개인정보의 안전성 확보 조치)

개인정보가 분실·도난·유출·위조·변조·훼손되지 않도록 안전성 확보 조치를 해야 함

- 1 개인정보의 안전한 처리를 위한 내부 관리계획의 수립·시행·점검
- 2 개인정보에 대한 접근 권한을 제한하기 위한 조치
- 3 개인정보에 대한 접근을 통제하기 위한 조치
- 4 개인정보를 안전하게 저장·전송하는데 필요한 조치
- 5 개인정보 침해사고 발생에 대응하기 위한 접속기록의 보관 및 위조·변조 방지를 위한 조치
- 6 개인정보처리시스템 및 개인정보취급자가 개인정보 처리에 이용하는 정보기기에 대해 컴퓨터바이러스, 스파이웨어, 랜섬웨어 등 악성프로그램의 침투 여부를 항상 점검·치료할 수 있도록 하는 등의 기능이 포함된 프로그램의 설치·운영과 주기적 갱신·점검 조치
- 7 개인정보의 안전한 보관을 위한 보관시설의 마련 또는 잠금장치의 설치 등 물리적 조치

위반 시 3천만원 이하의 과태료



2. 개인정보의 안전한 관리

🔒 안전성 확보조치를 취할 의무 위반의 판단(판례)

✓ 개인정보의 안전성 확보에 필요한 보호조치를 취하여야 할 법률 상 또는 계약상 의무를 위반하였는지 여부는 다음의 사항을 종합적으로 고려 필요
[대법원 2018. 12. 28, 선고, 2017다207994, 판결]

- 해킹 등 침해사고 당시 일반적으로 알려져 있는 정보보안 기술 수준
- 정보통신서비스 제공자의 업종과 영업 규모
- 정보통신서비스 제공자가 취하고 있던 전체적인 보안조치의 내용
- 정보보안조치에 필요한 경제적 비용 및 그 효용의 정도
- 해킹기술 수준과 정보보안기술 발전 정도에 따른 피해 발생 회피 가능성
- 정보통신서비스제공자가 수집한 개인정보의 내용과 개인정보 누출로 인하여 이용자가 입게 되는 피해 정도 등

✓ 개인정보의 기술적·관리적 보호조치 기준(정보통신부 고시 제2005-18호 및 제2007-3호, 이하 '이 사건 고시'라 한다)은 해킹 등 침해사고 당시의 기술수준 등을 고려하여 정보통신서비스제공자가 구 정보통신망법 제28조 제1항에 따라 준수해야 할 기술적·관리적 보호조치를 구체적으로 규정하고 있으므로, 정보통신서비스제공자가 이 사건 고시에서 정하고 있는 기술적·관리적 보호조치를 다하였다면, 특별한 사정이 없는 한, 정보통신서비스제공자가 개인정보의 안전성 확보에 필요한 보호조치를 취하여야 할 법률상 또는 계약상 의무를 위반하였다고 보기는 어렵다
[대법원 2015. 2. 12, 선고, 2013다 43994, 2013다44003(병합) 판결]

※ 안전성 확보조치의 판례에 대한 분석은 고급과정에서 교육 진행 중

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

안전조치의무(제29조)

▶ 개인정보의 안전성 확보조치 기준과 기술적 관리적 보호조치 기준 통합

(종전) 확보조치 기준	(종전) 보호조치 기준	개정 고시	유예 기간
		제1장 총칙	유예기간 ('24.9.15.부터 시행) [특례대상] : 종전의 「개인정보의 기술적·관리적 보호조치 기준」 적용대상인 개인정보처리자 [일반대상] : 종전의 「개인정보의 안전성 확보조치 기준」 적용대상인 개인정보처리자
제1조(목적)	제1조(목적)	제1조(목적)	
제2조(정의)	제2조(정의)	제2조(정의)	
		제2장 개인정보의 안전성 확보조치	
제3조(안전조치 기준 적용)		제3조(안전조치 기준 적용)	
제4조(내부 관리계획의 수립·시행)	제3조(내부 관리계획의 수립·시행)	제4조(내부 관리계획의 수립·시행)	
제5조(접근 권한의 권리)	제4조(접근 통제) ①, ②, ③, ⑦ ⑧	제5조(접근 권한의 권리)	[특례대상] 제5조제6항 [일반대상] 제5조제6항 중 정보주체에 관한 개정규정
제6조(접근통제)	제4조(접근통제) ④, ⑤, ⑥, ⑨, ⑩	제6조(접근통제)	
제7조(개인정보의 암호화)	제6조(개인정보의 암호화)	제7조(개인정보의 암호화)	[일반대상] 제7조제4항, [특례대상] 제7조제6항
제8조(접속기록의 보관 및 점검)	제5조(접속기록의 위·변조 방지)	제8조(접속기록의 보관 및 점검)	[특례대상] 제8조 제2항
제9조(악성프로그램 등 방지)	제7조(악성프로그램 등 방지)	제9조(악성프로그램 등 방지)	
제10조(관리용 단말기의 안전조치)			

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

안전조치의무(제29조)

▶ 개인정보의 안전성 확보조치 기준과 기술적 관리적 보호조치 기준 통합

(종전) 확보조치 기준	(종전) 보호조치 기준	개정 고시	유예 기간
제11조(물리적 안전조치)	제8조(물리적 접근 방지)	제10조(물리적 안전조치)	
제12조(재해·재난 대비 안전조치)		제11조(재해·재난 대비 안전조치)	[특례대상] 제11조
	제9조(출력·복사 시 보호조치)	제12조(출력·복사 시 보호조치)	[일반대상] 제12조 제2항
	제10조(개인정보 표시 제한 보호 조치)		
제13조(개인정보의 파기)		제13조(개인정보의 파기)	
※ 공공부문 개인정보 유출방지 대책 반영 (시행령 제30조의2제1항)		제3장 공공시스템 운영기관 등의 개인정보 안전성 확보조치	공공시스템운영기관과 공공시스템이용기관
		제14조(공공시스템운영기관의 안전 조치 기준 적용)	
		제15조(공공시스템운영기관의 내부 관리계획의 수립·시행)	
		제16조(공공시스템운영기관의 접근 권한의 관리)	
		제17조(공공시스템운영기관의 접속 기록의 보관 및 점검)	



2. 개인정보의 안전한 관리

안전조치의무 주요 조치사항 및 방법

▶ 내부관리계획의 수립·시행 및 점검 (제4조)

- 1 개인정보처리자가 내부 관리계획의 수립 및 시행, 이행 점검 하도록 개정
- 2 적용대상: 개인정보처리자 (단, 1만명 미만의 정보주체에 관하여 개인정보를 처리하는 소상공인·개인·단체의 경우 생략 가능)
- 3 내부 관리계획의 수립 및 시행 관련 사항
 - ✓ 개인정보책임자 및 개인정보취급자를 대상으로 차등화하여 정기적 교육 실시
※고려사항: 사업규모, 개인정보 보유 수, 업무성격 등
 - ✓ 내부 관리계획에 중요한 변경 사항이 있는 경우 즉시 반영, 수정, 시행, 수정 이력 관리
- 4 내부 관리계획의 이행 실태 점검·관리 관련 사항
 - ✓ 역할 : 개인정보 보호책임자 ✓ 기간 : 연 1회 이상
 - ✓ 결과보고 : 내부 관리계획의 이행 실태 (접근권한 관리, 접속기록 보관 및 점검, 암호화 등) 점검 결과



2. 개인정보의 안전한 관리

안전조치의무 주요 조치사항 및 방법

▶ 내부관리계획의 수립·시행 및 점검 (제4조)

(중전) 확보조치 기준

제4조(내부 관리계획의 수립·시행)

- ① 개인정보처리자는 개인정보의 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 의사결정 절차를 통하여 다음 각 호의 사항을 포함하는 내부 관리계획을 수립·시행하여야 한다.

(중전) 보호조치 기준

제4조(내부 관리계획의 수립·시행)

- ① 정보통신서비스 제공자 등은 다음 각 호의 사항을 정하여 개인정보보호 조직을 구성·운영하여야 한다.
- ② 정보통신서비스 제공자 등은 제1항 및 제2항에 대한 세부 계획, 제4조부터 제8조까지의 보호조치 이행을 위한 세부적인 추진방안을 포함한 내부관리계획을 수립·시행하여야 한다.

개정고시

제4조(내부 관리계획의 수립·시행 및 점검)

- ① 개인정보처리자는 개인정보의 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 의사결정 절차를 통하여 다음 각호의 사항을 포함하는 내부 관리계획을 수립·시행하여야 한다.

다만, 1만명 미만의 정보주체에 관하여 개인정보를 처리하는 소상공인·개인·단체의 경우에는 생략할 수 있다.

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 안전조치의무 주요 조치사항 및 방법

▶ 내부관리계획의 수립·시행 및 점검 (제4조)

- ✓ 종전 일반규정과 특례규정의 유사한 내용을 통합
- ✓ 4호. 개인정보취급자에 대한 관리·감독에 관한 사항 추가
- ✓ 10호. 개인정보를 처리하는 개인정보처리자는 개인정보가 유출·변조·훼손되지 않도록 개인정보를 처리하는 환경, 기기, 설비 등에 대하여 취약점을 점검
- ✓ 15호. 개인정보 처리 방법 및 환경 등의 변화로 인하여 내부 관리계획에 중요한 변경이 있을 때에는 변경 사항 즉시 반영

내부 관리계획의 포함 사항

- 01 개인정보 보호 조직의 구성 및 운영에 관한 사항
- 02 개인정보 보호책임자의 자격요건 및 지정에 관한 사항
- 03 개인정보 보호책임자와 개인정보취급자의 역할 및 책임에 관한 사항
- 04 개인정보취급자에 대한 관리·감독 및 교육에 관한 사항
- 05 접근 권한의 관리에 관한 사항
- 06 접근 통제에 관한 사항
- 07 개인정보의 암호화 조치에 관한 사항
- 08 접속기록 보관 및 점검에 관한 사항
- 09 악성프로그램 등 방지에 관한 사항
- 10 개인정보의 유출, 도난 방지 등을 위한 취약점 점검에 관한 사항
- 11 물리적 안전조치에 관한 사항
- 12 개인정보 유출사고 대응 계획 수립·시행에 관한 사항
- 13 위험 분석 및 관리에 관한 사항
- 14 개인정보 처리업무를 위탁하는 경우 수탁자에 대한 관리 및 감독에 관한 사항
- 15 개인정보 내부 관리계획의 수립, 변경 및 승인에 관한 사항
- 16 그 밖에 개인정보 보호를 위하여 필요한 사항



2. 개인정보의 안전한 관리

안전조치의무 주요 조치사항 및 방법

▶ 접근권한 관리

1 최소 범위로 권한 차등부여 및 변경·말소

- ✓ 업무별 접근 가능한 메뉴 및 상세권한 세분화 및 최소한의 차등 부여
- ✓ 업무 변경시 지체없이 권한 변경 및 말소필요

2 접근권한 부여, 변경, 말소 내역 3년 이상 보관

- ✓ 접근권한 부여·변경·말소 내역 3년간 보관
- ✓ 권한변경 내역의 누적 기록·관리
- ✓ 접근권한에 관한 기록 : ① 계정신청정보(ID, 사용자), ② 신청일시, ③ 권한 상태 (권한 및 생성/변경/말소, ④ 승인자 및 발급자 정보, ⑤ 신청 및 발급 사유



2. 개인정보의 안전한 관리

안전조치의무 주요 조치사항 및 방법

▶ 접근권한 관리

3 1인 1계정 발급 및 공유 금지

- ✓ **정당한 사유가 없는 한 개인정보취급자 별로 계정 발급 및 다른 취급자와 공유 금지**
 - ※ 정당한 사유 : root 등 시스템에서 고정된 계정 1개만 생성이 가능한 경우로서 다른 계정 생성이 기술적으로 불가능한 경우 등

5 권한 도용 방지

- ✓ **개인정보취급자 또는 정보주체가 일정 횟수 이상 인증 실패 시 접근 제한**
 - ※ 정보통신서비스제공자의 경우 1년간 유예
 - ※ 정보주체에게 확대되는 규정은 일반 개인정보처리자도 1년간 유예

4 인증수단 안전하게 관리

- ✓ **개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리**
- ✓ **비밀번호 외 생체인증 등 다양한 인증수단 활용**
- ✓ **비밀번호를 인증수단으로 이용하는 경우 스스로의 환경에 맞는 비밀번호 작성 규칙을 자율적으로 적용**



2. 개인정보의 안전한 관리

안전조치의무 주요 조치사항 및 방법

▶ 접근통제

1 불법적인 접근 및 침해사고 방지를 위한 안전조치

- ✓ 개인정보처리시스템의 IPT 주소 등을 제한하여 비인가자의 접근 제한
- ✓ IP 주소 등을 분석하여 개인정보 유출 시도 탐지 및 대응

2 외부 접근 통제

- ✓ 원칙적인 외부 접근 차단
- ✓ 불가피한 외부 접속 시 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단 적용
- ✓ 이용자 외 개인정보처리시: 가상사설망 등 안전한 접속수단 또는 안전한 인증 수단 적용 가능

3 노출 및 공유 설정 제한

- ✓ 인터넷 홈페이지, P2P, 공유 설정 등을 통하여 권한 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 개인정보취급자의 컴퓨터 및 모바일 기기 조치

4 세션 타임 아웃

- ✓ 일정시간 이상 업무처리를 하지 않는 경우에는 자동 접속 차단 등 필요한 조치

5 모바일 기기 관리

- ✓ 업무용 모바일 기기의 분실·도난 등으로 개인정보가 유출되지 않도록 해당 모바일 기기에 비밀번호 설정 등의 보호조치



2. 개인정보의 안전한 관리

🔒 안전조치의무 주요 조치사항 및 방법

▶ 접근통제

6 망 분리

✓ 적용 대상

- 전년도 말 기준 직전 3개월간 그 개인정보가 저장관리되고 있는 이용자 수가 일일평균 100만명 이상인 개인정보처리자

※ **이용자**: 정보통신망법에 따른 정보통신서비스 제공자가 제공하는 정보통신서비스를 이용하는 자

※ 이용자의 법적 정의에 따라 **망분리**는 정보통신서비스제공자에게만 적용

✓ 조치 사항

- 개인정보처리시스템에서 개인정보를 ① 다운로드 또는 ② 파기할 수 있거나 개인정보처리시스템에 대한 ③ 접근권한을 설정할 수 있는 개인정보취급자의 컴퓨터 등에 대한 인터넷망 차단 조치 필요

※ 다운로드: 개인정보처리시스템에 직접 접속하여 취급자의 컴퓨터 등에
개인정보를 엑셀, 워드, 텍스트, 이미지 등 파일 형태로 저장 하는 것을 의미

※ 파기: 개인정보처리시스템에 저장된 개인정보파일, 레코드, 테이블 또는 데이터베이스(DB)를 삭제하는 것을 의미

※ 접근권한설정: 개인정보처리시스템에 접근하는 개인정보취급자에게 다운로드, 파기 등의 접근권한을 설정하는 것을 의미함



2. 개인정보의 안전한 관리

안전조치의무 주요 조치사항 및 방법

▶ 접근통제

6 망 분리

- ✓ 다만, 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」제2조제3호*에 따른 클라우드 컴퓨팅서비스를 이용하여 개인정보처리시스템을 구성운영하는 경우에는 해당 서비스에 대한 접속 외에는 인터넷을 차단하는 조치를 하여야 함
 - ※ 제2조제3호 “클라우드컴퓨팅서비스”란 클라우드컴퓨팅을 활용하여 상용(商用)으로 타인에게 정보통신자원을 제공하는 서비스로서 대통령령으로 정하는 것을 말한다.
- ✓ 논리적 망 분리 및 물리적 망 분리 모두 가능



2. 개인정보의 안전한 관리

안전조치의무 주요 조치사항 및 방법

▶ 개인정보의 암호화

1 인증정보 암호화

- ✓ 비밀번호, 생체인식 정보 등 인증정보를 저장 또는 정보통신망을 통하여 송수신하는 경우
 - 안전한 알고리즘으로 암호화
 - 비밀번호는 복호화되지 않도록 일방향 암호화(SHA-256 등) 적용

2 이용자 개인정보 암호화

- ✓ 이용자의 주민등록번호, 여권번호, 운전면허번호, 외국인등록번호, 신용카드번호, 계좌번호, 생체인식정보는 안전한 알고리즘으로 암호화 하여 적용



2. 개인정보의 안전한 관리

🔒 안전조치의무 주요 조치사항 및 방법

▶ 개인정보의 암호화

3 고유식별정보 암호화

✓ 인터넷 구간/인터넷 구간과 내부망의 중간 지점(DMZ: Demilitarized Zone)에 고유식별정보 저장 시 암호화

✓ 내부망에 고유식별정보를 저장하는 경우

※ 다만, 주민등록번호 외의 고유식별정보를 저장하는 경우에는 아래 기준에 따라 암호화의 적용여부 및 적용범위를 정하여 시행 가능

- ① 제33조에 따른 개인정보 영향평가의 대상이 되는 공공기관의 경우에는 해당 개인정보 영향평가의 결과
- ② 암호화 미적용시 위험도 분석에 따른 결과

4 정보통신망을 통한 인터넷망 구간 송·수신 시

✓ 개인정보를 정보통신망을 통하여 인터넷망 구간으로 송수신하는 경우 암호화



2. 개인정보의 안전한 관리

🔒 안전조치의무 주요 조치사항 및 방법

▶ 개인정보의 암호화

5 기기 및 저장 매체 저장 시

- ✓ 이용자의 개인정보 또는 이용자가 아닌 정보주체의 고유식별정보, 생체인식정보를 개인정보취급자의 컴퓨터, 모바일 기기 및 보조 저장매체 등에 저장 시 암호화한 후 저장

6 암호키 관리

- ✓ 적용 대상
 - 10만명 이상의 정보주체에 관하여 개인정보를 처리하는 대기업·중견기업·공공기관
 - 100만명 이상의 정보주체에 관하여 개인정보를 처리하는 중소기업·단체
- ✓ 조치사항
 - 암호화된 개인정보를 안전하게 보관하기 위하여 안전한 암호 키 생성, 이용, 보관, 배포 및 파기 등에 관한 절차를 수립·시행
 - ※ 암호 키는 암호화된 데이터를 복호화 할 수 있는 정보이므로 암호 키의 안전한 사용과 관리는 매우 중요하며, 라이프사이클 단계별 암호 키 관리 절차를 수립·시행 필요

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 안전조치의무 주요 조치사항 및 방법

▶ 개인정보의 암호화

구분	정보통신망을 통한 송·수신시		저장시				개인정보취급자 컴퓨터, 모바일기기, 보조매체 등에 저장시	
	정보통신망	인터넷망	저장위치 무관		인터넷구간, DMZ	내부망		
이용자의 개인정보	인증정보 (비밀번호, 생체 인식정보 등)	개인정보 *일반 개인정보처리자의 경우 2024.9.15 시행	인증정보 (비밀번호, 생체 인식정보) *단, 비밀번호는 일방향 암호화	신용카드 번호, 계좌번호, 생체인식정보 -	주민등록번호	여권번호, 운전면허번호, 외국인등록번호		개인정보
이용자 외 정보주체 개인정보						고유식별정보(주민 등록번호 제외)	*내부망 저장시 암호화하거나 영향평가 또는 위함도 분석을 통해 암호화 미 적용 가능	
암호키 관리	10만명 이상 대기업·중견기업·공공기관, 100만명 이상 중소기업·단체 : 암호키 생성, 이용, 보관,배포 및 파기 등에 관한 절차를 수립·시행							

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 안전조치의무 주요 조치사항 및 방법

▶ 접속기록 보관 및 관리

1 접속기록 1년 이상 보관

- ✓ 개인정보취급자가 접속한 사실을 알 수 있도록 전자적으로 자동 기록되도록 조치
- ✓ 필요 정보
 - ① 식별자 : 시스템에 접속한 자를 식별할 수 있도록 부여된 정보
 - ② 접속일시(연, 월, 일, 시, 분, 초) : 접속한 시점 또는 업무를 수행한 시점
 - ③ 접속지(IP 주소 등) : 접속한 취급자의 컴퓨터, 모바일기기 등 주소
 - ④ 정보주체 정보 : 개인정보 취급자가 누구의 개인정보를 처리했는지 알 수 있는 이름, ID 등
 - ⑤ 수행업무(조회, 저장, 수정, 삭제, 다운로드 등) : 취급자가 시스템에서 처리한 정보주체에 관한 수행업무 내용을 알 수 있는 정보
- ✓ 보유기간
 - 모든 개인정보처리시스템 : 최소 1년 이상
 - 유출 시 피해가능성이 높은 개인정보 (5만명 이상 개인정보, 고유식별정보 또는 민감정보) : 최소 2년 이상
 - 기간통신사업자 : 최소 2년 이상

2 접속기록 월 1회 이상 점검

- ✓ 최소 월 1회 이상 점검
- ✓ 비정상 행위 탐지 및 적절한 대응조치 적용
- ✓ 점검 대상
 - ① 점검주체 (개인정보보호 부서, 감사부서, 개인정보보호 전문업체 등)
 - ② 점검시기 : 최소 월 1회 이상
 - ③ 점검항목 및 내용 : 비인가된 개인정보 처리 및 대량의 개인정보 다운로드 등 비정상 행위, 접속기록의 위변조 여부 등
 - ④ 점검 후속조치 : 개선조치, 결과보고 등
- ✓ 접속기록이 위변조 및 도난, 분실되지 않도록 안전한 보관
(기존) 별도의 물리적인 저장 장치 보관, 정기적인 백업 -> (개정 개인정보 보호법) 안전하게 보관하기 위한 조치
(예시)
 - ① 접속기록의 상시 백업 : 별도의 보조저장매체, 저장장치 등에 보관
 - ② 저장 시 CD-ROM, DVD-R, WORM 등과 같은 덮어쓰기 방지 매체 사용
 - ③ 접속기록을 수정 가능한 매체(하드디스크 등)에 백업하는 경우 위변조 여부를 확인할 수 있는 정보를 별도의 장비에 보관

※ 안전성 확보조치와 관련된 보다 자세한 내용은 중급과정에서 교육 진행 중



2. 개인정보의 안전한 관리

🔒 개인정보 처리방침의 수립 및 공개(제30조)

▶ 개인정보 처리방침의 주요 내용

1. 개인정보의 **처리 목적**
2. 개인정보의 **처리 및 보유기간**
3. 개인정보의 **제3자 제공**에 관한 사항 (해당하는 경우에만)
4. 개인정보의 **파기절차 및 파기방법**(개인정보를 보존하여야 하는 경우에는 그 보존근거와 보존하는 개인정보 항목)
5. 민감정보의 **공개 가능성 및 비공개**를 선택하는 방법(해당되는 경우에만)
6. 개인정보 처리의 **위탁**에 관한 사항(해당하는 경우에만)
7. **가명정보의 처리** 등에 관한 사항(해당되는 경우에만)
8. **정보주체와 법정대리인의 권리·의무 및 그 행사방법**에 관한 사항
9. **개인정보 보호책임자의 성명 또는 개인정보 보호업무** 및 관련 고충사항을 처리하는 **부서의 명칭과 전화번호 등 연락처**
10. 인터넷 접속정보파일 등 개인정보를 자동으로 수집하는 장치의 설치·운영 및 그 거부에 관한 사항(해당하는 경우에만)
11. 처리하는 개인정보의 **항목**
12. 개인정보의 **안전성 확보조치**에 관한 사항
13. 개인정보 처리방침 변경에 관한 사항

개인정보 처리방침은 **인터넷 홈페이지에 지속적으로 게재**하여 공개해야 함

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 개인정보 처리방침의 수립 및 공개(제30조)

▶ 개인정보 처리방침 기재사항

구분	기재사항	적용
1	제목 및 서문	의무
2	개인정보의 처리목적	의무
3	개인정보의 처리 및 보유기간	의무
4	처리하는 개인정보의 항목	의무
5	만 14세미만 아동의 개인정보 처리에 관한 사항	권장, 해당 시
6	개인정보의 제3자 제공에 관한 사항	의무, 해당 시
7	개인정보의 파기 절차 및 방법에 관한 사항	의무
8	미이용자의 개인정보 파기 등에 관한 조치	권장, 해당 시
9	민감정보의 공개 가능성 및 비공개를 선택하는 방법	의무, 해당 시
10	개인정보 처리업무의 위탁에 관한 사항	의무, 해당 시
11	개인정보의 국외 이전에 관한 사항	권장, 해당 시
12	가명정보의 처리 등에 관한 사항	의무, 해당 시
13	정보주체와 법정대리인의 권리 의무 및 행사방법에 관한 사항	의무

구분	기재사항	적용
14	개인정보의 안전성 확보조치에 관한 사항	의무
15	인터넷 접속정보파일 등 개인정보를 자동으로 수집하는 장치의 설치·운영 및 그 거부에 관한 사항	의무, 해당 시
16	행태정보의 수집 이용 제공 및 거부 등에 관한 사항*	의무, 해당 시
17	추가적인 이용 제공 관련 판단 기준*	의무, 해당 시
18	가명정보 처리에 관한 사항	의무, 해당 시
19	개인정보 보호 책임자에 관한 사항	의무
20	국내 대리인 지정에 관한 사항	의무, 해당 시
21	개인정보의 열람청구를 접수 처리하는 부서	의무
22	정보주체의 권익침해에 대한 구제방법	의무
23	고정형 및 이동형 영상정보처리기기 운영 관리에 관한 사항	권장, 해당 시
24	개인정보 처리방침의 변경에 관한 사항	의무
25	그밖에 개인정보처리자가 개인정보 처리 기준 및 보호조치 등에 관하여 자율적으로 개인정보 처리방침에 포함하여 정한 사항	권장, 해당 시



2. 개인정보의 안전한 관리

🔒 개인정보 처리방침의 수립 및 공개(제30조)

▶ 행태정보의 처리와 개인정보 처리방침 상 표기

✓ 개인정보처리자가 정보주체의 온라인 행태정보를 처리하고 이를 기반으로 '온라인 맞춤형 광고' 등을 제공하는 경우 그 수집·이용에 관한 사항 및 거부 등에 대해 기재

① 수집하는 행태정보의 항목, ② 수집방법, ③ 수집목적, ④ 보유이용기간 및 이후 정보처리 방법 ⑤ 제3자 제공 시 제공받는자 항목, 목적 등 ⑥ 동의를 거부할 수 있는 권리 및 방법 등의 기재

※ 단, 상품 및 서비스의 판매 홍보 목적이 아니며, 제공하는 서비스와 관련된 이용자 편의 제공을 위해 사용 환경(UX, UI 등)을 이용자별로 상이하게 구성하는 등의 맞춤형 서비스 제공은 온라인 맞춤형 광고에 해당하지 않음

✓ 작성 예시

- ① 개인정보처리자는 서비스 이용과정에서 정보주체에게 최적화된 맞춤형 서비스 및 혜택, 온라인 맞춤형 광고 등을 제공하기 위하여 행태정보를 수집 이용하고 있습니다.
- ② 개인정보 처리자는 다음과 같이 행태정보를 수집합니다.

수집하는 행태정보의 항목	행태정보 수집 방법	행태정보 수집목적	보유·이용기간 및 이후 정보처리 방법
이용자의 웹사이트/앱 서비스 방문이력, 검색이력, 구매이력	이용자의 웹사이트 및 앱 방문/실행 시 자동 수집	이용자의 관심, 성향에 기반한 개인 맞춤형 상품추천 서비스(광고포함)를 제공	수집일부터 **일 후 파기



2. 개인정보의 안전한 관리

🔒 개인정보 처리방침의 수립 및 공개(제30조)

▶ 추가적인 이용제공의 판단과 개인정보처리방침 공개

- ✓ 개인정보처리자가 법 제15조제3항 또는 제17조제4항에 따라 정보주체의 동의없이 개인정보를 이용 또는 제공하려는 경우 영 제14조의 2에 따라 각 호의 사항을 고려해야 하며, 고려사항에 대한 판단기준을 법 제30조 제1항에 따른 개인정보 처리방침에 미리 공개해야 함

※ 추가적인 이용제공 시 고려사항에 대한 판단기준은 사업자/단체 스스로 **자율적으로 판단**하여 작성 공개하여야 함
※ 법 제31조제1항에 따른 개인정보 보호책임자가 해당 기준에 따라 개인정보의 추가적인 이용 또는 제공을 하고 있는지 여부를 점검해야 함

✓ 작성 예시

- ① 개인정보처리자는 법 제15조제3항 또는 제17조제4항에 따라 개인정보보호법 시행령 제14조의 2에 따른 사항을 고려하여 정보주체의 동의없이 개인정보를 추가적으로 이용 제공할 수 있습니다.

항목	이용 제공 목적	보유 및 이용기간
이름 연락처, 주소	정기적으로 제공하는 OO서비스 관련 추가 안내물 발송	목적 달성 후 즉시 파기

- ② 이에 따라 000은 정보주체의 동의 없이 추가적인 이용 제공을 하기 위해서 다음과 같은 사항을 고려하였습니다.

- ✓ 개인정보를 추가적으로 이용 제공하려는 목적이 당초 수집목적과 관련성이 있는지 여부
- ✓ 개인정보를 수집한 정황 또는 처리관행에 비추어 볼 때 추가적인 이용 제공에 대한 예측 가능성이 있는지 여부
- ✓ 개인정보의 추가적인 이용 제공이 정보주체의 이익을 부당하게 침해하는지 여부
- ✓ 가명처리 또는 암호화 등 안전성 확보에 필요한 조치를 하였는지 여부

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 개인정보 보호책임자의 지정 요건(제31조)

➤ 공공

국회, 법원, 헌법재판소, 중앙선거관리위원회의 행정사무를 처리하는 기관 및 중앙 행정기관	➤	고위공무원단에 속하는 공무원
정무직공무원을 장 (長)으로 하는 국가기관	➤	3급 이상 공무원
고위공무원, 3급 공무원을 장으로 하는 국가기관	➤	4급 이상 공무원
기타 국가기관(소속 기관 포함)	➤	개인정보 처리 업무 부서장
시·도 및 시·도 교육청	➤	3급 이상 공무원
각급 학교	➤	행정사무 총괄자
기타 공공기관	➤	개인정보 처리 업무 부서장

➤ 민간 : 사업주(대표자) 또는 임원(임원이 없는 경우, 개인정보 처리 업무 담당부서장)

- ✓ 개인정보 보호와 관련하여 이 법 및 다른 법령의 위반 사실을 알게 된 경우, 즉시 개선조치 시행, 필요 시 소속 기관의 장에게 보고
- ✓ 개인정보처리자는 보호책임자가 업무를 수행함에 있어서 정당한 이유 없이 불이익을 줘서는 안됨



2. 개인정보의 안전한 관리

🔒 개인정보파일의 등록 및 공개(제32조) : 공공기관만 해당

▶ 개인정보파일을 운용하는 공공기관이 등록해야 하는 사항

- ✓ 개인정보파일의 명칭, 운영 근거 및 목적, 개인정보 항목
- ✓ 개인정보의 처리방법 및 보유기간, 반복적인 제공의 경우 제공받는 자
- ✓ 공공기관의 명칭, 개인정보의 정보주체 수, 개인정보 처리 업무 담당 부서
- ✓ 개인정보의 열람 요구를 접수·처리하는 부서와 열람을 제한·거절할 수 있는 개인정보의 범위 및 사유

▶ 등록 예외

- ✓ 국가 안전, 외교상 비밀 등 국가의 중대한 이익에 관한 사항을 기록한 개인정보파일
- ✓ 범죄의 수사, 공소의 제기 및 유지, 형 및 감호 집행, 교정처분, 보호처분, 보안관찰처분과 출입국관리에 관한 사항
- ✓ 조세범처벌법, 관세법에 따른 범칙행위 조사에 관한 사항
- ✓ 내부적 업무처리만을 위하여 사용되는 개인정보파일
- ✓ 다른 법령에 따라 비밀로 분류된 개인정보파일

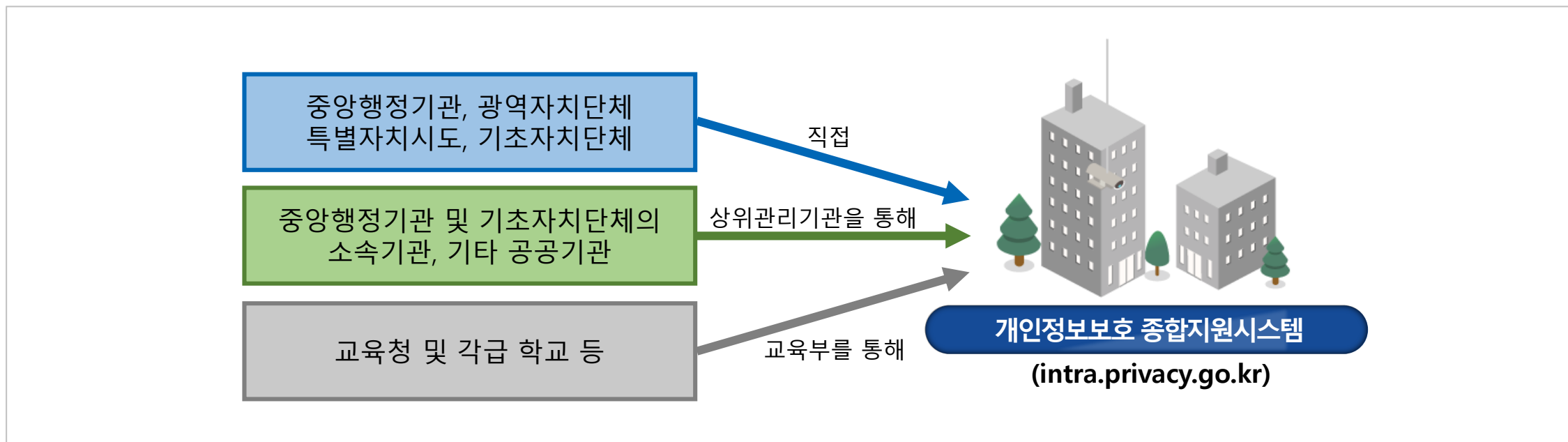


개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 개인정보파일의 등록 절차(제32조) : 공공기관만 해당



- ✓ 중앙행정기관 및 지방자치단체의 소속기관, 기타 공공기관은 상위 관리기관에 등록변경 사항의 검토 및 적정성 판단을 요청한 후, 상위 관리기관의 확인을 받아 개인정보보호 종합지원시스템(intraprivacy.go.kr)에 등록하여야 함
- ✓ 교육청 및 각급 학교 등의 개인정보 보호책임자는 교육부에 등록변경 사항의 검토 및 적정성 판단을 요청한 후, 교육부의 확인을 받아 등록하여야 함



2. 개인정보의 안전한 관리

🔒 개인정보 보호 인증(제32조의2)

개인정보처리자의 개인정보 처리 및 보호와 관련한
일련의 조치가 법에 부합하는지 등에 관하여 인증

▶ 정보보호 및 개인정보 보호 관리체계(ISMS-P)

✓ 인증의 기대 효과

- 체계적·지속적인 개인정보 보호 활동 가능
- 경영진 차원에서 상시 모니터링 체계 구축
- 개인정보 침해사고에 효율적 대응 가능
- 개인정보 보호에 대한 국민·고객의 신뢰 향상

✓ 인증기관: 한국인터넷진흥원

✓ 인증 유효기관: 3년

✓ 신청기관 유형: 공공기관, 대기업, 중소기업, 소상공인

* 정보통신서비스 제공자는 대기업 유형으로 인증

✓ 인증심사 기준: 3개 영역 102개 인증기준

※ 인증기준 방법·절차 등은 고시 참조

✓ 정보보호 및 개인정보 보호 관리체계 인증에 관한 고시 시행: 2018년 11월 7일



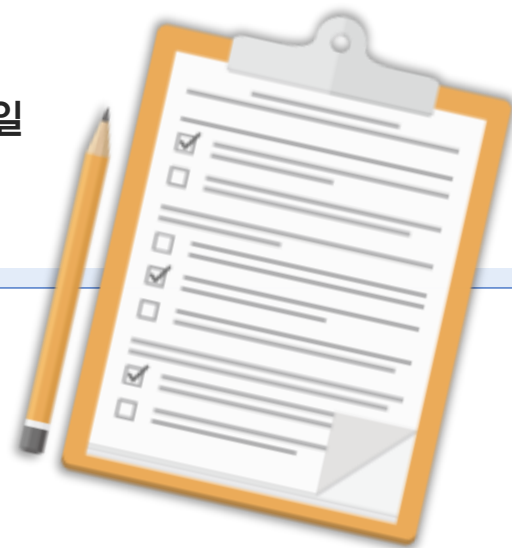


2. 개인정보의 안전한 관리

개인정보 영향평가(제33조) : 공공기관만 해당

▶ 영향평가 수행대상

- ✓ 구축·운용 또는 변경하려는 개인정보파일로서 **5만명 이상의 정보주체**에 관한 **민감정보 또는 고유식별정보**의 처리가 수반되는 개인정보파일
- ✓ 구축·운용하고 있는 개인정보파일을 해동 공공기관 내부 또는 외부에서 구축 운용하고 있는 다른 개인정보파일과 **연계하려는 경우**로써 연계 결과 **50만명 이상의 정보주체**에 관한 개인정보가 포함되는 개인정보파일
- ✓ 구축·운용 또는 변경하려는 개인정보 파일로서 **100만명 이상의 정보주체**에 관한 개인정보파일



개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 개인정보 유출 통지 등(제34조) → 통지

▶ 적용 조항

법 제34조(개인정보 유출 등의 통지·신고), 시행령 제39조(개인정보 유출 통지의 방법 및 절차)

▶ 정의

[개정] 개인정보 유출 등: 개인정보가 분실·도난·유출

▶ 통지 요건

(1명 이상의 정보주체의) 개인정보가 유출 등이 되었음을 알게 되었을 때

▶ 통지 기한

[개정] 유출사실을 알았을 때 지체없이 – 정당한 사유가 없는 한 72시간 이내 (영 제39조 제1항)

[개정] [예외] 72시간이 넘어 통지할 수 있는 경우

✓ 유출 등이 된 개인정보의 확산 및 추가 유출등을 방지하기 위하여 접속경로의 차단, 취약점 점검·보완, 유출 등이 된 개인정보의 회수·삭제 등 **긴급한 조치가 필요한 경우**에는 그 조치를 한 후 지체 없이 정보주체에게 통지 가능(영 제39조 제1항)

▶ 통지 방법

- [개별 통지(서면 등의 방법)]
- [예외] 연락처가 없으면 30일 이상 인터넷 홈페이지에 게시 (인터넷 홈페이지가 없으면, 사업장 등 보기 쉬운 장소에 30일 이상 게시)

▪ [개정 전] 유출 → [개정 후] 유출 등(분실·도난·유출)

▪ [개정 전] 24시간 이내(정보통신서비스 제공자 등), 5일 이내(일반 개인정보처리자) → [개정 후] 72시간 이내



2. 개인정보의 안전한 관리

🔒 개인정보 유출 통지 등(제34조) → 통지

▶ 통지 내용

다음 5가지를 정보주체에 통지

1. 유출 등이 된 개인정보의 항목
2. 유출 등이 된 시점과 그 경위
3. 유출 등으로 인하여 발생할 수 있는 피해를 최소화하기 위하여 정보주체가 할 수 있는 방법 등에 관한 정보
4. 개인정보처리자의 대응조치 및 피해 구제절차
5. 정보주체에게 피해가 발생한 경우 신고 등을 접수할 수 있는 담당부서 및 연락처

[통지 내용 예외] 위 1 또는 2를 파악하지 못한 경우, 파악한 것과 3~5를 먼저 정보주체에 통지(우선 통지)하고, 나머지는 파악한 즉시 통지(추후 통지)

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 개인정보 유출 통지 등(제34조) → 신고

▶ 적용 조항

법 제34조(개인정보 유출 등의 통지·신고), 시행령 제40조(개인정보 유출 등의 신고)

▶ 정의

개인정보 **유출 등**: 개인정보가 **분실·도난·유출**

▶ 신고 요건

- 개인정보 유출 등이 되었음을 알게 되었을 때 다음 중 하나에 해당하는 경우(영 제40조 제1항)
 1. 1천 명 이상의 정보주체에 관한 개인정보가 유출 등이 된 경우
 2. **[신설]** 민감정보, 고유식별정보가 유출 등이 된 경우
 3. **[신설]** 외부로부터의 불법적인 접근에 의해 개인정보가 유출 등이 된 경우 //해킹에 의한 개인정보 유출
- **[신설]** [예외] 신고하지 않을 수 있는 요건 정의
 - ✓ 개인정보 유출 등의 경로가 확인되어 해당 개인정보를 회수·삭제하는 등의 조치를 통해 정보주체의 권익 침해 가능성이 현저히 낮은 경우

▶ 신고 기한

[개정] 유출사실을 알았을 때 지체없이 - 정당한 사유가 없는 한 72시간 이내 (영 제40조 제1항)

- ✓ 72시간이 넘어 신고할 수 있는 예외 규정은 없음

▶ 신고 내용

통지 내용과 동일, 신고 내용 예외도 통지 내용 예외와 동일

▶ 신고처

개인정보보호위원회 또는 한국인터넷진흥원

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 공공시스템 운영기관의 개인정보 안전성 확보 조치

[신설] 개인정보의 안전성 확보조치 기준(고시) 제3장 공공시스템 운영기관 등의 개인정보 안전성 확보조치(제14조~제17조)

- 일반적인 안전조치 이외에 공공시스템 운영기관이 추가로 지켜야 할 사항 명시
- 공공시스템: 다음에 해당하는 개인정보처리시스템 중 개인정보보호위가 지정한 시스템
 1. 2개 이상 기관의 공통 또는 유사한 업무를 지원하기 위하여 단일 시스템을 구축하여 다른 기관이 접속하여 이용할 수 있도록 한 단일접속 시스템으로서 다음 각 목의 어느 하나에 해당하는 경우
 - 가. 100만명 이상의 정보주체에 관한 개인정보를 처리하는 시스템
 - 나. 개인정보처리시스템에 대한 개인정보취급자의 수가 200명 이상인 시스템
 - 다. 정보주체의 사생활을 현저히 침해할 우려가 있는 민감한 개인정보를 처리하는 시스템
 2. 2개 이상 기관의 공통 또는 유사한 업무를 지원하기 위하여 표준이 되는 시스템을 개발하여 다른 기관이 운영할 수 있도록 배포한 표준배포 시스템으로서 대국민 서비스를 위한 행정업무 또는 민원업무 처리용으로 사용하는 경우
 3. 기관의 고유한 업무 수행을 지원하기 위하여 기관별로 운영하는 개별 시스템으로서 다음 각 목의 어느 하나에 해당하는 경우
 - 가. 100만명 이상의 정보주체에 관한 개인정보를 처리하는 시스템
 - 나. 개인정보처리시스템에 대한 개인정보취급자의 수가 200명 이상인 시스템
 - 다. 「주민등록법」에 따른 주민등록정보시스템과 연계하여 운영되는 시스템
 - 라. 총 사업비가 100억원 이상인 시스템
- 공공시스템 운영기관: 공공시스템을 운영하는 공공기관

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



2. 개인정보의 안전한 관리

🔒 공공시스템 운영기관의 개인정보 안전성 확보 조치

공공시스템 운영기관의 내부 관리계획 수립·시행(제15조)

1. **관리책임자 지정***에 관한 사항(영 제30조의2 제4항)
2. 관리책임자의 역할 및 책임에 관한 사항
3. 개인정보취급자의 역할 및 책임에 관한 사항
4. 제4조 제1항 제4호부터 제6호까지 및 제8호에 관한 사항
5. 제16조 및 제17조에 관한 사항

공공시스템 운영기관의 접속기록의 보관 및 점검(제17조)

- ✓ 접속기록 등을 **자동화된 방식으로 분석**하여 불법적인 개인정보 유출 및 오용·남용 시도 탐지하고 그 사유를 소명 등 필요한 조치
- ✓ **공공시스템 이용기관**이 소관 개인정보취급자의 접속기록을 직접 점검할 수 있는 기능 제공

공공시스템 운영기관의 접근 권한의 관리(제16조)

- ✓ 접근권한 관리는 인사정보와 연계.
- ✓ 인사정보에 등록되지 않은 자는 계정 발급 불가. 불가피하면 발급 내역에 기록하고 발급 가능
- ✓ 계정 발급 시 개인정보보호 교육 시행, 보안서약서 징구
- ✓ 정당한 취급자에게만 접근권한이 부여됐는지, 접근권한 변경 내역을 반기별 1회 이상 점검
- ✓ 공공시스템 이용기관은 위 조치 수행

* **시행령 제30조의2**(공공시스템 운영기관 등의 개인정보 안전성 확보 조치 등)

④ 공공시스템운영기관은 공공시스템별로 **해당 공공시스템을 총괄하여 관리하는 부서의 장을 관리책임자로 지정**하여야 한다.

3

개인정보 보호법 법령 해석 사례





3. 법령 해석 사례

🔒 개인정보 수집·이용 분야

▶ 서비스 품질에 대한 고객만족도 조사를 하면서 고객의 동의없이 개인정보를 이용해도 되는지요?

- ✓ (민간) 고객으로부터 동의를 받거나 계약체결의 이행을 위하여 필요한 범위 내에서 동의를 받지 않고 만족도 조사가 가능함
(공공) 법령에 근거해 민원인의 동의를 받지 않고 만족도 조사가 가능함
 - 민간은 개인정보 보호법 제15조 제1항 제1호에 따라 정보주체의 동의를 받고 개인정보를 수집 이용할 수 있음
 - 또한 물건판매 또는 서비스 제공 등 계약과 관련한 만족도 조사는 정보주체의 계약 체결 및 이행을 위하여 불가피하게 필요한 범위 내에서 정보주체의 동의를 받지 않아도 개인정보 수집·이용할 수 있음
 - 공공의 경우, 제15조 제1항 제3호에 따라 법령 등에서 정하는 소관 업무의 수행을 위하여 불가피한 경우 동의를 받지 않고 개인정보를 수집 이용할 수 있음
 - 예를 들어 '공공기관의 운영에 관한 법률' 제13조에 따라 국민에게 직접 서비스를 제공하는 기관의 경우 매년 1회 이상 고객만족도 조사를 실시하여야 하며, '민원처리에 관한 법률' 제26조에 따라 행정기관의 장은 처리한 민원에 대하여 민원인의 만족 여부 및 개선사항 등을 조사하여 업무에 반영할 수 있음

KEY WORD

#고객만족도 조사, #제15조제1항제3호, #제15조제1항제4호



3. 법령 해석 사례

개인정보 수집·이용 분야

- ▶ 인터넷으로 서비스를 하는 회사입니다. 우리 회사는 홈페이지 회원가입 시 이용자로부터 동의를 받아 이름, 휴대폰 번호를 수집 및 저장하고 있습니다. 또한 SNS 계정을 통한 간편 회원가입 기능을 제공하고 있습니다. 이 과정에서 SNS 회사로부터 이용자의 이름, 휴대폰 번호, 이메일 주소를 제공받고 있습니다. 그런데 SNS 회사에서 받는 개인정보에 대해서는 이용자의 동의를 받지 않고, 우리 회사의 개인정보 처리방침에서 그 사실을 명시하고만 있습니다. SNS 회사에서 개인정보를 제공받는 것이 개인정보보호법에 위배되는지 궁금합니다.

✓ 정보주체의 동의를 받지 않고 SNS 회사에서 개인정보를 제공받아 이용하는 것은 개인정보보호법을 위반하는 것입니다.

- 일반적인 개인정보처리자는 「개인정보 보호법」 제15조 제1항 제1호에 따라, 정보주체에게 수집·이용되는 개인정보를 명확하게 알리고 동의를 받아야 하며, 이 때 동의의 방법은 법 제22조에 따릅니다.
- 따라서, 본인의 회사에서 정보주체에게 동의를 받은 내용 이외에 추가 개인정보를 제3자로부터 제공받을 때에는 별도의 동의를 받아야 하며, 별도의 동의없이 개인정보 처리방침에 기재하여 알리는 것만으로는 법 위반에 해당합니다.

KEY WORD

#SNS를 통한 개인정보 수집, #동의방법, #SNS 간편회원가입,

개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



3. 법령 해석 사례

🔒 개인정보 수집·이용 분야

- ▶ 교수로 재직 중인 사람의 사진, 성명, 성별, 출생연도, 직업, 직장, 학력, 경력 등의 개인정보를 해당 교수가 재직 중인 학과 홈페이지 등을 통해 수집하여 별도의 사이트에서 유료로 제공할 수 있는 지 궁금합니다.

- ✓ 학과 홈페이지 등에 자발적으로 공개된 개인정보를 수집하여 유료로 제3자에게 제공한 행위는 정보주체의 동의가 있었다고 객관적으로 인정되는 범위 내이므로 유료 등 영리 목적으로 제공하여도 정보주체의 별도 동의를 받지 않아도 됨
- 정보주체가 직접 또는 제3자를 통하여 이미 공개한 개인정보는 공개 당시 정보주체가 자신의 개인정보에 대한 수집이나 제3자 제공 등의 처리에 대하여 일정한 범위 내에서 동의를 하였다고 할 것임
 - 공개된 개인정보를 객관적으로 보아 정보주체가 동의한 범위 내에서 처리하는 것으로 평가할 수 있는 경우에도 동의의 범위가 외부에 표시되지 아니하였다는 이유만으로 또다시 정보주체의 별도의 동의를 받을 것을 요구한다면 이는 정보주체의 공개의사에도 부합하지 않고 정보주체나 개인정보처리자에게 무의미한 동의절차를 밟기 위한 비용만을 부담시키는 결과가 됨
 - 추가로 「개인정보 보호법」 제20조는 공개된 개인정보 등을 수집처리하는 때에는 정보주체의 요구가 있으면 즉시 개인정보의 수집 출처, 개인정보의 처리 목적, 제37조에 따른 개인정보 처리의 정지를 요구할 권리가 있다는 사실을 정보주체에게 알리도록 규정하고 있으므로 공개된 개인정보에 대한 정보주체의 개인정보자기결정권은 이러한 사후통제에 의하여 보호 받게 됨
 - 따라서 이미 공개된 개인정보를 정보주체의 동의가 있었다고 객관적으로 인정되는 범위 내에서 수집·이용·제공 등 처리를 할 때는 정보주체의 별도 동의는 불필요하다고 보아야 하고, 별도의 동의를 받지 아니하였다고 하여 「개인정보 보호법」 제15조나 제17조를 위반한 것으로 볼 수 없음
 - 정보주체의 동의가 있었다고 인정되는 범위 내인지는 공개된 개인정보의 성격, 공개의 형태와 대상 범위, 정보주체의 공개 의도 내지 목적뿐만 아니라, 정보처리자의 정보제공 등 처리의 형태와 정보제공으로 공개의 대상 범위가 원래의 것과 달라졌는지, 정보제공이 정보주체의 원래의 공개 목적과 상당한 관련성이 있는지 등을 검토하여 객관적으로 판단하여야 함

KEY WORD

#정보주체 이외로의 수집, #공개된 개인정보, #공개된 목적과의 관련성, #정보주체의 동의



3. 법령 해석 사례

🔒 개인정보 수집·이용 분야

- ▶ 방호직으로 근무하고 있는 사람입니다. 방호직의 특성상 근무중 순찰을 실시하는데 관리자가 공개적인 게시판에 순찰보고서라는 항목으로 해당근무자의 성명, 순찰포인트(순찰 위치), 누락여부 등을 기재하여 게시하고 있습니다. 개인정보 보호법 위반이 아닌지요?

- ✓ 개인정보 보호법 제2조 제1호가 규정하는 개인정보란 살아 있는 개인에 관한 정보로서 성명, 주민등록번호 및 영상 등을 통하여 개인을 알아볼 수 있는 정보이며, 해당 정보만으로는 특정 개인을 알아볼 수 없더라도 다른 정보와 쉽게 결합하여 알아볼 수 있는 것을 포함합니다.
- 따라서, 법인 또는 단체의 이름(상호), 소재지 주소 및 전화번호, 업무별 연락처, 영업실적 등 전적으로 법인 또는 단체에 관한 정보는 개인정보에 해당하지 않습니다.
 - 반면, 개인사업자의 상호명, 사업장 주소, 전화번호, 사업자등록번호, 매출액 등 사업체 운영에 관한 정보는 원칙적으로 개인정보에 해당하지 않으나, 대표자 성명을 비롯한 임원진과 업무 담당자의 이름, 개인 연락처, 사진 등은 법인이나 단체에 관한 정보이면서 동시에 상황에 따라 개인정보로 취급될 수 있습니다.
 - 결국, 회사 순찰근무자의 순찰 현황은 법인에 대한 정보이면서 개인정보로 취급될 수도 있어 내부 공개가 위법이라고 단정하기 어려우나 공개하는 경우 성명의 일부를 알아볼 수 없도록 처리함이 바람직합니다.

KEY WORD

#개인정보의 정의, #법인정보, #직원 개인정보, #내부공개



3. 법령 해석 사례

개인정보 수집·이용 분야

- ▶ 개인정보 보호법에 따라 개인 사업자가 주민등록증을 수집할 수 없는 것으로 알고 있습니다만, 혹시 어느 정도 수집할 수 있는지요? 예를 들면 이름, 주민등록번호 앞자리, 주민등록번호 첫 번째 뒷자리, 발행일, 주민등록기관, 사진 중에서.

✓ 이름, 생년월일, 성별, 발행일, 주민등록기관, 사진은 주민등록번호가 아니므로 동의를 받아 수집할 수 있음

- 「개인정보 보호법」 제24조의2에 따라 개인정보처리자는 법률 등에서 구체적으로 주민등록번호의 처리를 요구하거나 허용한 경우 등 외에는 주민등록번호를 처리할 수 없음
- 이 때 주민등록번호란 주민등록법 제7조의2에 따라 시장·군수 또는 구청장이 주민에게 개인별로 고유한 등록번호를 부여한 것으로 생년월일, 성별을 포함한 13자리의 번호임
- 따라서 이름, 생년월일, 성별, 발행일, 주민등록기관, 사진은 주민등록번호가 아니므로 동의를 받아 수집할 수 있음

KEY WORD

#개인정보 수집이용 동의서, #주민등록번호, #주민등록증



3. 법령 해석 사례

🔒 개인정보 목적 외 이용·제공 분야

- ▶ 기관 내부에서 자체감사를 위하여 소속 직원의 개인정보를 처리할 수 있는지, 있다면 어떤 조건에서 처리할 수 있는지 궁금합니다.

- ✓ 당해 기관이 국가기관 등 공공기관 직원인지, 민간기관인지에 따라 다릅니다. 공공기관은 동의 없이 소속 직원의 개인정보를 수집·처리할 수 있지만, 민간기관은 소속 직원의 동의가 필요합니다.
 - '공공감사에 관한 법률' 제20조 제1항과 제3항은 자체감사를 위하여 공무원 및 소속 직원에게 자료 제출을 요구할 수 있다고 규정하고 있으므로, 다른 법률에 특별한 규정있는 경우에 해당하며, 이에 따라 공공기관은 동의없이 자체감사를 위하여 소속직원의 개인정보를 처리할 수 있음
 - (민간기관인 경우) 민간기관(회사 등)은 「개인정보 보호법」 제18조 제2항 제1호에 따라 소속 직원의 동의를 받거나 노사협의를 통해 자체감사를 위하여 개인정보를 수집, 이용하거나 가지고 있는 개인정보를 목적 외 이용 가능함

KEY WORD

#자체감사, #목적외 이용제공 #제18조제2항제1호, #제18조제2항제2호



3. 법령 해석 사례

🔒 고정형 영상정보처리기기(CCTV) 분야

- ▶ 아파트 입구 대로변에서 불법 유턴 차량이 많아 사고 위험이 있어 당 아파트에서 불법 유턴 차량을 신고할 목적으로 CCTV를 설치해도 되는지 문의 드립니다. 공동주택관리법 시행규칙 제8조 3항에 의거하여 관리주체는 보안 및 방범 목적 외의 용도로 활용하거나 타인에게 열람하게 하거나 제공하여서는 아니된다고 명시 되어 있어 아파트에서 설치하여 대로변 불법차량을 파악하여 신고 목적용으로 설치하여도 되는지 문의 드립니다.

✓ 아파트 관리사무소에서 불법 유턴 차량 신고 목적으로는 공개된 장소에 CCTV를 설치할 수 없음

- 「개인정보 보호법」제25조 제1항에 따라 누구든지 공개된 장소에는 법령에서 구체적으로 허용하고 있는 경우, 교통단속을 위하여 필요한 경우, 교통정보의 수집분석 및 제공을 위하여 필요한 경우 등의 목적으로 영상정보처리기기(CCTV)를 설치운영할 수 있음
- 따라서, 아파트 관리사무소에서 불법 유턴 차량 신고 목적으로는 공개된 장소에 CCTV를 설치할 수 없음
- 참고로, 교통단속을 위하여 CCTV를 설치하려면 설치목적에 부합하는 단속 권한이 있는 자가 설치하여야 함

KEY WORD

#CCTV, #교통정보 수집분석, #단속목적, #CCTV 설치목적 #단속권한



3. 법령 해석 사례

고정형 영상정보처리기기(CCTV) 분야

- ▶ 아파트 입주민이 본인 이외 특정시간대 승강기 내부 이용자의 상태를 확인하기 위하여 영상정보 열람 등을 요구하고 있으며, 관리사무소에서는 동의가 필요한 사항으로 경찰관 입회 하에 검색이 가능하다고 통보하고 있는데, 적절한 처리인지요?

✓ 정보주체의 동의를 받지 않은 상태에서 경찰관 직무집행법을 근거로 경찰 입회하에 영상정보를 열람할 수 없음

- 「개인정보보호법」 제35조 제1항에 따라 정보주체는 자신의 개인정보 열람을 해당 영상정보처리기기운영자에게 요구할 수 있으며, 같은 법 제18조 제2항에 따라 정보주체로부터 동의를 받은 경우 등에는 개인정보를 목적 외 이용하거나 제3자에게 제공할 수 있음
- 따라서, 관리사무소는 해당 CCTV 영상에 수록된 정보주체의 동의를 받아 열람을 허용하되, 관리사무소에서 관련 영상을 먼저 확인 후 해당 부분에 대해서만 열람하도록 하여 열람을 필요 최소한으로 제한해야 함
- 한편, 경찰이 「경찰관 직무집행법」 제8조 제1항 따른 사실확인을 하기 위해 현장에 입회한 사실만으로 정보주체의 동의를 받지 않은 제3자에게 영상정보를 열람하도록 할 근거는 되지 않음

KEY WORD

#CCTV, #제3자 제공(열람), #경찰의 CCTV 열람



3. 법령 해석 사례

🔒 고정형 영상정보처리기기(CCTV) 분야

- ▶ CCTV 열람 신청 시 모자이크 처리 비용의 주체가 누구인지 알고 싶습니다. 신청인 부담인지, CCTV운영 담당기관 부담인지 답변 부탁드립니다

✓ 열람에 드는 비용은 열람요구자가 부담함

- 「개인정보 보호법」제35조 제1항 및 표준 개인정보 보호지침 제44조 제1항에 따라 정보주체는 영상정보 처리기기 운영자가 처리하는 개인영상정보에 대하여 열람 또는 존재확인 등을 해당 운영자에게 요구할 수 있도록 하였고, 이러한 요구를 받은 운영자는 지체없이 필요한 조치를 취해야 함
- 영상정보 처리기기 운영자는 사전에 공개한 열람절차와 방법에 따라 열람을 실시하되, 정보주체 이외의 자의 개인영상정보를 알아볼 수 없도록 모자이크 등 비식별조치를 취한 후 열람물을 제공해야 함
- 한편, 보호법 시행령 제47조에 개인(영상)정보처리자는 개인정보 열람요구를 한 정보주체에게 필요한 실비의 범위에서 비용을 청구할 수 있도록 하였으므로 열람요구자가 비용을 부담함
- 참고로, 시중에 보급된 비식별조치 프로그램을 활용하여 열람비용을 최소화하도록 권고함

KEY WORD

#CCTV, #열람비용, #모자이크



3. 법령 해석 사례

🔒 개인정보 목적외 이용·제공 분야

- ▶ 소속 공무원의 출장 여비 및 초과근무수당의 부당수령 등에 대한 제보나 의심 정황 발생 시, 제보 내용의 진위여부를 확인하기 위해 청사에 방호 목적으로 설치된 CCTV 영상정보를 이용할 수 있는지?

- ✓ **민간은 소속 직원의 동의 또는 노사협의를 통해 처리할 수 있으나, 공공기관은 공공 감사법에 근거하여 청사의 CCTV 영상을 자체감사에 이용할 수 있음**
 - '(공공)「개인정보 보호법」 제18조 제2항 제2호에 따라 법률의 특별한 규정이 있는 경우 정보주체 또는 제3자의 이익을 부당하게 침해할 우려가 있을 때를 제외하고는 개인정보를 목적 외 이용하거나 제3자에게 제공할 수 있음
 - '공공감사법 제20조 제1항, 제3항은 자체감사를 위하여 공무원 및 소속 직원에게 자료제출을 요구할 수 있다고 규정하고 있어, 다른 법률에 특별한 규정에 해당하며, 공공기관이 청사관리 목적으로 설치하여 수집한 CCTV 영상정보를 자체감사 목적으로 이용할 수 있음. 다만, 이 경우에도 다른 정보주체 등의 이익을 부당하게 침해하지 않도록 하여야 함
 - (민간기관인 경우) 「개인정보 보호법」 제18조 제2항 제1호에 따라 정보주체의 동의를 받아 개인정보를 목적외 이용 및 제3자 제공할 수 있으므로 소속직원으로부터 동의를 받아 CCTV 영상정보를 자체감사에 이용할 수 있으며, 노사협의를 통해 처리할 수 있음

KEY WORD

#자체감사, #목적외 이용제공, #CCTV, #제18조제2항제1호, #제18조제2항제2호



3. 법령 해석 사례

개인정보 파기 분야

- ▶ 민원인이 지방자치단체에서 보유하고 개인정보 수집에 대한 동의의 철회를 주장하며 그 파기를 요구하고 있습니다. 현재 보유하고 있는 개인정보를 파기하여야 하는지 궁금합니다.

✓ 지방자치단체에서 보유하고 있는 개인정보의 수집·이용 근거가 법령에 기반한 것이 아니라 정보주체의 동의에 기반한 것이라면 파기하여야 합니다.

- 「개인정보 보호법」 제4조 제4호는 정보주체에게 '개인정보의 파기를 요구할 권리'를 인정하고 있으므로, 정보주체는 개인정보의 파기를 요구할 수 있습니다.
- 단, 지방자치단체에서 보유하고 있는 개인정보의 수집·이용 근거가 「개인정보 보호법」 제15조 제1항 제2호, 제3호 '법령에 기반한 것'인 경우는 파기할 필요가 없습니다.

※ 다른 법령에서 그 개인정보가 수집대상으로 명시되어 있는 경우 그 삭제를 요구할 수 없음

KEY WORD

#정보주체의 권리보장, #개인정보의 파기, #타 법령과의 관계



3. 법령 해석 사례

개인정보 파기 분야

- ▶ 회원관리 시스템에서 회원 탈퇴 시, 이름, 연락처, 주소 등 개인을 식별하는 정보는 모두 지체 없이 파기합니다. 이때, 생성정보였던, 회원번호 000001도 함께 파기하여야 하는 것일까요? 회원번호 신규 생성 등을 위하여 회원번호만 따로 순차적으로 관리하려 합니다.

✓ **개인을 식별할 수 없는 숫자는 개인정보가 아니므로 파기 불필요.**

- 「개인정보 보호법」 제21조 제1항에 따라 개인정보처리자는 다른 법령에 따라 보존하여야 하는 경우 이외에는 보유기간이 경과하거나 처리 목적 달성 등 그 개인정보가 불필요하게 되었을 때 지체 없이 그 개인정보를 파기하여야 함
- 따라서, 개인정보의 처리 목적이 달성된 경우 개인을 식별할 수 있는 정보(이름, 연락처, 주소 등)는 모두 지체 없이 파기해야 함
- 다만, 법 제58조의2에 따라 이 법은 시간비용기술 등을 합리적으로 고려할 때 다른 정보를 사용하여도 더 이상 개인을 알아볼 수 없는 정보에는 적용하지 아니함
- 따라서, 관련정보가 모두 파기되어 연계 생성된 회원번호를 더 이상 누구의 개인정보인지 알아볼 수 없다면 이는 익명 정보로서 파기하지 않아도 됨

KEY WORD

#개인정보의 범위, #개인정보의 파기, #회원번호



3. 법령 해석 사례

개인정보 파기 분야

- ▶ 회원가입 시 개인정보 보유기간에 대해 '회원탈퇴 즉시 삭제'로 고지하고 있으나, 쿠폰 부정사용 등 불량회원을 식별하기 위해 일부 개인정보를 탈퇴 후 1개월 동안 보존하고 있는 경우, 수집동의서에 회원탈퇴 후 1개월까지 보관이라 명시하고 동의를 받아야 할까요?

✓ 개인정보 추가보관에 대한 동의를 받아 추가로 보관할 수 있음.

- 「개인정보 보호법」 제21조 제1항의 다른 법령에 따라 보존하여야 하는 경우 이외에는 보유 기간이 경과하거나 처리 목적 달성 등 그 개인정보가 불필요하게 되었을 때 지체 없이 그 개인정보를 파기하여야 합니다.
- 개인정보 추가 보관에 대하여 사전동의를 받지 않은 회원이 탈퇴한 경우 지체 없이 해당 정보를 파기하여야 합니다.
- 다만 「개인정보 보호법」 제15조에 따라 회원 가입시 혹은 탈퇴 이전에 정보주체(회원)에게 개인정보의 보유 및 이용기간 등에 대한 동의를 받은 경우에는 해당 개인정보를 필요한 범위내 추가로 보관할 수 있습니다.

KEY WORD

#개인정보의 파기, #유효기간제 #추가보관, #개인정보 수집이용 동의서, #불량회원



3. 법령 해석 사례

🔒 개인정보 파기 분야

- ▶ 전자상거래법 시행령 제6조에 따라 대금결제 및 재화 등의 공급에 관한 기록: 5년 등 개인정보 보존기간을 정하고 관리하고 있습니다. 회원이 결제와 관련하여, 7년 전 기록에 대한 조회를 요청하는 경우가 있는데, 위 보존기간 이상 개인정보를 보존해도 되는지요?

✓ 고객에게 연장보존에 대한 동의를 받으면 연장하여 보존할 수 있음

- 「개인정보 보호법」 제21조 제1항에 따라 개인정보처리자는 다른 법령에 따라 보존하여야 하는 경우 이외에는 보유기간이 경과하거나 처리 목적 달성 등 그 개인정보가 불필요하게 되었을 때 지체 없이 그 개인정보를 파기하여야 함
- 법령에서 보존기간을 별도로 정한 경우 보존기간이 경과되면 지체없이 개인정보를 파기해야 하나, 법 제15조 제2항에서 정한 개인정보의 수집·이용 목적, 수집하려는 개인정보의 항목, 개인정보의 보유 및 이용 기간, 동의를 거부할 권리가 있다는 사실 및 동의 거부에 따른 불이익이 있는 경우에는 그 불이익의 내용을 고객에게 알리고 새로 동의를 받으면 연장하여 보존할 수 있음

KEY WORD

#개인정보의 파기, #연장보존 #법령의 보존기간, #개인정보 수집·이용 동의서



3. 법령 해석 사례

🔒 개인정보 파기 분야

- ▶ 온라인쇼핑몰을 운영하면서 각종 이벤트를 개최할 때 별도 본인인증이 없는 간편가입 회원도 ID별로 참여가 가능하도록 하자, 이를 악용하여 수백개의 ID를 생성하여 멤버십포인트를 적립 및 사용하는 회원이 있어 회원가입 동의를 받아 부정고객에 한해 개인정보를 '영구' 보존하면서 걸러내려고 하는데, 해도 괜찮은지요?

✓ 개인정보 영구 보존은 보존 기한이 없으므로 법에 위반됨

- 「개인정보 보호법」 제21조 제1항에 따라 개인정보처리자는 다른 법령에 따라 보존하여야 하는 경우 이외에는 보유기간이 경과하거나 처리 목적 달성 등 그 개인정보가 불필요하게 되었을 때 지체 없이 그 개인정보를 파기하여야 함
 - 따라서, 별도의 보존기간을 정하지 않은 경우 개인정보의 처리 목적 달성 등 그 개인정보가 불필요하게 되었을 때까지 보유한다는 형태의 동의를 구하면 되나, '영구 보존'은 이러한 기한이 없으므로 법에 위반됨
- ※ 공공기관은 「공공기록물 관리에 관한 법률」에 따라 개인정보를 영구 보존할 수 있음

KEY WORD

#개인정보의 파기, #영구보존, #보유기간, #처리목적 달성, #보유기간 경과, #개인정보 수집이용 동의서



3. 법령 해석 사례

개인정보 업무 위탁 분야

- ▶ 산업안전보건법상 사업주가 안전보건관리책임자 등에 대해 직무교육을 실시하도록 되어 있고, 교육기관에 수강신청서를 제출하도록 되어 있습니다. 이 경우 해당 교육을 진행하는 안전보건 교육기관(예: 대한산업안전협회)은 개인정보 처리 위탁사에 해당하는지요?

- ✓ '업무 위탁' 과 개인정보 '제3자 제공' 모두 개인정보가 다른 사람에게 이전하거나 다른 사람과 공동으로 이용하게 되지만, 업무 위탁은 개인정보처리자의 업무처리 범위 내에서 개인정보 처리가 행해지고 위탁자가 위탁자인 개인정보처리자의 관리·감독을 받으며, 제3자 제공은 제3자의 이익을 위해서 개인정보 처리가 행해지고 제3자가 자신의 책임 하에 개인정보를 처리하게 됩니다.
 - 산업안전보건법에 따른 법정 위탁교육을 위해 개인정보처리자가 보유한 개인정보를 직무교육 기관이 처리하도록 위탁할 수 있으며, 이 경우 위수탁자 모두 법 제26조를 준수하여야 함

KEY WORD

#개인정보 처리위탁, #직무교육, #위수탁자 관리

부록

개인정보 관련 법령, 고시, 가이드라인 현황



개인정보의 안전한 관리와 개인정보 보호법 법령 해석 사례



(부록) 개인정보 관련 법령, 고시, 가이드라인 현황

🔒 개인정보보호 관련 가이드라인 현황

No	유관 가이드명	발행시기
1	가명정보 처리 가이드라인 개정	2024-02-05
2	공공·민간 고정형 영상정보처리기기 설치·운영 가이드 라인	2024-01-19
3	개인정보 법령해석 사례	매년 발행
4	개인정보 보호법 및 시행령 개정사항 안내	2023-12-29
5	개인정보보호 가이드라인(공공기관 편)	2023-12-28
6	홈페이지 개인정보 노출방지 안내서	2023-12-19
7	개인정보보호 가이드라인(통계작성 편)	2023-11-15
8	개인정보 유출 등 사고대응 매뉴얼	2023-10-16
9	개인정보 보호 가이드라인(온라인 경품행사편)	2023-05-03
11	2022 가명정보 활용 우수사례집	2023-03-28
12	우리 기업을 위한 EU 일반 개인정보보호법(GDPR) 가이드북	2023-02-03
13	개인정보 보호 가이드라인(인사·노무편)	2023-01-31
14	개인정보 영향평가 대가산정 가이드 및 계산기	2022-12-15
15	아동·청소년 개인정보 보호 가이드라인(2022.7. 제정)	2022-07-22

No	유관 가이드명	발행시기
16	개인정보 처리방침 작성지침	2022-03-03
17	알기쉬운 개인정보 처리 동의 안내서	2022-03-03
18	소상공인을 위한 개인정보보호 핸드북	2022-02-18
19	공동주택 개인정보보호 상담사례집	2022-01-18
20	스마트도시 개인정보 보호 가이드라인	2021-12-31
21	긴급 상황 시 개인정보 처리 및 보호수칙	2021-10-28
22	생체정보 보호 가이드라인	2021-09-08
23	개인정보 보호법 표준 해석례	매년 발행
24	인공지능(AI) 개인정보보호 자율점검표(개발자·운영자용)	2021-07-20
25	사회복지시설 개인정보보호 가이드라인	2021-01-04
26	약국 개인정보보호 가이드라인	2021-01-04

* 개인정보포털 → 자료 → 지침자료

https://www.privacy.go.kr/front/bbs/bbsList.do?bbsNo=BBSMSTR_000000000049

감사합니다



※ 본 교재의 저작권은 한국인터넷진흥원에 있으며 교육 목적 외 상업적 등의 목적으로 재편집 사용을 금합니다.

개인정보 유·노출예방

믿을 수 있는 개인정보 활용, 신뢰사회의 기본입니다
Privacy by Trust, Trust by Privacy



Contents

- 1 개인정보 유·노출 개념
- 2 개인정보 유·노출 원인 및 사례
- 3 개인정보 유·노출 예방



1

개인정보 유·노출 개념





1. 개인정보 유·노출 개념

🔒 개인정보 “유출” 및 “노출”의 정의

▶ “개인정보” 『유출』이란?

- 정보주체의 “개인정보”에 대하여 개인정보처리자가 통제를 상실하거나 또는 권한 없는 자의 접근을 허용한 경우

▶ “개인정보” 『노출』이란?

- 홈페이지 상 개인정보가 공개되어 누구든지 알아볼 수 있는 상태

유출

- 법령이나 개인정보처리자의 자유로운 의사에 의하지 않고 개인정보가 해당 개인정보처리자의 관리통제권을 벗어나 제3자가 그 내용을 알 수 있는 상태에 이르게 된 것을 말함

노출

- 개인정보가 포함된 게시물이 누구든지 알아볼 수 있는 상태로 등록된 경우
- 이용자 문의 댓글에 개인정보가 공개되어 노출이 된 경우
- 개인정보가 포함된 첨부파일을 홈페이지 상에 게시한 경우



1. 개인정보 유·노출 개념

🔒 개인정보 노출 모니터링의 중요성

▶ 고유식별정보 등 사생활 침해가 우려되는 정보가 노출

- 고유식별정보(주민등록번호, 여권번호, 운전면허번호, 외국인 등록번호), 신용카드번호, 계좌번호, 바이오 정보 등이 노출

- 주민등록번호는 본인의 동의가 있더라도 법적 근거가 없으면 **처리 불가**
- 바이오 정보 등은 처리 시 **본인의 동의 필요** 및 **암호화 보관**하여야 하는 **중요 정보**

▶ 개인정보취급자

- 홈페이지에 노출된 개인정보를 신속히 삭제하지 않을 경우, 제3자에 의해 개인정보가 유출이 되는 등 급격히 피해가 확산됨

- 개인은 명의도용, 보이스피싱 등 범죄에 악용되고, 대량 스팸 수신 등 피해가 발생
- 기관은 개인정보 유출에 따른 **민사·행정·사법 책임** 및 **이미지 실추** 등





1. 개인정보 유·노출 개념

🔒 개인정보 유·노출 시 조치사항

노출

- 신속히 노출 페이지 삭제 또는 비공개 처리
- 검색엔진에 노출된 개인정보 삭제 요청 및 로봇 배제 규칙 적용(외부 검색엔진의 접근 차단)
- 시스템의 계정, 로그 등을 점검 후 분석결과에 따른 접속 경로 차단(제3자 접근 여부 파악)
- 재발방지를 위해 서버, PC 등 정보처리시스템의 백신을 최신으로 업데이트 후 디렉토리 점검



유출 등

- 개인정보처리자는 개인정보가 유출이 되었음을 알게 된 때 정보주체에게 지체 없이 통지(72시간 이내)

- 유출이 된 개인정보의 항목
- 유출이 된 시점과 그 경위
- 유출로 인하여 발생할 수 있는 피해를 최소화하기 위하여 정보주체가 할 수 있는 방법 등에 관한 정보
- 개인정보처리자의 대응조치 및 피해 구제절차
- 정보주체에게 피해가 발생한 경우 신고 등을 접수할 수 있는 담당부서 및 연락처

필수항목

- 피해 최소화를 위한 대책 마련 및 필요한 조치 실시
- 신고 대상

- ① 1천명 이상의 정보주체에 관한 개인정보가 유출이 된 경우
- ② 민감정보, 고유식별정보가 유출이 된 경우
- ③ 외부로부터의 불법적인 접근에 의해 개인정보가 유출이 된 경우

- 국가(개인정보보호위원회 또는 한국인터넷진흥원)에 신고하고 개인정보 유출 사실을 홈페이지에 30일 이상 게재

※ 개인정보 포털(www.privacy.go.kr)을 통하여 유출 등 신고



1. 개인정보 유·노출 개념

개인정보 유·노출 후속조치

▶ 노출 기관에 대한 조치

- ✓ 개인정보가 노출된 기관에 삭제 등 조치하도록 즉시 통보(이메일, 전화 등)
- ✓ 노출 정부·공공기관 대상 '개인정보 노출 모니터링 결과 통보 및 재발방지 협조 요청' 공문 발송(매월)
- ✓ 노출 기관 담당자 대상 "**개인정보 노출 재발방지**" 교육 실시(필수)
 - 권역별 집합 교육 참석 요청 공문 발송



반복·대량 노출 기관 및 교육 미참석 기관의 경우,
"개인정보 관리실태 특별점검" 대상에 포함 가능



1. 개인정보 유·노출 개념

🔒 개인정보 유·노출 후속조치

▶ 개인정보 처리 기관의 안전조치 의무 및 처벌 규정

✓ 안전조치 의무

- 개인정보 또는 **고유식별정보**가 분실·도난·유출·변조·훼손되지 않도록 안전성 확보에 필요한 **기술적·관리적·물리적 조치** 이행
(개인정보보호법 제24조제3항, 제29조)

✓ 안전성 확보 조치

- 안전성 확보조치에 필요한 세부사항은 개인정보보호위원회가 정하여 고시

번호	소명요청	조치할 사항	비고
1	고시 제6조 제3항	취급중인 개인정보가 인터넷 홈페이지, P2P, 공유설정, 공개된 무선망 이용 등을 통하여 열람권한이 없는 자에게 공개되거나 유출되지 않도록 접근 통제 등에 관한 조치 시행	
2	고시 제7조 제2항	비밀번호 및 바이오정보를 저장 시 암호화 (단, 비밀번호는 일방향 처리)	
3	고시 제7조 제3항	인터넷 구간 및 인터넷 구간과 내부망의 중간 지점(DMZ)에 고유식별정보를 저장하는 경우 암호화	
4	고시 제7조 제5항	고유식별정보, 생체인식정보를 개인정보취급자의 컴퓨터, 모바일기기 및 보조저장매체 등에 저장하는 경우 암호화	
5	고시 제8조 제1항	고유식별정보 또는 민감정보를 처리하는 개인정보처리시스템에 해당하는 경우 접속기록 1년 보관	



1. 개인정보 유·노출 개념

개인정보 유·노출 후속조치

▶ 개인정보 처리 기관의 안전조치 의무 및 처벌 규정

처벌 규정

관련 조항	내용	처벌규정
개인정보보호법 제64조의2	✓ 안전성 확보조치 미이행으로 개인정보 유출 발생 시	전체 매출액의 100분의 3을 초과하지 아니하는 범위에서 과징금을 부과
개인정보보호법 제75조 제2항 제5호	✓ 안전성 확보조치 위반	위반 시 3천만원 이하의 과태료

2

개인정보 유·노출 사례 및 조치





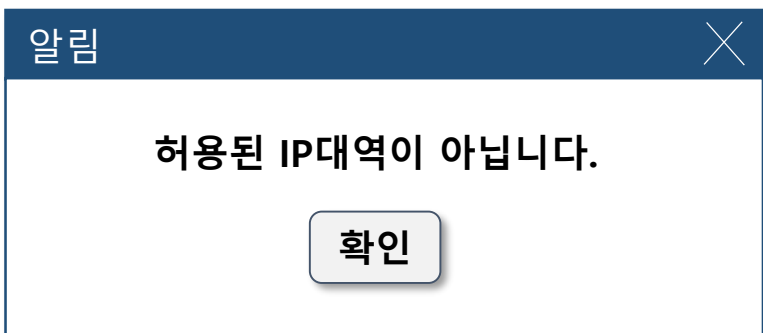
2. 개인정보 유·노출 사례 및 조치

외부공격

▶ DB 관리자페이지 공격으로 인한 유출

✓ 조치

- **Step 1.** 접속권한을 **IP주소, 포트, MAC주소 등으로 제한**하여 인가 받지 않은 접근을 제한
- **Step 2.** 정보통신망을 통해 외부에서 시스템에 접속 시 가상사설망(VPN) 등 **안전한 접속수단**을 사용하거나 **안전한 인증수단**을 적용
- **Step 3.** 개인정보취급자의 계정 설정 시 **안전한 비밀번호** 사용(영문, 특수문자, 숫자로 최소 8자리 이상)
 - * 특히 DB에 접속하는 DB관리자의 비밀번호는 변경 주기를 짧게 하는 등 강화된 안전조치를 적용
 - * ID: root, PW: root와 같이 취약한 비밀번호는 사용하지 않음



ID	KISABOAN001
PW	

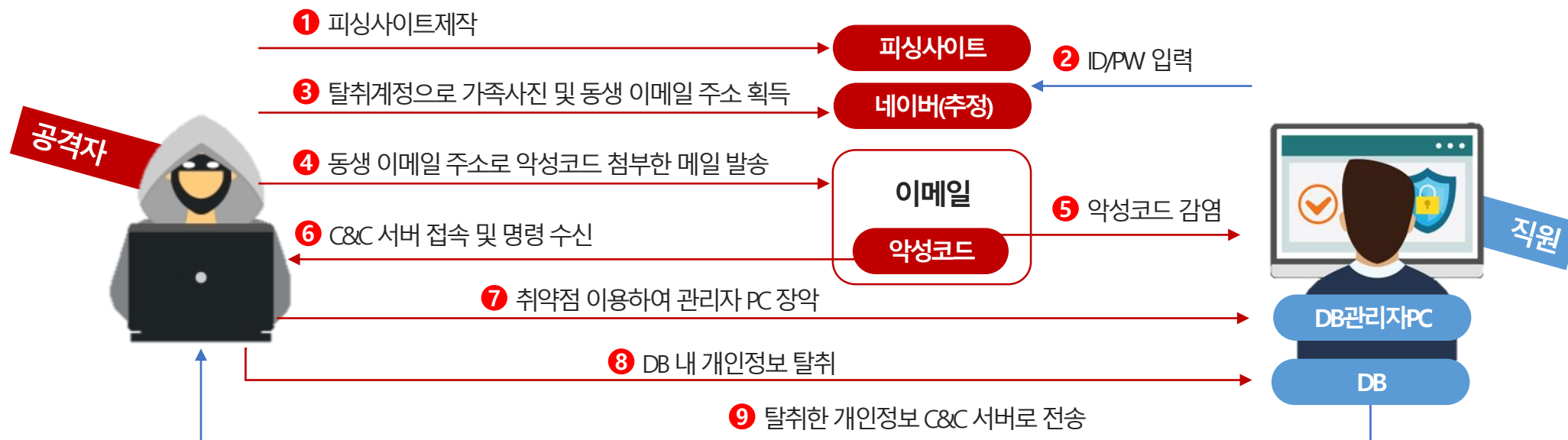


외부공격

▶ 지능형지속공격(APT, Advanced Persistent Threat)

✓ 조치

- Step 1. APT공격 대응 솔루션 도입운영 및 스팸메일과 첨부파일 필터링 및 차단
- Step 2. 의심스러운 이메일 열람 및 이메일 내 링크 주소 클릭, 첨부파일 실행 등 금지
- Step 3. 정기 보안교육과 모의훈련을 통해 취급자의인식 강화





2. 개인정보 유·노출 사례 및 조치

🔒 고의(내부직원 유출)

▶ 업무 담당자가 지인의 부탁을 받고 고객정보 유출

✓ 조치

- Step 1. 개인정보취급자 교육을 통해 유출사고에 대한 인식 강화
- Step 2. 개인정보처리시스템에 대한 접근 권한을 업무 수행에 필요한 최소한의 범위로 차등 부여
- Step 3. 내부관리계획에 개인정보 다운로드 기준을 마련하고, 접속기록을 매월 점검하여 개인정보 다운로드 시 그 사유를 확인
- Step 4. 보조저장매체의 반출입 통제를 위한 보안대책 마련하여 비인가된 사용 통제



개인정보취급자
교육



보안 USB



시건장치가 있는
케비닛



2. 개인정보 유·노출 사례 및 조치

고의(내부직원 유출)

▶ 퇴사한 직원이 개인정보처리시스템에서 개인정보 유출

✓ 조치

- **Step 1.** 개인정보취급자의 계정을 공유하여 사용하지 말고, **취급자 별로 계정을 부여**
- **Step 2.** 전보, 퇴직 등 인사이동이 발생하였을 경우 지체없이 **시스템 접근권한을 변경·말소**
- **Step 3.** 퇴직 점검표에 사용자계정 말소 항목을 반영하여 계정 말소 여부에 대해 확인 절차 마련
- **Step 4.** 개인정보처리시스템에 대한 접근 권한을 업무 수행에 필요한 **최소한의 범위**로 차등 부여
- **Step 5.** 내부관리계획에 개인정보 다운로드 기준을 마련하고, **접속기록을 매월 점검**하여 개인정보 다운로드 시 그 사유를 확인

➔ 개인정보 로그조회

2020.01.01 ~ 2020.03.01   

No.	계정	접속 일시	접속지 정보	정보주체	수행업무	상세 보기
1	Admin	2020.01.02 10:23	192.168.1.40	kim134	삭제	
2	Admin	2020.01.25 11:40	192.168.1.40	choi0045	등록	
3	Admin	2020.02.24 13:11	192.168.1.40	lee9204	수정	

개인정보처리시스템 접근제한 관리대장

순번	부서	사용자	계정	업무	접근권한	변경일시	변경사유	처리자
1	인사팀	홍팀장	hong123	인사관리	말소	2020.01.02 10:30	퇴사	Admin
2	인사팀	박대리	pack05	인사관리	인사정보(입력, 조회, 수정, 삭제)	2020.01.25 12:00	입사	Admin
3	인사팀	나직원	najwon33	인사관리	인사정보(입력)	2020.02.24 13:30	부서이동	Admin



2. 개인정보 유·노출 사례 및 조치

과실(담당자 업무 관련)

업무 담당자 행사 안내메일 단체발송

✓ 조치

- Step 1. 외부로 발송하는 이메일의 경우 **개별발송**을 기본 옵션으로 지정
- Step 2. 개인정보취급자 교육을 통해 이름, 이메일 주소가 개인정보임을 숙지
- Step 3. 이메일 개별발송 선택 시 개별발송 여부를 묻는 팝업창 게재 등 **시스템 개선**

받는사람 **kisa@kisa.or.kr** ← 받는 사람에는 노출 되도 문제가 없는 자신의 이메일이나 회사메일 하나정도 넣어주고 나머지 회원들은 숨은 참조에 넣어 개별로 발송

숨은참조 shho...

제목 Gmail에서 숨은참조로 동보메일 발송 방지하기

받는사람 ☒ **개인별** ? shh... sy... hr... 주소록

참조 ☐ 개별발송을 위해 체크박스 체크 후 전송

제목 ☐ 중요 ! 네이버에서 동보메일 발송 방지하기 약속잡기

받는사람 sh... sy... h... 주소록

제목 다음에서 동보메일 발송 방지하기

글꼴 10pt 가 가 가 가 가

☒ **한명씩 발송** ☒ 보낸메일 저장 ☐ 예약 발송 내용입력 후 한명씩 발송 체크 후 전송

Editor HTML TEXT



2. 개인정보 유·노출 사례 및 조치

🔒 개인정보가 포함된 게시물 및 댓글 게시

▶ 이용자 문의 댓글에 개인정보 노출

✓ 조치

- **Step 1.** 게시물을 비공개로 전환(게시물 작성자 또는 사이트 관리자)
- **Step 2.** 공개 필요 시, 마스킹 등의 방법을 통해 최소한의 개인정보를 기재
- **Step 3.** 검색엔진에 노출 여부 확인 및 저장된 페이지 삭제

홈페이지 관리자의 댓글에 개인정보 노출

작성자 : 김 [마스크] 작성일 : 2018.06.29 방문 : 10
제목 : 외국인 등록번호로 회원가입

안녕하세요.

이번에 교환학생으로 재학중인 외국인 친구가 회원가입을 하려고 하는데, 마이핀, 휴대폰이 없어서 본인확인이 불가능해서 회원가입을 못하고 있습니다.

외국인 등록번호로 회원가입을 할 수 있다고 들었는데 어떻게 해야하나요?
자세한 사항은 통화로 말씀드리고 싶네요.

관리자님 글 확인하시면 전화좀 부탁드립니다.

[다음글] 다음글이 없습니다.
[이전글] 이전글이 없습니다.

목록 답변 수정 삭제

한줄답변

관리자 (06.29) 전화로 말씀하신 외국인 분의 이름 [마스크], 외국인등록번호 90[마스크]가 맞나요? 빠른 시일내에 처리해드리겠습니다.

수정 삭제

»
비공개
전환

게시판을 비공개 게시판으로 운영

온라인상담

번호	제목	작성일
1132	주책 세금 문의	2018-10-29
1131	일반임대사업자에서 주택임대사업자로 전환할 경우에 대해서... 1	2018-10-26
1130	대형폐기물 1	2018-10-26
1129	동일한 내용의 행정소송이 최종 승소할 경우 1	2018-10-26
1128	건물 용도변경 관련 1	2018-10-26
1127	사업자신고 확인 1	2018-10-25

등록



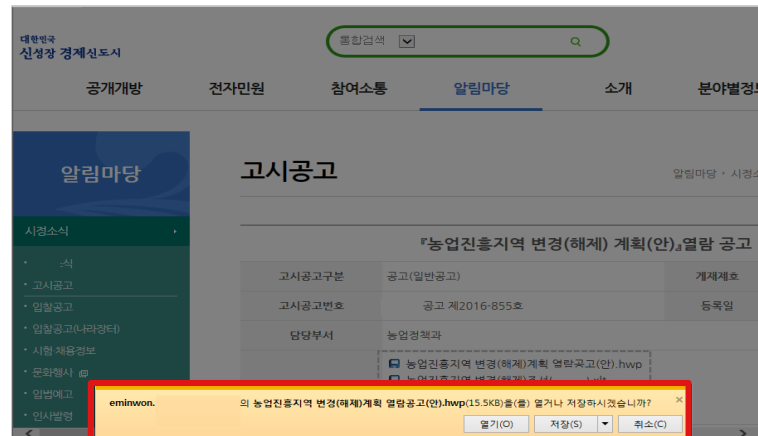
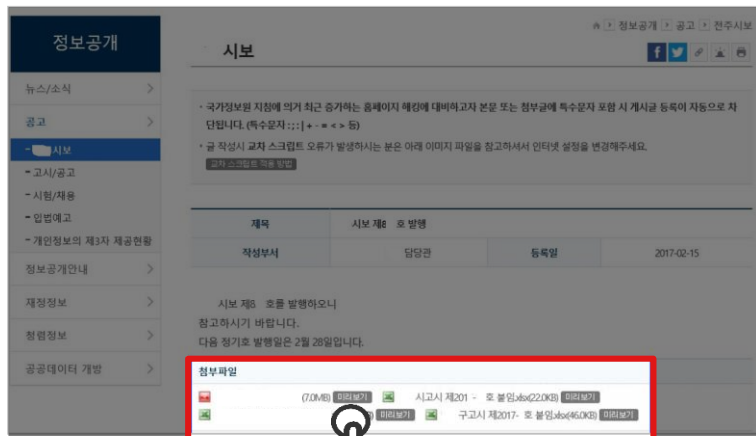
2. 개인정보 유·노출 사례 및 조치

🔒 개인정보가 포함된 첨부파일 게시

▶ 개인정보가 포함된 파일을 첨부하여 게시판에 게시

✓ 공통 조치

- **Step 1.** 게시물 또는 게시판을 비공개로 전환(게시물 작성자 또는 사이트 관리자)
- **Step 2.** 공개 필요 시, 개인정보 마스킹 등 비식별 처리
- **Step 3.** 검색엔진에 노출여부 확인 및 저장된 페이지 삭제



<클릭 시, "저장" 가능>



2. 개인정보 유·노출 사례 및 조치

🔒 이미지 파일 노출

▶ 첨부된 이미지 파일(PDF, JPG 등)에 개인정보 포함

✓ 조치

- 이미지 파일 **삭제** 또는 개인정보 부분을 **마스킹** 처리

마스킹 처리 조치 전

서울 부산 대구

등록일 | 해제된 질문 | 해제된 질문 | 상세분류별 보기

번호	제목	글쓴이	등록일
466	일반문의	공민/우쿠오카	2019.11.10
465	일반문의	공민/우쿠오카	2019.11.10
470	답변완료	공민/우쿠오카	2019.11.10
468	일반문의	공민/우쿠오카	2019.11.10
468	일반문의	공민/우쿠오카	2019.11.10
467	일반문의	공민/우쿠오카	2019.11.10

« < 1 2 3 4 5 »

주민등록증
홍길동(洪吉童)
501111-1234566
서울특별시 종로구
은원로 93, 1203동 1234호
(봉천동, 진달래아파트)
2019. 11. 25.
서울특별시 종로구청장

»
마스킹
적용

마스킹 처리 조치 후





2. 개인정보 유·노출 사례 및 조치

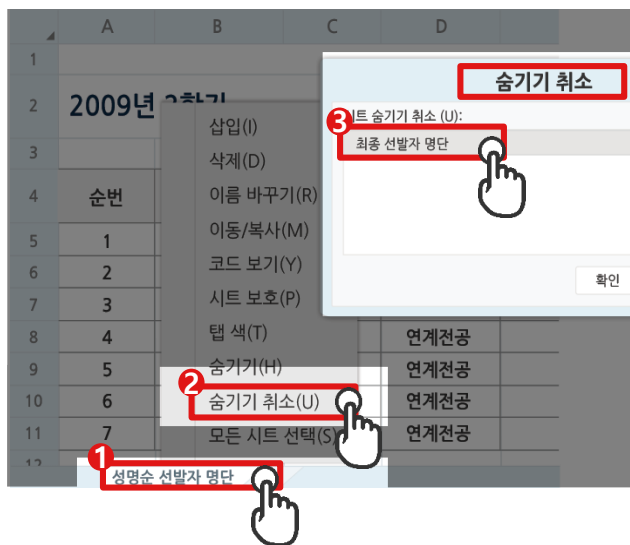
엑셀 파일에 노출

Sheet [숨기기] 처리

✓ 조치

- Step 1. 하단 Sheet 선택 > 오른쪽 마우스 클릭 > 숨기기 취소
- Step 2. 숨겨진 Sheet 삭제

Sheet가 숨겨져 있는 파일



»
숨기기
취소

Sheet 숨기기 취소한 파일

교원자격증 표시과목	주민등록번호	이수 학기	입학일
국어	881114	3	200
국어	860901	7	200
국어	880319	5	200
국어	880306	4	200

- 숨겨져있던 sheet가 나타남



2. 개인정보 유·노출 사례 및 조치

엑셀 파일에 노출

▶ 행/열 [숨기기] 처리

✓ 조치

- Step 1. 열(A,B...) 또는 행(1,2...) 전체선택 > 오른쪽 마우스 클릭 > 숨기기 취소
- Step 2. "행/열"에 기록된 개인정보 삭제 또는 마스킹 처리

행/열 숨기기 처리

● B 다음 E ?

	A	B	E
1	대형폐기물스티커 판매 현황		
2			
3	판매소명	주소	
4	AA 마트	SS시 AA구 FA동	
5	BB 타운	SS시 ZZ구 EA동	
6	NN 마트	SS시 AS구 AS동	
7	HH 슈퍼	SS시 AW구 SS동	
8	YY 월물	SS시 AZ구 QE동	
9	SS 슈퍼	SS시 AX구 EF동	
10	LL 마트	SS시 BA구 SD동	
11	AB 동점	SS시 AA구 BB동	
12	BC 상회	SS시 ZZ구 QQ동	
13	SF 슈퍼	SS시 AS구 EB동	
14	CZ 유통	SS시 AW구 CF동	
15	QW 슈퍼	SS시 AZ구 QB동	
16	BD 점	SS시 AX구 CV동	
17	ASE 점	SS시 BA구 BB동	

»
숨기기
취소

행/열 숨기기 취소

● 숨어있던 C와 D가 나타남

	A	B	C	D	E
1	대형폐기물스티커 판매 현황				
2					
3	판매소명	주소	대표자명	주민등록번호	
4	AA 마트	SS시 AA구 FA동	조	440227	
5	BB 타운	SS시 ZZ구 EA동	조	621013	
6	NN 마트	SS시 AS구 AS동	김	561230	
7	HH 슈퍼	SS시 AW구 SS동	이	550424	
8	YY 월물	SS시 AZ구 QE동	이		
9	SS 슈퍼	SS시 AX구 EF동	조		
10	LL 마트	SS시 BA구 SD동	유		
11	AB 동점	SS시 AA구 BB동	남	780822	
12	BC 상회	SS시 ZZ구 QQ동	김	630417	
13	SF 슈퍼	SS시 AS구 EB동	이	691110	
14	CZ 유통	SS시 AW구 CF동	이	750126	
15	QW 슈퍼	SS시 AZ구 QB동	오		
16	BD 점	SS시 AX구 CV동	김	750125	
17	ASE 점	SS시 BA구 BB동	관		

개인정보 유·노출예방 교육



2. 개인정보 유·노출 사례 및 조치

엑셀 파일에 노출

Sheet 보호 처리

✓ 조치

- Step 1. 해당 시트 오른쪽 마우스 클릭 > 시트 보호 해제(P)
- Step 2. "개인정보" 삭제 또는 마스킹 처리

Microsoft Excel

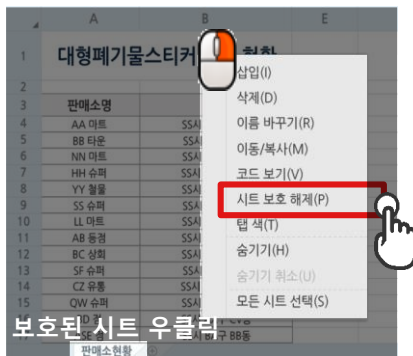


변경하려는 셀 또는 차트가 보호되어 있으며 읽기 전용입니다.

보호된 셀이나 차트를 수정하려면 먼저 [검토] 탭의 [변경 내용] 그룹에서 [시트 보호 해제] 명령을 사용하여 보호를 제거하십시오. 암호를 입력하라는 메시지가 표시될 수 있습니다.

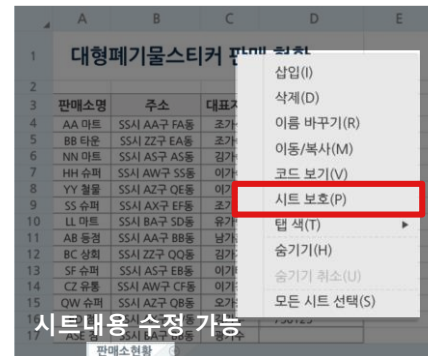
확인

Sheet 보호 상태(내용수정 불가)



»
시트보호
해제

Sheet 보호 해제(내용수정 가능)





2. 개인정보 유·노출 사례 및 조치

엑셀 파일에 노출

외부파일 참조

✓ 조치

- Step 1. 엑셀에서 함수 이용 시 셀 안의 값 확인(파일의 경로나 개인정보가 들어가지 않도록 주의)
- Step 2. 셀에 값을 넣을 때 데이터의 값만 사용하도록 조치
- Step 3. 엑셀 고급 옵션 중 '외부 연결값 저장' 기능 체크박스 해제

외부파일 참조 수식을 이용한 데이터 불러오기

D:\Desktop\W1. 채용별 데이터\W2019_0_하반기 공개채용_							
A	B	C	D	E	F	G	H
성명	생년월일	성별	나이	지원구분	최종학력	연락처	주소
홍	199			신	졸	010-12	울시
박	198			경	졸	010-45	중시
이	197			경	졸	010-01	주시
김	196			경	졸	010-52	남시
서	198			신	졸	010-22	광역시
박	199			신	졸	010-82	구시
윤	199			신	졸	010-72	천시
한	199			신	졸	010-52	경시
백	197			경	졸	010-32	울시



함수
이용 시
값만 사용

경로 노출 없이 데이터의 값만 이용

D:\Desktop\W1. 채용별 데이터\W2019_0_하반기 공개채용_							
A	B	C	D	E	F	G	H
성명	생년월일	성별	나이	지원구분	최종학력	연락처	주소
홍	199			신	졸	010-12	울시
박	198			경	졸	010-45	중시
이	197			경	졸	010-01	주시
김	196			경	졸	010-52	남시
서	198			신	졸	010-22	광역시
박	199			신	졸	010-82	구시
윤	199			신	졸	010-72	천시
한	199			신	졸	010-52	경시
백	197			경	졸	010-32	울시



2. 개인정보 유·노출 사례 및 조치

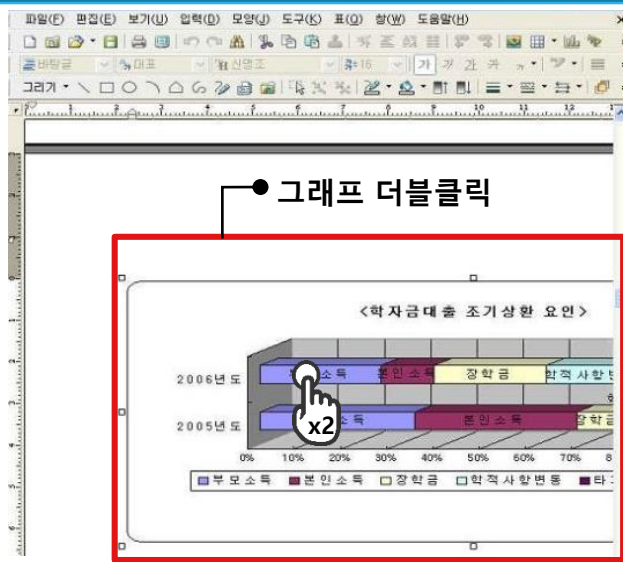
엑셀 파일에 노출

객체(OLE) 삽입

✓ 조치

- Step 1. 문서 내의 "표" 더블 클릭 후, OLE 객체 내 "개인정보" 포함 여부 확인
- Step 2. OLE 객체(엑셀시트)에 나타난 개인정보 삭제 또는 마스킹 처리

OLE 객체가 삽입된 파일



그래프 내
편집시트
나타남

OLE 객체에 포함되어 있던 엑셀시트

	E1	fx	주민등록번호	
	A	B	D	E
1	년도	은행	계좌번호	출생년도
2	2005	민	9452	81
3	2005	리	1235	80
4	2005	나	2352	49
5	2005	협	1324	77
6	2005	홍	2646	85
7	2005	나	3457	67
8	2005	협	9342	55
9	2006	리	2232	79
10	2006	나	1234	82
11	2006	민	5452	46
12	2006	리	5652	46
13	2006	나	7752	78
14	2006	협	9562	81
15	2006	홍	1582	67
16	2006	나	5342	55
17	2006	협	3434	79

개인정보
발견

개인정보 유·노출예방 교육



2. 개인정보 유·노출 사례 및 조치

🔒 한글파일에 노출

▶ 첨부된 한글파일(HWP, DOC)에 개인정보 노출

✓ 조치

- 문서에 포함된 "개인정보" 삭제 또는 "개인정보 보호" 기능으로 **마스킹**

개인정보가 포함된 한글문서

개인정보가 포함된 한글문서

● 불입자료 : 후원금 현금출납부 및 지출결의서(영수증 포함) 사본 1부.

(10) 종사자 명부

연번	직위	성명	주민등록번호	신규입용일	연간보수총액(원)	연간4대보험료(원)	비고
1	원장	이	550825-2	2006.3.1	21,886,000	2,268,480	
2	사무국장	유	670828-2	2005.1.1	25,856,840	3,414,720	
3	생활복지사	박	501112-2	2005.3.1	20,391,790	2,715,120	
4	생활지도원	황	600717-2	2005.3.1	20,621,580	2,748,960	
5	생활지도원	김	700321-2	2006.1.1	20,416,620	2,721,360	
6	생활지도원	권	821014-2	2007.1.1	19,148,420	2,448,960	
7	생활지도원	임	741007-2	2007.2.1	19,243,510	2,352,240	
8	훈련교사	김	780315-2	2006.6.1	19,380,840	2,296,320	
9	훈련교사	박	730214-2	2007.11.1	2,804,940	426,280	
10	조리원	김	561115-2	2007.1.1	17,896,180	2,292,240	
11	조리원	이	580408-2	2006.4.10	8,400,000	1,188,960	



개인정보
보호기능
이용

한글의 개인정보 보호 기능을 이용

한글의 개인정보 보호 기능을 이용

개인 정보 찾기 보호

김한컴 010-125-7899
이한글 010-778-5638
신한컴 010-758-8972

김한컴 *****
이한글 *****
신한컴 *****

② 도움말을 보려면 <F1>을 누르세요.

개인 정보 보호하기

개인 정보 선택 사항

☐ 전화번호(E) ☒ 주민등록번호(U) ☒ 외국인등록번호(N)
☐ 전자우편(M) ☒ 계좌 번호(J) ☒ 신용카드 번호(W)
☐ IP 주소(I) ☐ 생년월일(B) ☐ 주소(D)
☐ 사용자 정의(P) ☒ 기타(E):

보호 문자 선택

☒ ***** (G) ☐ ~~~~ (K) ☐ XXXX (X)
☐ 사용자 정의 문자(C): [] [문자표(H)...]

찾기(E) 보호하기(H) 모두 보호(S) 닫기



2. 개인정보 유·노출 사례 및 조치

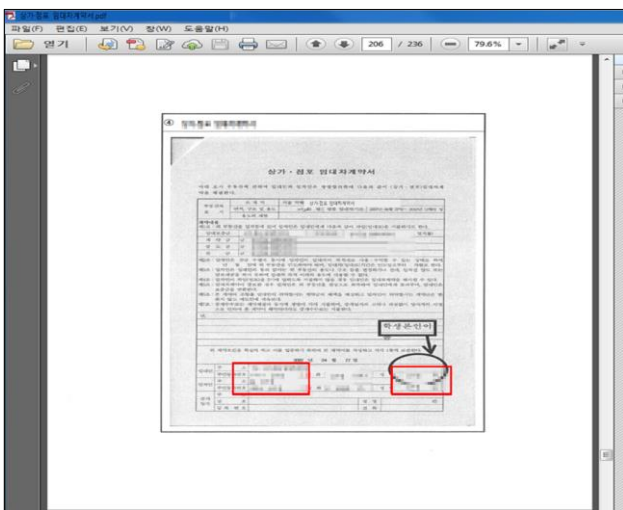
🔒 개인정보가 포함된 첨부파일 게시

▶ 이미지 파일(JPG, PDF 등)을 통한 개인정보 노출

✓ 조치

- Step 1. 비공개 게시판 운영
- Step 2. 게시물 비공개로 전환 또는 삭제
- Step 3. 이용자에게 개인정보를 입력하지 않도록 홈페이지 등에 안내

이미지형 PDF 파일에 의한 노출



»
비공개
설정

게시판 글 작성 시 안내 문구 삽입 및 비공개 설정

• 표시된 항목은 필수입력 항목입니다.

• 제목

작성자 김

공개여부 ☒비공개 ☐공개

• 내용

첨부파일 ※파일1개당 최대10MB까지만 가능합니다

※ 공개 글 작성 시 주민등록번호, 운전면허번호, 계좌번호 등 개인정보를 입력하시면 안됩니다!

☐ 위 글 등록을 위해 가입하신 개인정보수집 및 이용에 동의합니다.(필수)

저장 취소



2. 개인정보 유·노출 사례 및 조치

🔒 관리자페이지 접근제어 미흡

▶ 관리자만 볼 수 있는 페이지가 인증 과정을 거치지 않고 방치되어 일반 이용자에게 노출

✓ 조치

▪ Step 1. 올바른 관리자 페이지 설정

- ① 관리자 페이지 접속 시 "VPN"이나 "전용망" 등 **안전한 접속수단** 활용
- ② "OTP", "휴대폰", "공인인증서" 등 **안전한 인증수단** 적용
- ③ 관리자 페이지는 **특정 IP 및 인가된 IP**만 접근 가능토록 설정
- ④ 일반 이용자가 접근 가능한 **관리자 페이지 링크 삭제**

▪ Step 2. 검색엔진에 노출여부 확인 및 저장된 페이지 **삭제**

- ⑤ 관리자 페이지 주소는 추측하기 어려운 명칭으로 작성
- ⑥ **주기적인** 홈페이지 관리자 비밀번호 변경 및 로그인 시 **안전한 비밀번호 사용**
- ⑦ 미사용 페이지는 즉시 **삭제**

쉽게 유추 가능한 관리자페이지 인증없이 접속



»
전용망
구성 및
VPN인증

전용망 사용 또는 인증서비스 적용





2. 개인정보 유·노출 사례 및 조치

🔒 홈페이지 접속 경로(URL) 관련 오류

▶ 홈페이지 URL 값 변경 시 개인정보 노출

✓ 조치

- **Step 1.** 이용자 자신의 정보만 조회 가능하도록 접근제어
- **Step 2.** 회원 구분 값을 개인정보로 활용하는 경우 변경 필요
- **Step 3.** 홈페이지 설계 변경(GET 방식에서 POST 방식으로) 등을 통해 개인정보 노출 방지

URL값 변경 시 다른 회원의 정보가 노출

회원정보 수정
회원의 정보 중 변경된 내용이 있는 경우, 아래에서 수정해주세요.

※ 표시 필수입력사항

• 닉네임	
• 비밀번호 재설정	
• 비밀번호 확인	
• 이메일	
연락처	016 -
학교(학원)지역	경기도
학교(학원)구분	기타



파라미터 방식 변경

파라미터 값이 보이지않게 POST 방식 사용

Document
개인정보 수정

성명	주
주민등록번호	880924-



2. 개인정보 유·노출 사례 및 조치

🔒 디렉터리 리스팅 보안설정 미흡 - 디렉터리 리스팅 취약점으로 인해 노출

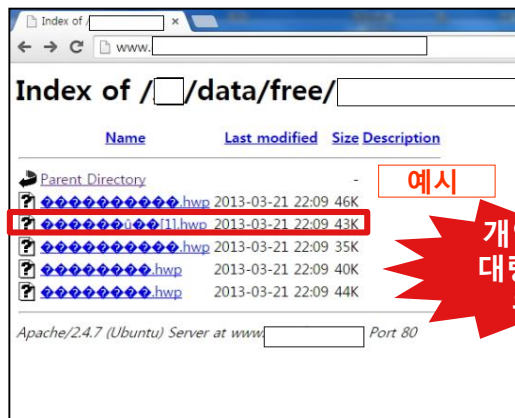
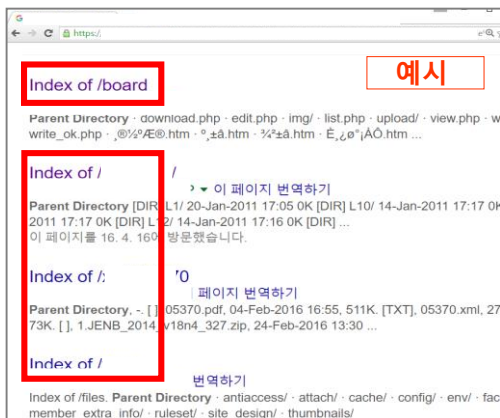
▶ 디렉터리 리스팅 취약점으로 인해 노출

- 서버관리자가 사이트 테스트 목적으로 사용하는 설정으로 인터넷 사용자에게 웹 서버 내 디렉터리와 파일 목록을 보여주는 기능
- 웹 서버의 URL로 "도메인 네임 + 디렉터리" 경로를 입력 했을 때, 웹 브라우저에 해당 디렉터리 내, 모든 파일 목록이 노출되는 보안 취약점

✓ 조치

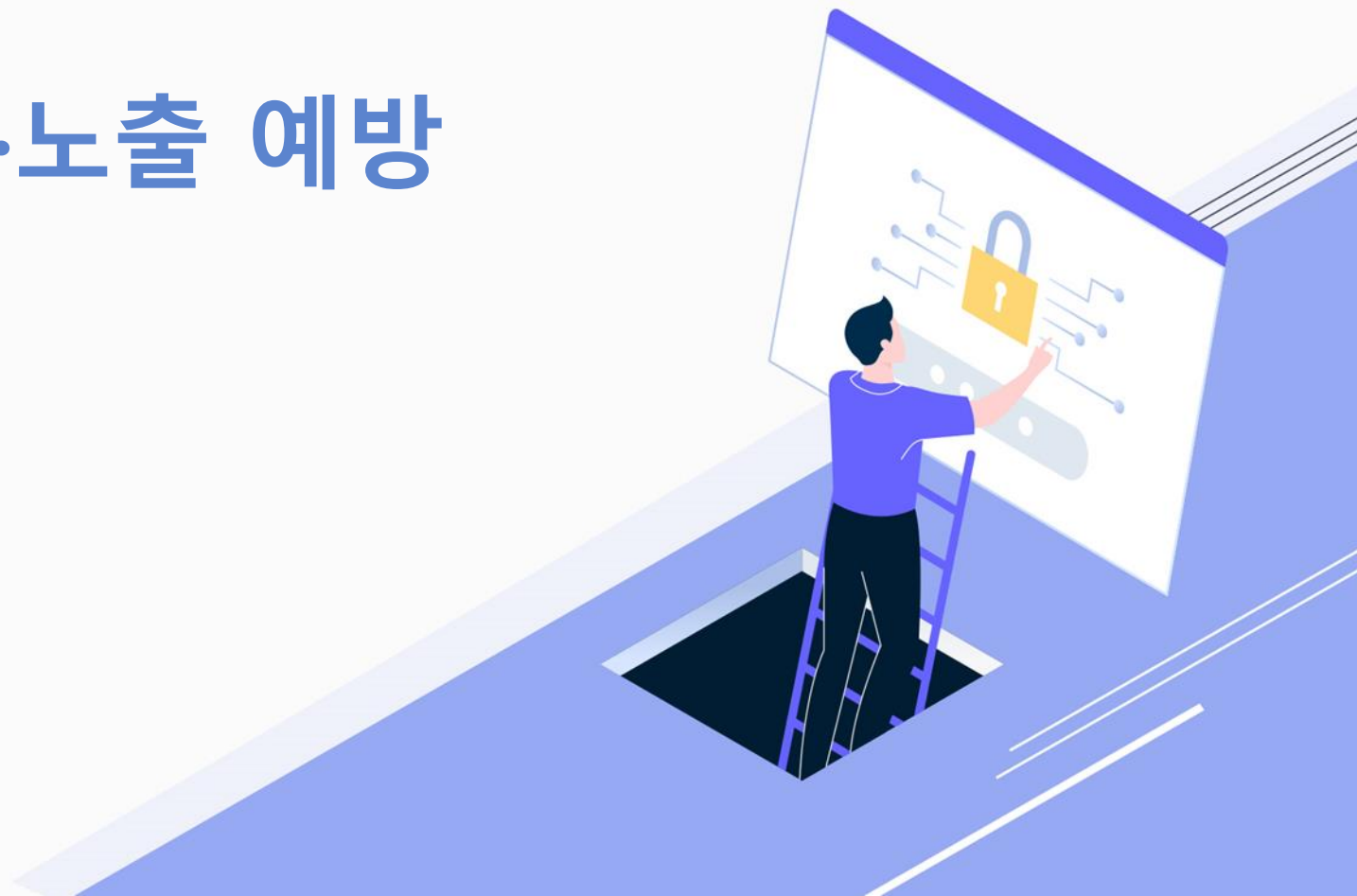
- **Step 1.** 운영체제 등 서비스 환경에 맞도록 디렉터리 리스팅 취약점 조치 필요
- **Step 2.** 접근제어 설정
- **Step 3.** 디렉터리 설정 및 변경

디렉터리 리스팅 취약점이 있는 홈페이지 검색(예시)



3

개인정보 유·노출 예방





3. 개인정보 유·노출 예방

안전성 확보 조치

▶ 안전성 확보에 필요한 기술적·관리적 및 물리적 조치



1. 내부관리 계획의
수립·시행 및 점검



2. 접근권한의 관리



3. 접근통제



4. 개인정보의
암호화



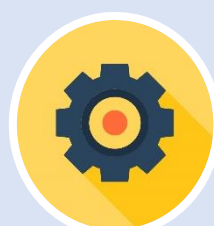
5. 접속기록의
보관 및 점검



6. 악성 프로그램 등
방지



7. 물리적 안전조치



8. 재해·재난 대비
안전조치



9. 출력·복사사
안전조치



10. 개인정보의 파기

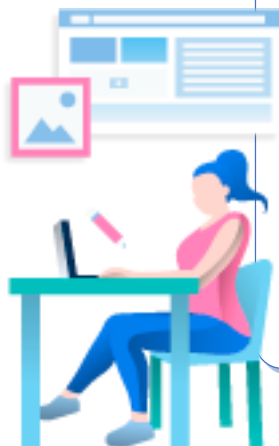


3. 개인정보 유·노출 예방

🔒 개인정보 노출 예방 수칙

운영자

- 게시판 운영 시 개인정보 노출 주의 **안내**
- 개인정보가 포함된 게시글 및 댓글 작성 시 **비공개** 설정
- 불가피하게 개인정보가 포함된 게시물 생성 및 게시글·댓글 작성시 **마스킹 등 비식별** 처리
- **첨부파일**을 등록하기 전 개인정보 유무 확인
- 주기적인 개인정보 **노출 점검**



개발자

- 관리자페이지 **접근제어** 설정
- 게시판을 **비공개** 또는 비밀글 설정이 가능하도록 구축
- **접속경로(URL)** 설정, **소스코드** 등에 개인정보 사용 금지
- **접속경로(URL)** 식별자는 '**숨김**' 처리하여 보호
- 홈페이지 개발 및 개편 시 웹·소스코드 **취약점 점검**
- **디렉토리 리스팅** 여부를 점검





3. 개인정보 유·노출 예방

🔒 운영자 개인정보 노출 예방수칙 5계명

1 게시판 운영 시 개인정보 노출 주의 안내하세요

- 서버관리자가 사이트 테스트 목적으로 사용하는 설정으로 인터넷 사용자에게 웹 서버 내 디렉터리와 파일 목록을 보여주는 기능
- 웹 서버의 URL로 "도메인 네임 + 디렉터리" 경로를 입력 했을 때, 웹 브라우저에 해당 디렉터리 내, 모든 파일 목록이 노출되는 보안 취약점

[예시]

• 운영에 부적합하다고 판단되는 글은 일임로 삭제처리되며, 게시물 내용에 따라 이동처리 할 수 있음을 알려 드립니다.

• 내용 입력시 주민등록번호, 연락처 등 개인정보가 노출되지 않도록 주의하시기 바랍니다.

제목			
작성자		☒ 전체공개	☐ 비공개
전화번호			
이메일	@	직접 입력	▼
내용			

웹 페이지 메시지



게시글 작성 시 주민등록번호, 연락처 등 개인정보가 포함되지 않았는지 확인하셨습니다가?

확인

취소



3. 개인정보 유·노출 예방

🔒 운영자 개인정보 노출 예방수칙 5계명

2 개인정보가 포함된 게시물 및 댓글 작성 시 비공개 설정하세요

- 게시물에 대한 비공개 여부를 설정할 수 있는 기능 필요
- 개인정보가 포함되는 민원 페이지나 각종 신청 관련 게시판은 비공개 설정

[예시]

접수번호	제목	작성자	등록일
37436	비공개 글입니다.	***	2018-08-01 13:55

* 표시된 항목은 필수입력 항목입니다.

* 제목	
작성자	김***
공개여부	☒ 비공개 ☐ 공개
* 내용	
첨부파일	찾아보기...

*파일 1개당 최대 10MB까지만 가능합니다

☐ 위 글 등록을 위해 기입하신 개인정보수집 및 이용에 동의합니다. (필수)

저장

취소



3. 개인정보 유·노출 예방

운영자 개인정보 노출 예방수칙 5계명

3 불가피하게 개인정보가 포함된 게시글·댓글 작성시에는 마스킹 등 비식별 처리하세요

- 이벤트 당첨, 합격자 공개 시 개인정보 마스킹

[예시]

당첨자 발표

1등: 호텔 이용권 1명

박* (010****25*)

2등: 외식상품권 20명

박* (010****51*)	구* (010****15*)
우* (010****84*)	백* (010****95*)
구* (010****32*)	이* (010****02*)
손* (010****01*)	설* (010****69*)
구* (010****67*)	이* (010****58*)
이* (010****19*)	김* (010****67*)
배* (010****33*)	배* (010****01*)
정* (010****13*)	이* (010****13*)
류* (010****40*)	김* (010****78*)
신* (010****73*)	신* (010****45*)



3. 개인정보 유·노출 예방

운영자 개인정보 노출 예방수칙 5계명

4 첨부파일을 등록하기 전에 개인정보 유무 확인하세요

- 첨부할 파일에서 불필요한 정보는 삭제 후 게시(업로드)
- 작성된 첨부 문서에서 개인정보의 포함여부 확인 후 게시(업로드)

엑셀문서

- 숨겨진 Sheet/행/열에 개인정보 포함 여부 확인
- 외부 공개용 문서의 경우 함수 사용은 지양하고, 데이터의 값만 활용
- 메모에 개인정보가 있는지 확인
- OLE 객체(그래프 등)는 더블클릭 후 원본자료에 개인정보가 있는지 확인

한글문서

- 한글의 "개인정보 보호 기능"(보기메뉴)을 이용하여 개인정보 유무 확인

이미지파일

- 이미지 파일에 개인정보 포함 유무 확인





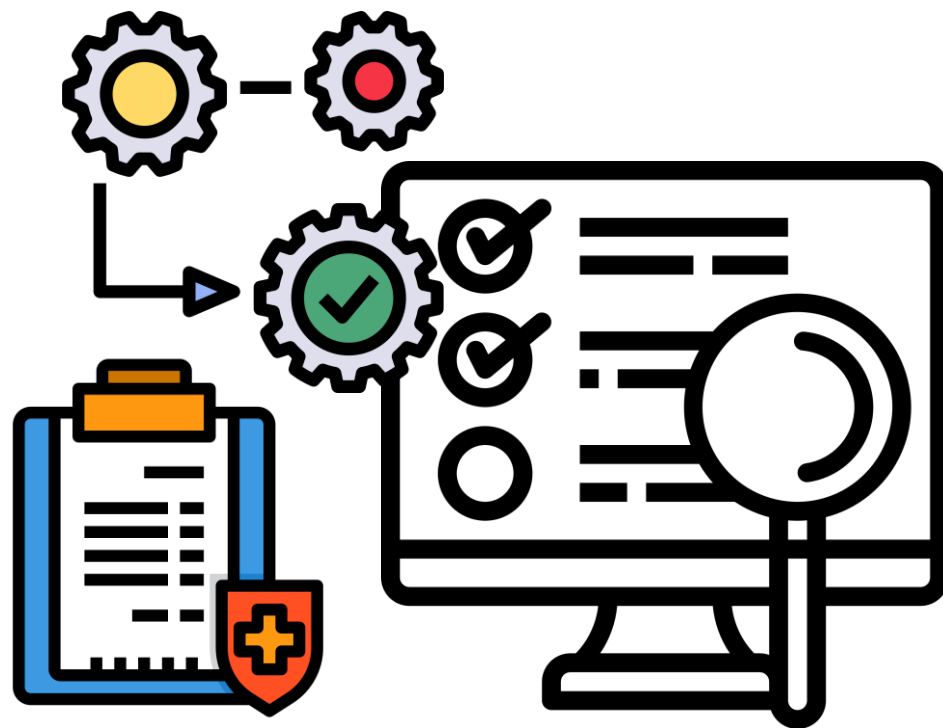
3. 개인정보 유·노출 예방

🔒 운영자 개인정보 노출 예방수칙 5계명

5 주기적으로 개인정보 노출 여부를 점검하세요

– 주기적으로 아래 사항을 점검

- ✓ 검색엔진(구글, 네이버, 다음 등) 확장기능을 이용한 개인정보 주기적 점검
(검색단어: "번호", "주민", "전화", "여권" 등 활용)
- ✓ 개인을 구분하는 값으로 개인정보 사용여부 점검
- ✓ 전송 및 저장시 개인정보 암호화 여부 점검
- ✓ (개발 시) 시큐어 코딩을 적용하여 개발
- ✓ (개발 후) 시큐어 코딩 준수여부 점검
- ✓ 웹 취약점 점검





3. 개인정보 유·노출 예방

🔒 개발자 개인정보 노출 예방수칙 6계명

1 관리자페이지를 안전하게 보호하세요

- 관리자페이지는 가급적 내부망에서만 연결되도록 구성
- "VPN"이나 "전용망" 등 안전한 접속수단 및 "OTP", "휴대폰", "공인인증서" 등 안전한 인증수단 적용
- 관리자페이지는 접속이 필요한 관리자만 접근할 수 있도록 인가된 IP로 제한하는 기능 적용

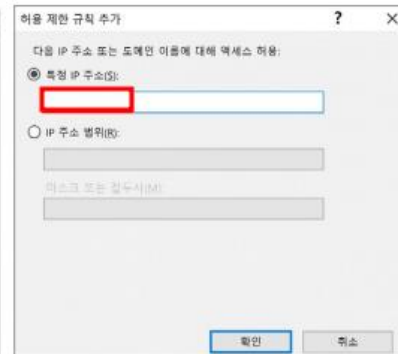
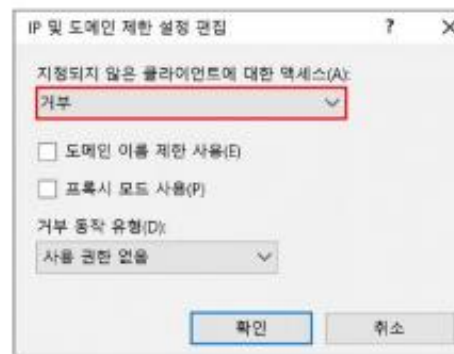
[예시]

✓ IIS 웹 서버(윈도우즈 서버)의 경우(IIS 7.x 이상 기준)

- "설정 > 제어판 > 관리도구 > 인터넷 서비스 관리자" 선택
- 해당 관리자페이지 폴더 > IP 주소 및 도메인 이름 제한 > 기능 설정 편집
- '지정되지 않은 클라이언트에 대한 액세스'를 거부로 설정(전체 접속 차단)
- 접속 허용할 IP주소 입력

✓ Tomcat 서버의 경우

- \$CATALINA_HOME(톰캣 홈 디렉터리)/conf/server.xml 파일 내용 중 <Host> 부분
- 필드 사이에 아래와 같은 설정을 추가한 후 서버를 재시작하면 관리자페이지에 대해 IP기반으로 허용된 IP만 접근이 가능하도록 제어가 가능



관리자페이지 접근제한 설정

```
<Host ...>
<Context path="/KISAadm" docBase="/tomcat/webapps/ROOT/KISAadm">
  <Valve className="org.apache.catalina.valves.RemoteHostValve"
    allow="허용할 IP"/>
</Context>
</Host>
```



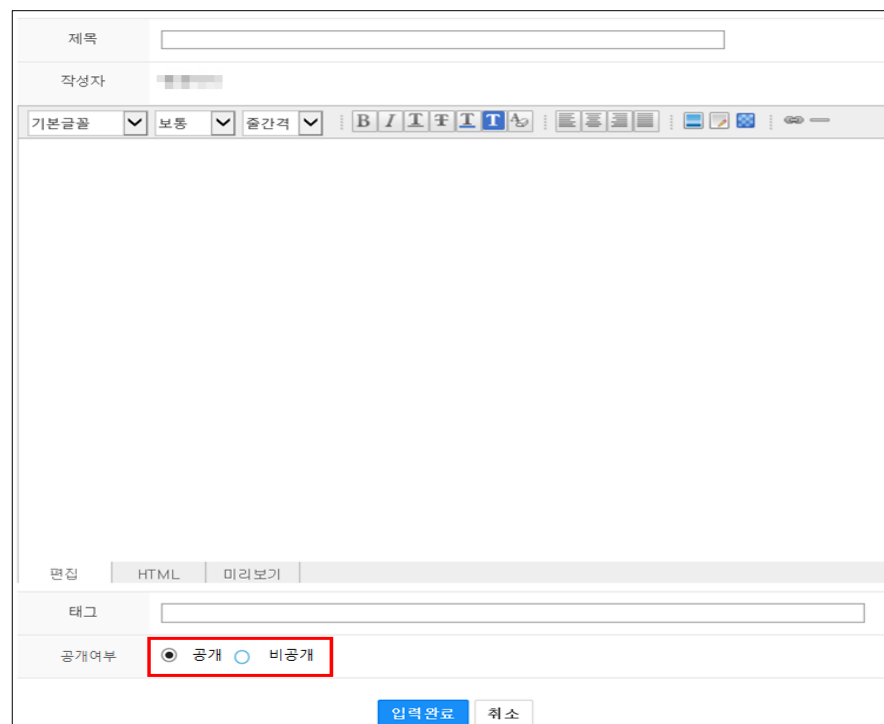
3. 개인정보 유·노출 예방

개발자 개인정보 노출 예방수칙 6계명

2 게시판은 비공개 또는 비밀글 설정이 가능하도록 구축하세요

- 게시글에 개인정보 포함시 비공개 또는 비밀글로 설정할 수 있는 기능 적용
- 비밀글은 작성자만 열람할 수 있도록 적용

[예시]



The screenshot shows a web board editor interface. At the top, there are fields for '제목' (Title) and '작성자' (Author). Below these is a rich text editor with a toolbar containing various formatting options like bold, italic, underline, and link. The main content area is a large text box. At the bottom, there are tabs for '편집' (Edit), 'HTML', and '미리보기' (Preview). Below the tabs is a '태그' (Tag) field. At the bottom right, there is a '공개여부' (Public/Private) section with two radio buttons: '공개' (Public) and '비공개' (Private). The '공개' button is selected and highlighted with a red box. At the very bottom, there are two buttons: '입력완료' (Finish Input) and '취소' (Cancel).



3. 개인정보 유·노출 예방

🔒 개발자 개인정보 노출 예방수칙 6계명

3 접속경로(URL) 설정, 소스코드 개발 등에 개인정보를 사용하지 마세요

- 회원정보 페이지 개발 시 접속경로(URL)에 생년월일, 주민등록번호 등 사용 금지
ex) `http://www.test.or.kr/board.php?search=info&list=19810101`
- 소스코드 내에 회원 식별자로 주민등록번호 등 사용 금지

[예시]

The diagram illustrates a security improvement in URL parameters. The top line shows a code snippet: `<td width="50%" height="10">작성자 : 주[redacted]</td><a href='?cmd=reply&info_idx=1&member_pno=880924'>sb`. A red box highlights the parameter `member_pno=880924`. A red arrow points down to the second line, which shows the same code snippet but with the parameter changed to `member_no=1004`: `<td width="50%" height="10">작성자 : 주[redacted]</td><a href='?cmd=reply&info_idx=1&member_no=1004_com=yes&gu`. A red box highlights the new parameter `member_no=1004`.

4 접속경로(URL) 식별자는 '숨김' 처리하여 보호하세요

- URL내 개인정보 등이 노출되지 않도록 POST 방식을 이용
ex) `http://www.test.or.kr/board.php?search=info&list=19810101`

- ✓ 홈페이지 설계 시 페이지 구분 값 등으로 개인정보를 사용하는 경우 URL에 개인정보가 노출됩니다.
웹브라우저 주소 표시줄에 개인정보가 노출되지 않도록 GET 방식 보다는 POST 방식을 사용해야합니다.



3. 개인정보 유·노출 예방

개발자 개인정보 노출 예방수칙 6계명

5 홈페이지 개편 시 웹·소스코드 취약점 점검하세요

- 소스코드 내 개인정보 포함여부 점검
- 소스코드 주석, 개발/테스트를 위한 에러 메시지 등에 서버정보 포함여부 확인

[예시]

Forbidden

You don't have permission to access / on this server.

Apache/2.2.3 (CentOS) Server at [redacted] Port 80

에러 페이지 내 서버정보 포함

```
29 /*본인요청으로 삭제(2017.11.09)*/  
30 /*if(''=="topstand" && '' == "2") {alert("실명제 적용에 따라 '반[redacted]'님은 '오[redacted]'님으로  
31 성명이 변경처리 되었습니다.\n\n이와 관련하여 문의사항은 전산과 [redacted]로 연락주시기 바랍니다.");}*/
```

웹페이지 소스코드 주석

- ✓ 모든 웹 페이지에 대해 개발단계에서 디버깅 및 테스트를 목적으로 작성한 주석구문에 서버 주요 정보가 포함되어 있을 경우 공격자가 해당 정보를 다른 취약점과 연계해 사용할 수 있으므로 제거해야 합니다.



3. 개인정보 유·노출 예방

개발자 개인정보 노출 예방수칙 6계명

6 디렉토리 리스팅 여부를 점검하세요

- 주기적인 점검 기본사항
- 디렉터리 리스팅 노출 방지 설정

- ✓ 검색엔진(구글, 네이버, 다음 등) 확장기능을 이용하여 내 홈페이지의 관리자페이지가 리스팅 되고 있는지 주기적 점검
(웹 서버의 url로 "도메인네임 + 디렉터리" 경로를 입력하여 웹브라우저에 해당 디렉토리 등 모든 파일목록이 노출되는지 점검)
- ✓ Apache
 - indexes "문자열"제거
- ✓ Tomcat
 - Param-value 값을 "False" 로 설정
- ✓ Nginx
 - Autoindex 값을 "off"로 설정
- ✓ 윈도우 인터넷 정보서비스(IIS)
 - 제어판 > 관리도구 > 인터넷서비스 관리자 > 기본 웹사이트 속성 정보 수정(디렉터리 검색 부분을 비활성화)

감사합니다



※ 본 교재의 저작권은 한국인터넷진흥원에 있으며 교육 목적 외 상업적 등의 목적으로 재편집 사용을 금합니다.